Executive summary

AI use cases in assurance, tax and security: 634 researched, fact-checked examples of AI changing the work, from the AI Transformation Advisor's knowledge base. October 2026.

Key takeaways

- **Broad and specific.** 634 examples across 29 focus areas in three fields, grouped on the next page into nine recurring categories. Every example names its sources and was checked against them.
- **Evidence strength differs by field.** Examples with a named deployment or measured result (grades A and B): security 58%, assurance 36%, tax 27%. Strongest: security operations, application security and AI security; audit controls and substantive testing. Thinnest: tax provision and Pillar Two, transfer pricing, corporate tax compliance, sustainability assurance.
- **AI mostly does a first pass that a person checks.** 48% of examples augment a step and 24% assist a person; 17% automate a step and 11% delegate a multi-step outcome to an agent with human checkpoints.
- **Read the numbers with care.** About 27% of the 1,132 outcome figures come from independent sources (regulators, academics, benchmarks); the rest are self-reported or vendor-published. Independent error or override rates for AI tools in live use are rare in all three fields.
- **People stay accountable.** In each field the rules keep a qualified person responsible: the auditor for the opinion, the tax practitioner under existing conduct rules, and security leaders for the decisions that start regulatory reporting clocks.
- **Beyond efficiency.** 73 examples change the service, pricing or operating model, not just a step: AI assurance services, agent platforms in tax firms, and security teams rebuilt around supervising AI.

By field

Field	Focus areas	Use cases	Named or measured (A/B)	Strongest areas
Assurance	10	206	75 (36%)	Controls testing, SOC reports, substantive testing
Tax	8	183	49 (27%)	Research and advisory, individual compliance, controversy
Security	11	245	141 (58%)	Application security, operations, AI security

How to read the rest of this document

Each field opens with its focus areas, then one card per use case: the **problem** in one sentence, the **approach** in a few bullets, and the organisations behind the **evidence**. Grades: **A** measured result reported by the named organisation; **B** named deployment, or a figure that is only an estimate; **C** vendor or analyst claim; **D** idea, not yet deployed. **Assist, Augment, Automate, Delegate** shows how much the AI does. No example uses client-confidential information.

Categories of use cases

Nine kinds of change recur in all three fields. A = assurance, T = tax, S = security; (A)-(D) = evidence grade.

Category	Use cases	Examples
Triage, monitoring and response AI sorts incoming work and watches signals; people handle exceptions and approve actions.	**157** A22 · T35 · S100	Assurance: Continuous, year-round control testing and monitoring instead of point-in-time cycles (B) Tax: Weekly IRS transcript checks to act before underreporter notices arrive (B) Security: Agentic alert triage: simple checks first, case built before analyst opens it (A)
Drafting with expert review AI drafts workpapers, memos, reports or fixes; a qualified reviewer signs off.	**83** A29 · T24 · S30	Assurance: AI-assisted walkthroughs that prepare, transcribe and draft process narratives (B) Tax: Drafting technical memos, advice letters and client emails from researched authority (B) Security: Draft incident summaries and executive updates, edited by the incident commander (A)
Documents to decisions, and reconciliation AI reads documents and records, checks them and flags breaks for a person.	**74** A38 · T21 · S15	Assurance: Agents match sampled items to supporting documents and bank activity (B) Tax: Agents read K-1 footnotes, map tax treatments and learn from logged overrides (B) Security: AI reviewer for access requests approves routine ones and escalates the rest (B)
Testing every item, not a sample AI tests whole populations and surfaces exceptions to investigate.	**32** A11 · T8 · S13	Assurance: Full-population testing of transactional and master-data controls instead of samples (A) Tax: AI risk targeting for audits at other tax authorities (A) Security: Scanning every code change before submission, with an agent proving reachability (A)
Research and knowledge assistants Cited research briefs, and answers from an approved knowledge base.	**67** A17 · T27 · S23	Assurance: Summarise board minutes with cited output to focus risk identification (B) Tax: Cited conversational tax research in place of keyword database search (B) Security: Customer security questionnaires answered from an approved knowledge base (A)
Agents that own a case end to end An agent takes a case to a drafted result, with human checkpoints.	**38** A11 · T19 · S8	Assurance: Auditor and client agents exchange evidence requests, with workpapers reviewed (EY pilot) (B) Tax: Agent prepares complex personal returns end to end for CPA sign-off (A) Security: Agent investigates alerts end to end; on-call staff supervise and correct (A)
Data conversion at scale AI converts or maps large volumes of data or code, with sampled checks.	**39** A6 · T18 · S15	Assurance: Standardised ERP data ingestion as the base for planning analytics (B) Tax: AI-proposed product tax codes with confidence scores, reviewed by a person (A) Security: Mapping and rationalising controls and evidence across frameworks with an agent (A)
Governing, testing and controlling AI Policies, tool approval, testing and oversight that make AI use defensible.	**99** A51 · T18 · S30	Assurance: Certify AI tools per use case, approve centrally, recertify on defined triggers (B) Tax: Dedicated AI team, champion network and training that protects the junior pipeline (B) Security: AI red teaming as standing practice: decision-led scope, in-house and outside testers (B)
New services, pricing and operating models What firms sell, how they price it and who does the work.	**45** A21 · T13 · S11	Assurance: Audit firms certify their own AI management systems before selling AI assurance (B) Tax: Value-based and fixed-fee pricing as AI shortens research and drafting (B) Security: Security team rebuilt around building and operating its own AI skills (B)

Assurance

External audit, SOC and attestation, sustainability assurance and assurance over AI; also in-house internal audit and SOX teams.

Focus area	What it covers	Evidence
Client acceptance and independence	Taking on and keeping clients, and proving independence.	**thin** 4 of 21 A/B
Planning and risk assessment	Understanding the entity and its own AI, risk assessment, fraud, materiality, scoping, budgets.	**moderate** 11 of 25 A/B
Controls testing	Walkthroughs, ITGCs, operating-effectiveness tests and deficiencies across ICFR, SOX and SOC work.	**strong** 16 of 25 A/B
Substantive testing	Journal-entry and fraud testing, evidence matching, confirmations, analytics, contracts, estimates.	**strong** 13 of 25 A/B
Specialists and experts	Using experts (valuation, actuarial, tax, forensic) and treating a client's AI as a specialist-like input; A/B entries are advisory, not audit.	**thin** 3 of 14 A/B
Completion and reporting	Disclosure checklists, tie-out, going concern, EQR, KAMs and CAMs, audit committee communications, the opinion.	**thin** 3 of 18 A/B
Quality management	Firm-level AI tool governance (certify, monitor, recertify) and engagement-level supervision and review of AI output; no measured outcome.	**moderate** 10 of 25 A/B
SOC reports and attestation	SOC 1, 2 and 3 and ISAE 3402 or 3000 end to end, compliance platforms, SOC 2 quality concerns.	**strong** 9 of 16 A/B
Sustainability assurance	ISSA 5000, CSRD limited assurance, GHG engagements; almost no AI evidence from assurance providers.	**thin** 0 of 13 A/B
Assurance over AI	Auditing an entity's AI used in ICFR, and standalone assurance over AI systems; named certifications, no measured outcome.	**thin** 6 of 24 A/B

Client acceptance and independence

Taking on and keeping clients, and proving independence. · 21 use cases · evidence thin (4 of 21 A/B)

AI-assisted conflicts and independence clearance across a multi-firm accounting network

Grade B · Augment

Problem. A private-equity-backed accounting network must clear conflicts and independence across member firms, which rely on spreadsheets, manual processes and long completion times before an engagement letter goes out.

Approach

- Crete Professionals Alliance feeds member-firm data into one warehouse; Intapp Conflicts uses AI risk-scoring so compliance staff focus on high-risk results.
- The compliance team reviews high-risk results and decides remediation; potential independence issues are escalated to partners.
- No time, accuracy or error figure is published (vendor-published); executives say the approach will relieve staff.

Evidence: Crete Professionals Alliance, Intapp · assurance-acceptance-independence-01

Risk-scored acceptance and continuance workflow with automated data pull and AI summaries

Grade C · Augment

Problem. Acceptance and continuance decisions draw on independence, conflict, reputational and know-your-client information held in separate systems and often handled in Excel and email.

Approach

- Intapp and Kingland sell risk-scored questionnaires and reviewer routing; Intapp adds AI request summaries, Kingland does not say which steps use AI.
- Risk teams review and approve when risk is detected, and decisions route to reviewers for sign-off.
- No customer result, time saving or error rate is published (vendor-published); a 2024 academic prototype outputs a risk level as decision support.

Evidence: Intapp, Kingland, academic prototype · assurance-acceptance-independence-02

AI-powered client lifecycle platform joining client checks and engagement acceptance

Grade C · Augment

Problem. Client onboarding, due diligence and engagement acceptance at a large audit and advisory firm sit in separate steps with manual hand-offs.

Approach

- Grant Thornton UK selected Fenergo's AI platform to join client checks, due diligence and acceptance; the AI's decisions are not described.
- Vendor says it removes thousands of hours of manual effort (vendor-published); the firm says it will speed engagement starts (self-reported).
- Who signs off the acceptance decision is not stated in either release.

Evidence: Grant Thornton UK, Fenergo · assurance-acceptance-independence-03

AI-assisted anti-money-laundering onboarding: document sorting, risk scoring and sanctions hit triage

Grade C · Augment

Problem. Onboarding information arrives by unstructured email, often incomplete, and sanctions and politically-exposed-person screening produces false matches that staff clear by hand.

Approach

- A vendor prototype entering pilot uses AI document classification to feed a client risk-scoring model; a language-model pipeline filters false screening hits.
- The vendor says the compliance officer receives cases already triaged; the money laundering reporting officer decides on suspicious activity reports.
- No accuracy or time-saving figure is published (vendor-published); trial firms are unnamed and not described as audit firms.

Evidence: Zygos (Softline), unnamed trial firms · assurance-acceptance-independence-04

AI extraction of client ownership structures into family trees for independence checks

Grade C · Augment

Problem. Independence and conflict checks depend on a complete map of a client's affiliates, often built by hand; IFIAR counted 11 findings in 2025 on unreliable tracking.

Approach

- Kingland says its tool uses AI to read client documents and extract ownership details into a family tree the user completes.
- The tool walks professionals through building the tree, so a person confirms the structure.
- Vendor says it gives a single source of truth for entity records; no measured result (vendor-published).

Evidence: Kingland, EY UK (non-AI system) · assurance-acceptance-independence-05

Independence monitoring dashboards, breach management and personal-holdings checks

Grade C · Augment

Problem. Independence is checked only at points in time, so emerging issues surface late; IFIAR recorded 22 findings in 2025 on failing to monitor staff and partner personal independence.

Approach

- Kingland describes dashboards joining independence, risk and engagement data plus a breach workflow; its only named AI function reads broker statements.
- Independence, risk and service-line leaders act on the trends shown.
- Vendor says new holdings are checked within 24 hours of a trade (vendor-published); broker-feed automation, not AI, with no measured result.

Evidence: Kingland, EY UK, Intapp · assurance-acceptance-independence-06

Partner rotation candidate matching that excludes people the independence rules bar

Grade C · Augment

Problem. Rotation planning must balance experience, availability and career stage against independence limits on who can take over a client.

Approach

- Kingland describes a tool that surfaces suitable candidates from experience, availability and career data, and excludes people the independence rules bar.
- Firm leaders make the rotation decision; the tool provides a view of candidates.
- Vendor says it gives a clear view of top candidates; no measured result (vendor-published).

Evidence: Kingland · assurance-acceptance-independence-07

Automated engagement-letter production

Grade C · Augment

Problem. Engagement letters are produced for every audit and must reflect the engagement's terms.

Approach

- Some firms use an automated solution for engagement letters; the survey does not say whether AI is used.
- Intapp markets automated creation and collection of engagement letters inside its acceptance product, without naming customers.
- 26% of surveyed firms have an automated engagement-letter solution (independent); this is automation, not necessarily AI.
- The human checkpoint is not stated in the source.

Evidence: CPA.com (AICPA), Intapp · assurance-acceptance-independence-08

Pricing and targeting engagements from historical firm data inside acceptance

Grade C · Assist

Problem. Intapp's white paper says firms treat acceptance and independence checking as a cost centre and asks whether they know the true cost of each engagement.

Approach

- Use historical firm data in automated acceptance to set prices and terms, target high-value clients and steer partners with whitelists and blacklists.
- Potential revenue impact estimates: 1.5-4% informed pricing, 1-3% strategic targeting, 0.05-1.5% identifying conflicts (vendor-published; not measured results).
- The human checkpoint is not stated in the source.

Evidence: Intapp (white paper) · assurance-acceptance-independence-09

Idea: assess a client's reliance on AI in financial reporting at acceptance

Grade D · Assist

Problem. Idea, not a deployment: clients increasingly use AI in financial reporting, so the auditor may be unable to gather evidence and management may not understand its own outputs.

Approach

- An AICPA practice aid says a client's AI use may affect acceptance or continuance; heavier reliance may mean more information is needed.
- The AICPA says auditors should address client AI reliance at the start and check the team has the skills needed.
- A new human assessment step, not AI doing the task; the partner and firm risk function decide. No firm practice found.

Evidence: No named deployment · assurance-acceptance-independence-10

Idea: engagement terms covering the firm's AI use and client-data consent

Grade D · Assist

Problem. Idea, not a deployment: firms use AI on client work, but it is unclear when the engagement letter or a consent must say so.

Approach

- The AICPA practice aid says the US audit-terms standard does not require naming AI tools, though laws, contracts or policy may.
- AICPA ethics staff say firms should ask whether client consent is needed before client data goes into an AI tool.
- The partner decides what the engagement letter says and whether consent has been obtained. No firm practice was found.

Evidence: No named deployment · assurance-acceptance-independence-11

Idea: tell audit committees about the auditor's AI use and independence implications

Grade D · Assist

Problem. Idea, not a deployment: the SEC's chief accountant says audit committees are asking about the independence implications of auditors' AI use.

Approach

- A firm's account of its AI tools, vendors and alliances would become part of its communication with those charged with governance.
- The engagement leader would communicate with the audit committee. No firm describes a standard communication on this topic.

Evidence: No named deployment · assurance-acceptance-independence-12

Idea: review AI tool-vendor contracts and licences for independence before adopting them

Grade D · Assist

Problem. Idea, not a deployment: tool vendors can shift control, judgment, fees or evidence access away from the auditor, creating undue-influence and self-interest threats.

Approach

- Before adopting a vendor, review contracts for cross-referral concentration, vendor involvement in the work, payment for evidence access and marketing control.
- A commentator proposes recording who owns each vendor, what the firm pays, and whether the vendor can train models on client data.
- The independence partner concludes and documents the evaluation. No firm was found that has published such a review.

Evidence: No named deployment · assurance-acceptance-independence-13

Idea: check firm-wide AI-vendor alliances against audit-client lists

Grade D · Assist

Problem. Idea, not a deployment: networks have firm-wide AI vendor alliances, and the SEC's chief accountant says it gets complicated when a firm's non-audit partner uses an audit client.

Approach

- Independence teams would map AI-vendor relationships against audit-client and affiliate lists before signing and at each acceptance or continuance.
- Context: Deloitte is making Claude available to 470,000 people, KPMG to more than 276,000 staff (vendor-published); scale, not an outcome.
- No firm process was found; the suggested check is global independence leadership sign-off and audit-committee dialogue.

Evidence: No named deployment · assurance-acceptance-independence-14

Idea: permissibility gate for AI services offered to audit clients

Grade D · Assist

Problem. Idea, not a deployment: firms are expanding AI services to clients they may also audit, and building or hosting AI for an attest client can raise independence concerns.

Approach

- Route every proposed AI build, host, licence or assurance service through pre-approval, checking self-review threats, management responsibility and commercial dependency.
- Deloitte Ireland and Luxembourg describe pre-approval workflows, but none is described as AI-specific; applying the gate to AI services is the idea.
- Independence and conflicts teams review before approval, and the audit partner evaluates threats and safeguards.

Evidence: No named deployment · assurance-acceptance-independence-15

Independence due diligence and governance safeguards before taking private-equity investment

Grade B · Assist

Problem. Private-equity investment enters the profession mainly through alternative practice structures, and IFAC says new governance layers can dilute audit partners' control over client selection.

Approach

- AICPA guidance describes due diligence before the deal, an expert-drafted administrative services agreement, independence monitoring and a multipronged independence evaluation.
- Grant Thornton UK's Cinven investment closed in early 2025 after regulatory approval, with the audit practice kept in its LLP.
- This is a human control process, not AI; the FRC asks firms to engage early and with full candour.
- Context: 385 transactions in 2025, 139 involving audit firms (independent); a measure of structural change, not of the review step.

Evidence: Grant Thornton UK, AICPA, IFAC, FRC · assurance-acceptance-independence-16

Screen clients against the investor group; consult the regulator on grey areas

Grade B · Assist

Problem. When a firm's owner or its funds hold stakes in companies, taking those or related companies as audit clients can fall into independence grey areas.

Approach

- At acceptance the firm checks links to the investor's holdings, declines where independence is doubtful and consults the regulator on unclear cases.
- Grant Thornton UK's chief executive said the firm would not audit a company in which owner Cinven has invested (self-reported).
- One reported case: the FRC agreed a prospective client was a grey area and the firm did not proceed (self-reported).
- Independence and risk leaders assess whether the investor or its staff are covered persons; no source describes AI in this screening.

Evidence: Grant Thornton UK, FRC, ICAEW · assurance-acceptance-independence-17

AI audit platform launched by Grant Thornton in an alternative practice structure

Grade C · Augment

Problem. In an alternative practice structure the non-attest entity can supply the attest firm with technology, so a shared AI platform raises who provides it and whether independence rules apply.

Approach

- Grant Thornton LLP announced gtap on 7 May 2026, a cloud audit platform with AI workflows and agents surfacing risks and anomalies.
- It starts on private-company audits, expanding to public-company audits the next year; the firm says professionals supervise every step.
- The CEO says automating transactional work lets teams focus on judgment; no measured result (self-reported).
- Idea only: treat shared platforms as part of the independence assessment, with attest-firm leadership approval.

Evidence: Grant Thornton US and Ireland · assurance-acceptance-independence-18

Investor-funded holding company building AI audit tooling and investing in audit firms

Grade C · Augment

Problem. Audit tools and workflows have not meaningfully changed in decades, according to Modus's CEO, and Lightspeed's partners say public accounting has been underserved by technology.

Approach

- Modus raised $85 million (vendor-published), led by Lightspeed, to invest in audit-first firms and build AI-enabled audit tooling.
- It has invested in one top-200 firm and, according to Lightspeed, has deployed seven AI workflows there (vendor-published).
- No audit-quality or efficiency result is reported; the human checkpoint is not stated in the source.

Evidence: Modus, Lightspeed Venture Partners · assurance-acceptance-independence-19

New audit firms built around AI from the start

Grade C · Delegate

Problem. Auditing has been slower than other professions to absorb automation and still relies on manual collection, matching and documentation, according to coverage of Repodo's launch.

Approach

- Repodo, a Copenhagen audit firm, raised EUR 8.2 million pre-seed (vendor-published); AI systems are meant to handle much of the repetitive work.
- Oath Verified raised about $10 million in total (vendor-published) and uses an alternative practice structure because its platform company is venture-backed.
- Licensed professionals keep judgment, oversight, the signature and final responsibility; no client, quality or independence result is published.

Evidence: Repodo, Oath Verified · assurance-acceptance-independence-20

Audit fee renegotiation justified by AI-enabled efficiency

Grade B · Assist

Problem. Audit has been priced on hours, seniority and review depth; if AI speeds execution, clients may expect lower fees.

Approach

- KPMG International reportedly negotiated a lower audit fee from Grant Thornton UK, arguing AI would cut costs (unnamed sources, Financial Times).
- Fee 14% lower, from $416,000 to $357,000, per KPMG International's filing (independent); the link to AI rests on unnamed sources.
- Commentators split between holding fees because humans validate and sign off, and moving to subscription or continuous audit-as-a-service pricing.

Evidence: KPMG International, Grant Thornton UK · assurance-acceptance-independence-21

Planning and risk assessment

Understanding the entity and its own AI, risk assessment, fraud, materiality, scoping, budgets. · 25 use cases · evidence moderate (11 of 25 A/B)

Summarise board minutes with cited output to focus risk identification

Grade B · Augment

Problem. Auditors read board minutes and similar documents to spot risk indicators, but the volume is large, reading it all is slow, and relevant passages are easy to miss.

Approach

- KPMG describes Clara AI assistants that review documents such as minutes to flag possible risks, announced for 90,000 auditors in July 2024.
- The FRC's worked example for a hypothetical firm has the tool summarise each meeting, with every point citing its source.
- The auditor reads the minutes to check completeness and accuracy; KPMG gives no usage, accuracy or time figure (self-reported).
- The Dutch regulator AFM says nearly all firms it visited use generative AI, for example to summarise minutes, without naming them.

Evidence: KPMG, FRC (worked example), AFM · assurance-planning-risk-assessment-01

Chat assistants for entity research and methodology questions during planning

Grade B · Assist

Problem. Building an understanding of the entity, its industry and its regulatory environment takes desk research and document reading, and auditors spend time finding firm-approved guidance.

Approach

- KPMG reported more than 2.175 million Audit Chat conversations since October 2023 (self-reported); this is usage, not effect.
- RSM's Ask Luca answers questions grounded in firm-approved guidance and, RSM says, reduces research time (self-reported); PwC describes ChatNational.
- The auditor owns the understanding of the entity: ICAEW found chatbots cannot perform inquiry, observation or inspection; RSM calls human review vital.

Evidence: KPMG, RSM, PwC, ICAEW · assurance-planning-risk-assessment-02

Agents that scan media reports for emerging threats and draft staff memos

Grade B · Augment

Problem. Keeping up with news and events that bear on an audited entity's risk is manual and uneven.

Approach

- Bloomberg Law reports Deloitte auditors worldwide gained agents that scan media reports for emerging threats and produce first drafts of staff memos.
- Deloitte describes an agent network in Omnia for nearly 85,000 practitioners, running preliminary procedures for review.
- Practitioners supervise and validate agent output; a Deloitte leader expects faster working-paper population, an expectation not a result (self-reported).

Evidence: Deloitte, Bloomberg Law · assurance-planning-risk-assessment-03

Analyse audit-committee communications to surface issues earlier in audit preparation

Grade C · Augment

Problem. Issues raised in communications with the audit committee can reach the engagement team late in the audit preparation cycle.

Approach

- PwC said in October 2026 that one tool it will use for 2026 year-end audits analyses audit-committee communications to surface issues sooner.
- No outcome is published and the human checkpoint is not described in the source.

Evidence: PwC · assurance-planning-risk-assessment-04

Tool-assisted understanding of the client's IT environment and access rights

Grade C · Augment

Problem. Understanding the entity's IT environment is required in risk assessment, but sampling user lists and access logs gives a partial picture, and mid-tier firms often lack IT audit teams.

Approach

- The Dutch regulator AFM saw auditors using tools to evaluate access rights and user activity; these are analytics tools, not necessarily AI.
- A vendor co-founder writes that agentic AI platforms can map risks to controls and draft ISA 315 documentation with human-in-the-loop review.
- Auditors review, validate and challenge flagged issues and evaluate tool results against the IT auditor's findings. No outcome is published.

Evidence: AFM, ICAEW viewpoint by a vendor co-founder · assurance-planning-risk-assessment-05

Idea: understand the entity's AI use as a standard risk assessment step

Grade D · Assist

Problem. Idea, not a deployment: audit partners rated only 6% of their largest clients' AI governance as advanced, yet the AS 2110 text has no AI-specific step.

Approach

- Planning would add inquiry into how the entity uses AI in financial reporting, its governance, and whether AI-generated documents feed audit evidence.
- The AICPA practice aid (13 October 2026) covers AI-specific risks and controls; this is guidance, not yet a measured practice.
- The auditor remains responsible for the audit and the opinion, in the AICPA chief auditor's words; no firm has published results.

Evidence: No named deployment · assurance-planning-risk-assessment-06

Standardised ERP data ingestion as the base for planning analytics

Grade B · Automate

Problem. Fragmented tools and client data in many formats block analytics at the start of the audit; surveyed US firms name poor client data (60%) among the top blockers.

Approach

- Grant Thornton's gtap is a cloud platform standardising how audit data from any ERP system is ingested, transformed and analysed.
- It supports full-population analysis, started with private-company audits, and plans public companies the next year.
- Auditors oversee the risks and anomalies agents flag; Grant Thornton says consistency rises and manual steps fall, with no figure (self-reported).
- Adoption signal: 35% of surveyed US firms have automated trial-balance import and 19% automated data ingestion (independent).

Evidence: Grant Thornton, CPA.com (AICPA) · assurance-planning-risk-assessment-07

Whole-population ledger analytics to identify risks and unusual flows

Grade B · Augment

Problem. Planning often starts from a trial balance, a few schedules, last year's file and judgment, so significant classes and unexpected flows can stay hidden until costlier substantive testing.

Approach

- RSM auditors review journal-entry visualisations for risk insight, and KPMG says Clara Transaction Scoring covers 100% of populations.
- The auditor interprets results and follows up outliers; senior team members reflect on whether scepticism was maintained.
- Adoption signal, not quality: 55% of IFIAR members frequently observed automated tools in risk assessment in 2024, 49% in 2023 (independent).
- 22% of US firms have an automated risk-assessment solution; every respondent using one reported positive impact (independent).

Evidence: KPMG, RSM, Wolters Kluwer, IFIAR · assurance-planning-risk-assessment-08

Draft engagement-specific risk suggestions from trial balance, prior-year file and board minutes

Grade B · Augment

Problem. Risk assessment starts from a blank page or from last year's risks, and is time-consuming, according to a customer.

Approach

- Caseware's Risk Suggestion Agent, launched 6 October 2026, suggests engagement-specific risks with a rationale from financial data and board minutes.
- The auditor accepts, edits or rejects every suggestion; nothing enters the engagement file without a deliberate decision.
- In a demonstration it surfaced 5 risks, one a $118,000 discrepancy with board minutes (vendor-published).
- A GRF CPAs & Advisors partner says it saves time, with no figure (vendor-published).

Evidence: Caseware, GRF CPAs & Advisors · assurance-planning-risk-assessment-09

Agentic risk assessment linking evidence, analytics, assertions, materiality and planned procedures

Grade C · Augment

Problem. Risk scores from analytics often sit outside workpaper tools and are hard to tie to assertions and materiality, and linking risks to procedures is manual.

Approach

- MindBridge announced Agentic Risk Assessment on 22 September 2026, connecting evidence, analytics, assertions, materiality and methodology to support planning decisions.
- Wolters Kluwer describes a future-state vision where agents draft a cited risk narrative and map risks to procedures, with the auditor reviewing.
- The auditor reviews and refines the output; MindBridge claims better planning decisions, with no figure and no named customer (vendor-published).

Evidence: MindBridge, Wolters Kluwer · assurance-planning-risk-assessment-10

Large-firm agent platforms covering planning and risk identification

Grade B · Delegate

Problem. Separate point tools leave planning, risk assessment and testing disconnected, so risk views are not updated as work proceeds.

Approach

- EY embedded a multi-agent framework in EY Canvas on 7 April 2026, with end-to-end support expected by 2028.
- Deloitte says Omnia agents identify potential risk factors; KPMG Clara GenAI helps refine risk assessments; PwC expects an agentic platform.
- Practitioners supervise and validate agent output; preliminary conclusions go to professionals for review.
- EY reports reach of 130,000 professionals and 160,000 engagements (self-reported): reach, not effect.

Evidence: EY, Deloitte, KPMG, PwC, Grant Thornton · assurance-planning-risk-assessment-11

Idea: chatbot drafts risks of material misstatement from financial statements (weak results)

Grade D · Assist

Problem. Idea, not a deployment: identifying risks of material misstatement takes time, and a general-purpose chatbot can produce a polished draft in seconds.

Approach

- ICAEW tested Copilot, Claude Sonnet 4 and Grok 3 once each on a fictional retailer; the case for chatbots was not made.
- None of three performed risk assessment as a human auditor would; 0 of 3 separated statement-level from assertion-level risks (independent).
- Reports took from under 20 seconds to about 3.5 minutes (independent); Copilot did not treat revenue as a risk area.
- ICAEW concludes human judgement is needed to interpret the output and decide the risks, because each model gave different answers.

Evidence: No named deployment · assurance-planning-risk-assessment-12

Idea: multi-agent restatement-risk scoring from report text, ratios and audit matters

Grade D · Augment

Problem. Idea, not a deployment: entity-level risk signals come from several evidence streams that can disagree, and point predictions say nothing about how well the streams agree.

Approach

- A research preprint describes UMAR: three agents score risk from report text, financial ratios and audit matters, each with an uncertainty estimate.
- An aggregator combines the scores and measures conflict between agents; the authors call the output potentially actionable and interpretable.
- On the authors' test set it beat logistic regression, XGBoost and FinBERT: AUROC 0.782, calibration error 0.052 (independent). Human checkpoint not described.

Evidence: No named deployment · assurance-planning-risk-assessment-13

GenAI as a sounding board in fraud risk assessment and fraud brainstorming

Grade C · Assist

Problem. Fraud risk assessment is vulnerable to cognitive bias, such as irrelevant information diluting relevant indicators, and brainstorming depends on the team's knowledge of schemes elsewhere.

Approach

- The AFM reports auditors at unnamed Dutch firms making their own fraud risk assessment first, then using GenAI to challenge it.
- A City of Charlotte internal auditor showed a chatbot drafting a table of cemetery fraud schemes; the slides show no review step.
- Conference experiment with irrelevant information added: ratings 8.00 vs 6.42 without ChatGPT, 8.91 vs 7.97 with it (independent).
- No outcome is published for the practitioner demonstration.

Evidence: AFM, City of Charlotte auditor, Tilburg University · assurance-planning-risk-assessment-14

Idea: extend fraud risk assessment to AI-enabled schemes and AI-generated evidence

Grade D · Assist

Problem. Idea, not a deployment: documents such as invoices and bank statements may now originate from or be altered by AI, which traditional fraud risk factors do not cover.

Approach

- The fraud risk assessment and team discussion would add AI-enabled schemes such as deepfake impersonation in wire authorisations and fabricated invoices.
- Teams would consider whether AI algorithms initiate accounting entries and plan authenticity checks where document authenticity is in doubt.
- The engagement team discusses with the engagement partner as the human checkpoint.
- Survey of 373 internal audit leaders: 85% rate AI-enabled fraud a moderate to high risk; 62% unprepared or minimally prepared (independent).

Evidence: No named deployment · assurance-planning-risk-assessment-15

Idea: chatbot proposes the materiality benchmark, percentage and performance materiality

Grade D · Assist

Problem. Idea, not a deployment: setting overall and performance materiality needs a benchmark, a percentage and a rationale, and inspectors scrutinise year-on-year changes.

Approach

- ICAEW asked three chatbots to calculate materiality with a rationale in one test; no source describes AI setting materiality in practice.
- The models proposed different benchmarks for the same facts: Claude 5% of profit before tax, Copilot 0.75% of revenue (independent).
- Copilot's rationale may be a hallucination; ICAEW concludes human judgement is required to choose the benchmark and thresholds.

Evidence: No named deployment · assurance-planning-risk-assessment-16

AI-supported scoping decisions, including group components

Grade C · Augment

Problem. Deciding which accounts, processes, locations and components are in scope is a judgment call made largely from prior-year files and team knowledge, and group audits are among the hardest.

Approach

- PwC said in October 2025 it planned soon to have a scoping risk-assessment tool; its October 2026 follow-up does not mention it.
- Wolters Kluwer says automation and AI can consolidate group data and prioritise exceptions; it describes no component-scoping method and names no customer.
- A person decides scope: PwC says the tool will help people make smarter decisions; auditors evaluate AI-flagged results. No outcome published.

Evidence: PwC, Wolters Kluwer, PCAOB staff · assurance-planning-risk-assessment-17

Auto-populate the planning document from prior-year information and show what changed

Grade B · Augment

Problem. Planning documents are rebuilt each year from prior-year files, and auditors may not notice what has changed in the business.

Approach

- PwC's Simplified Audit for Private Business ingests prior-year information and auto-populates a planning document; 2025 was its first year in planning.
- PwC says it saves time and helps auditors ask better questions by showing what changed (self-reported); no figure is published.
- The document is a foundation for the auditor to consider; planning judgments stay with the team; no review steps are described.
- PwC describes AI time savings across its audit tools as not that drastic yet (self-reported).

Evidence: PwC · assurance-planning-risk-assessment-18

In-file assistant that checks the planning file for gaps at planning review

Grade C · Augment

Problem. Gaps in the risk assessment, such as a variance no logged risk covers, are often found during fieldwork rather than at planning review.

Approach

- In a Caseware CwX 2026 demonstration, the Verity agent flagged a variance against board minutes with no logged risk attached.
- The reviewer accepts, edits or rejects each suggestion before anything enters the engagement.
- Caseware reports early beta cut manual workflows from 15-20 minutes to under two (vendor-published); not specific to planning review.
- Caseware reports 94% accuracy on golden-dataset items (vendor-published); not specific to planning.

Evidence: Caseware · assurance-planning-risk-assessment-19

Methodology-embedded, risk-based engagement platform with in-context AI guidance for mid-tier firms

Grade B · Augment

Problem. Mid-tier firms use disconnected tools and prior-year habits, and some surveyed firms say they still struggle to move from prior-year workpapers to a risk-driven approach.

Approach

- EisnerAmper, Citrin Cooperman and PKF O'Connor Davies adopted the Dynamic Assurance Solution risk-focused suite, now with Caseware Verity.
- PKF also joined an agentic pioneer programme to co-develop its own agents; EisnerAmper phased its roll-out with training.
- Caseware says every AI-assisted output is citation-backed, reviewable and traceable before entering the engagement file.
- Adoption, not an AI effect: more than 1,100 EisnerAmper professionals and over 1,500 engagements on the platform (vendor-published).

Evidence: EisnerAmper, Citrin Cooperman, PKF O'Connor Davies, Caseware · assurance-planning-risk-assessment-20

Engagement-level plan for AI and tool use, with team competence checked

Grade C · Assist

Problem. Tools are adopted ad hoc, it is not always clear where GenAI was applied in an audit, and teams may use tools they are not trained for.

Approach

- The audit plan states which tools will be used for which risks; the team's competence to use them is assessed at planning.
- The AFM saw audit plans at some firms stating which tools are used; the AICPA practice aid recommends planning intended AI use.
- The engagement leader sets expectations at the outset; senior team members review overall technology use in the file. No outcome published.

Evidence: AFM, IFIAR, AICPA · assurance-planning-risk-assessment-21

AI-supported staffing requests, budget planning and engagement-leader review

Grade B · Augment

Problem. Manual staffing and budgeting processes give leaders little visibility into engagement planning and resourcing.

Approach

- RSM Luca Resourcing replaces manual processes with a connected tool supporting initial staffing requests, budget planning and engagement-leader review.
- RSM presents it as one of three AI-related additions to its audit ecosystem; what the AI does inside is not stated.
- Engagement-leader review of staffing and budget is a step in the tool; RSM says it improves visibility and speeds staffing decisions (self-reported).

Evidence: RSM · assurance-planning-risk-assessment-22

AI efficiency gains negotiated into audit fees and engagement budgets

Grade C · Assist

Problem. If firms tell clients AI cuts hours, clients may ask why fees do not fall.

Approach

- Reported case: KPMG International pressed auditor Grant Thornton UK for a lower fee, arguing AI should cut audit cost; the fee fell.
- Reported fee about 14% lower, $416,000 (2024) to $357,000 (2025); second-hand and unconfirmed (independent).
- PwC said in 2025 clients know AI saves hours and ask for discounts; practitioners disagree on whether quality should support higher fees.
- The human checkpoint is not described in the source.

Evidence: KPMG International, Grant Thornton UK, PwC · assurance-planning-risk-assessment-23

Continuous risk assessment and dynamic planning that update risks as data arrives

Grade C · Delegate

Problem. Risk assessment is a point-in-time planning step revised only when the team notices contradicting evidence, although AS 2110 .74 requires it to continue through the audit.

Approach

- Direction of travel, not yet practice: Thomson Reuters says client transactions flow continuously into AI engines that flag issues as they occur.
- Grant Thornton designed gtap as the foundation for such a model, and Caseware's long-term aim includes AI that continuously assists planning.
- The engagement team decides whether to revise the risk assessment; auditor intervention protocols apply when anomalies appear.
- Thomson Reuters claims 80-90% complete deliverables by year-end with minimal human intervention (vendor-published); the claim is unsourced.

Evidence: Thomson Reuters, Grant Thornton, Caseware · assurance-planning-risk-assessment-24

AI-drafted risk considerations, risk-to-control scoping and work programs for internal audit

Grade B · Augment

Problem. Internal audit teams plan many diverse audits with limited staff, and mapping risks to controls by hand before testing starts is where teams lose the most time.

Approach

- Helvetia Baloise's chief audit executive says the team uses AI to support audit work programs and summarise reports and policies.
- Fieldguide's Field Agents map risks to controls and score them for a scoped starting point; BDO's risk advisory practice is rolling out.
- The auditor reviews the scoping result and makes the final call; severity ratings, materiality calls and sign-off stay with people.
- FJ Management's head of internal audit states a vision of an agent planning procedures and drafting workpapers for review; no outcome published.

Evidence: Helvetia Baloise, Fieldguide, BDO, FJ Management · assurance-planning-risk-assessment-25

Controls testing

Walkthroughs, ITGCs, operating-effectiveness tests and deficiencies across ICFR, SOX and SOC work. · 25 use cases · evidence strong (16 of 25 A/B)

AI-assisted walkthroughs that prepare, transcribe and draft process narratives

Grade B · Augment

Problem. Walkthroughs, which trace one transaction end to end to confirm how a control works, are repeated every year even when processes barely change, and documenting them is tedious.

Approach

- PwC's Advanced Walkthrough Assistant ingests prior-year walkthroughs and drafts documentation for review; PwC said it will be used on 2026 year-end audits.
- KPMG UK uses Clara AI to review control wording before walkthroughs and Copilot to transcribe them into flowcharts, where permitted.
- The auditor performs the inquiry and observation; a reviewer approves the narrative, flowchart and design conclusion.
- KPMG UK reports fewer meetings for control owners; PwC says busy-season savings are not that drastic yet (self-reported).

Evidence: PwC, KPMG UK, Optro · assurance-controls-testing-01

Test-of-design support and AI-drafted control test plans

Grade B · Augment

Problem. Breaking control descriptions into testable attributes and writing test plans is manual and uneven, and badly worded controls lead to follow-up requests and exceptions later.

Approach

- KPMG UK's Clara AI agents capture controls, draft a test plan for review and score control wording as decision support only.
- Fieldguide and Petual agents draft test plans from the risk and control matrix; PwC's dynamic controls testing generates procedures that users review.
- The auditor approves the test plan before testing runs and forms an independent view of design before comparing it with tool output.
- KPMG UK says fuller attribute identification reduces follow-up requests, not quantified (self-reported).

Evidence: KPMG UK, Fieldguide, Petual, PwC · assurance-controls-testing-02

Agent-assisted evidence requests and pre-submission evidence checks

Grade C · Augment

Problem. Chasing evidence is a main source of SOX delay: testers spend weeks requesting, chasing and re-requesting evidence from control owners across 20+ systems.

Approach

- Agents draft requests, check submitted evidence for completeness, file integrity and format, and help preparers fix gaps before submission.
- Vendors describe next steps as pulling evidence through integrations and messaging control owners in Slack or Teams.
- The control owner confirms submissions; the auditor determines sufficiency, not the platform.
- Frazier & Deeter: evidence requests about 8% faster (19 hours) with Fieldguide (vendor-published); Optro claims fewer follow-ups, not quantified.

Evidence: Optro, Fieldguide, Frazier & Deeter · assurance-controls-testing-03

Risk-scored sample, coverage and control targeting

Grade A · Augment

Problem. Sample and coverage choices rely on static lists, geographic assumptions and hard-to-explain judgment, so testing effort follows rotation and habit rather than likely control breakdowns.

Approach

- Microsoft Internal Audit's Sample Selection Agent scores items on revenue, discounts, country risk and control indicators to produce a defensible risk-based selection.
- Optro offers AI risk-based sample selection; KPMG describes predictive modelling of where control breakdowns are likely.
- The audit lead approves the selection basis, threshold and any untested residual population.
- Microsoft Internal Audit reports weeks of manual analysis cut to one day and ~2K hours/year saved (self-reported).

Evidence: Microsoft Internal Audit, Optro, KPMG · assurance-controls-testing-04

Agentic attribute testing of SOX key controls, with workpapers drafted for review

Grade A · Delegate

Problem. Testers open PDFs, screenshots and exports for every sample, check each control attribute and document it by hand; KPMG's 2025 survey averages 16 hours per control.

Approach

- Agents read unstructured evidence, test each attribute with citations to source, and draft workpapers; exceptions route to a human reviewer.
- Reddit's internal audit built this on Midship (now Optro Autonomous Testing); Klaviyo and Navan are other named users.
- Reddit reports testing time down 60% per control (self-reported); 175 controls automated, over 40% of SOX scope (vendor-published).
- People approve the test plan, sign off each conclusion and exception, and own deviation evaluation and deficiency classification.

Evidence: Reddit, Klaviyo, Navan, Optro, Petual · assurance-controls-testing-05

Two-agent change-management testing for IT general controls

Grade A · Automate

Problem. Testing change-management controls means opening tickets across several systems with inconsistent formats, entering attributes in spreadsheets by hand and annotating evidence sample by sample.

Approach

- Microsoft Internal Audit built two Copilot Studio agents; one extracts tester, approver and dates from tickets into a table with pass/fail logic.
- A second agent marks each extracted field on the source evidence so the reviewer sees where each attribute was validated.
- Auditors review the audit table and exceptions; a reviewer samples the tick-marked evidence before sign-off.
- Microsoft reports 850 hours/year and $185K/year saved, built and launched in 1-3 months (self-reported).

Evidence: Microsoft Internal Audit · assurance-controls-testing-06

Matching client-provided evidence to selected samples with agents

Grade B · Automate

Problem. Each sampled control instance needs its supporting evidence traced to the sample and checked attribute by attribute, and evidence arrives in many formats, so manual tracing slows the test.

Approach

- Agents trace incoming documents to requested samples, extract and validate values, and record match or exception status with links to the source.
- PwC said in October 2025 its controls-testing automation would work like Evidence Match; KPMG UK uses DataSnipper on IT change tickets.
- The auditor reviews each exception and signs off the test.
- No controls-specific result is published; RMF Audit & Control's roughly 50% saving is for invoice samples, not controls (vendor-published).

Evidence: PwC, KPMG UK, DataSnipper, RMF Audit & Control · assurance-controls-testing-07

Full-population testing of transactional and master-data controls instead of samples

Grade A · Automate

Problem. Sample-based tests limit the conclusion to items examined and miss errors outside the sample; IFIAR recorded 24 insufficient-sample and 11 biased-sample findings in 2025.

Approach

- Extraction and matching agents, paired with deterministic code, test every item and link each value to its source.
- Armanino with DataSnipper tests 100% of vendor master changes rather than a sample (vendor-published); the auditor reviews each match.
- Microsoft Internal Audit agents test high-risk data sets in full; function-wide, report issuance fell from 3 to 2 weeks (self-reported).
- Investigation thresholds are set before seeing output; the auditor investigates every flagged item or a justified subset; the partner approves evidential weight.

Evidence: Armanino, DataSnipper, Microsoft Internal Audit, KPMG · assurance-controls-testing-08

Continuous, year-round control testing and monitoring instead of point-in-time cycles

Grade B · Automate

Problem. Testing bunched at interim and year-end finds failures months after they occur, often during the external audit, when remediation costs most and little time is left.

Approach

- Agents test controls as evidence arrives, and scheduled queries watch control data and route exceptions to owners.
- Snowflake Internal Audit runs queries on Snowflake data through the Optro connector; Klaviyo tests throughout the year with Optro Autonomous Testing.
- Owners triage each alert, people periodically review exceptions and agent configuration changes, and the auditor concludes on operating effectiveness.
- Klaviyo and Snowflake report earlier issue detection and faster remediation, not quantified (vendor-published).

Evidence: Snowflake, Klaviyo, Optro, Fieldguide · assurance-controls-testing-09

AI secondary review and multi-agent challenge of control-testing workpapers

Grade B · Augment

Problem. Manager review is a bottleneck, so small teams re-review only the riskiest workpapers and errors slip through; auditors are also less skeptical of work done by tools.

Approach

- FJ Management Internal Audit connects Claude to its Optro record; several models review each workpaper independently and disagreements are flagged.
- A human checks each AI memo before it is attached; severity, materiality and sign-off stay with auditors.
- FJ Management says memos caught actual defects and plans 100% secondary review (vendor-published, not quantified).
- A research prototype, IntelliAudit, left 91.7% of final statuses unchanged on simulated organisations (independent); not accuracy against human auditors.

Evidence: FJ Management, Optro, Microsoft, Tilburg University · assurance-controls-testing-10

AI-assisted testing in SOC 1, SOC 2 and ISAE 3402 service-auditor engagements

Grade A · Augment

Problem. Service-auditor engagements test high volumes of change-ticket evidence and rely on control owners' time; KPMG UK says demand for controls assurance reports nearly doubled.

Approach

- KPMG UK uses Clara AI agents for walkthrough preparation and test plans, DataSnipper to extract change tickets, and Copilot for workpaper drafting.
- KPMG UK reports testing time about 18% lower on recent engagements, and about 15% lower with DataSnipper (self-reported).
- The service auditor reviews all extracted data and conclusions; the opinion is unchanged.

Evidence: KPMG UK, Fieldguide, Schneider Downs · assurance-controls-testing-11

AI drafting in the SOC cycle: system descriptions, evidence tracking, deviation responses

Grade C · Augment

Problem. Every SOC cycle, service organisations draft and update the system description, map it to the Trust Services Criteria, collect evidence snapshots and write management responses to deviations.

Approach

- GenAI turns process documents into draft control descriptions mapped to the criteria and drafts management responses covering root cause and remediation.
- It also tracks evidence collection and project status and keeps continuous evidence snapshots.
- Management owns the description and responses; the service auditor tests independently and evaluates deviations.
- In a live poll at the 2026 EY SOC conference, 63% of attendees named evidence collection a top AI use case.

Evidence: EY, Schneider Downs · assurance-controls-testing-12

AI review of third-party SOC reports for reliance by user entities

Grade C · Augment

Problem. SOX programmes and user auditors read many vendor SOC reports to extract scope, test results, exceptions and complementary user entity controls, then map them to their own risk assessment.

Approach

- AI reads SOC reports, extracts test results, compares them with the user's risk assessment and prior periods, and flags deviations (EY speakers).
- KPMG lists agents that manage SOC reports and extract control descriptions and test results.
- The auditor or control owner concludes on reliance, evaluates deviations and tests user entity controls.
- Described as a current application by EY and KPMG; no deployment figures found.

Evidence: EY, KPMG · assurance-controls-testing-13

Compliance-automation platforms feeding SOC 2 examiners with continuously pulled evidence

Grade C · Automate

Problem. Clients submit dozens of screenshots and spreadsheets per SOC engagement, and SOC 2 is a gating requirement for enterprise sales, so speed is prized.

Approach

- Compliance-automation tools connect to the client's systems and pull evidence into a real-time dashboard that the CPA examiner tests against.
- The debate is about where this automation replaces the examiner's own risk assessment and testing.
- A licensed CPA designs and executes the tests and signs the opinion.
- SOC leaders agree the tools make the process quicker; no figure is published (self-reported).

Evidence: Unnamed SOC leaders and tool vendors · assurance-controls-testing-14

Testing controls that AI performs: AI-enabled controls as a new test object

Grade C · Assist

Problem. Clients now put GenAI and agents into financial-reporting processes, audit programmes mostly test around the AI, and there is no accepted method for testing a black-box control.

Approach

- Auditors scope AI components per use case and decide whether to rely on AI output, extending access and change controls to them.
- AI-specific evidence includes lineage, per-inference logs and drift monitoring; COSO supplies control-testing templates for eight capability types.
- KPMG UK is introducing a SOC 2+ opinion over AI governance and controls; the AICPA practice aid helps auditors understand AI-affected controls.
- KPMG forecasts the first wave of AI-related material weaknesses in 2027 as programmes stop testing around AI (self-reported).

Evidence: COSO, KPMG, AICPA, CAQ · assurance-controls-testing-15

Firm-wide audit-platform agents extending into tests of controls in integrated audits

Grade B · Delegate

Problem. External auditors repeat walkthroughs and tests of controls every year across large engagement portfolios at fixed or falling fees, and orchestrate tasks across many separate tools by hand.

Approach

- Network-wide agent frameworks extract data, analyse evidence, draft documentation and develop preliminary conclusions for professionals to review.
- Deloitte Omnia agents run preliminary procedures; EY Canvas embeds agents; KPMG announced controls-testing agents as next; PwC plans controls-testing automation.
- The engagement team reviews every agent conclusion and the partner signs the opinion.
- EY covers about 130,000 assurance staff; Deloitte's framework reaches about 85,000 practitioners; PwC says year-one savings are not that drastic yet (self-reported).

Evidence: Deloitte, EY, KPMG, PwC, Grant Thornton · assurance-controls-testing-16

AI-native audit pilot where agents test controls and balances on full populations

Grade B · Delegate

Problem. Sampling-based audits spend most hours on data gathering and documentation rather than judgment.

Approach

- PwC Australia's AI-native audit platform has agents assess risk, plan audits and test balances and controls in real time on full populations.
- Auditors handle context, communication and final judgments; human auditors oversee and validate all agent work.
- The pilot starts with 5 audit clients, with all clients by 2028 and 1,600 auditors (self-reported plan).

Evidence: PwC Australia · assurance-controls-testing-17

Orchestrated agent swarms working alongside auditors in internal audit

Grade B · Delegate

Problem. Prompt libraries plateau because nobody owns the prompts or measures their output, routines are built one by one, and one agent per task does not scale across an audit plan.

Approach

- PayPal Internal Audit describes swarm auditing: teams of agents orchestrated in parallel to run analytics and tests under a defined collaboration framework.
- Scripts and agents built in audit are handed to first- and second-line owners; a separate bucket of hours covers experimentation.
- Auditors remain the decision layer; agents are not replacing the team in the near term. No figures published (self-reported).

Evidence: PayPal Internal Audit · assurance-controls-testing-18

In-sourcing previously outsourced SOX and IT general controls testing to agents

Grade B · Delegate

Problem. Many SOX programmes buy testing hours from co-sourcers; in KPMG's 2025 survey 58% said providers made up over 20% of SOX budget, and changing testers hurt consistency.

Approach

- Internal audit teams have agents run formerly outsourced tests, starting with IT general controls and then business-process controls, under their own review.
- Havertys expects external spend to shift from testing hours to advisory work and starts with outsourced IT controls (vendor-published).
- An unnamed Petual customer reportedly cut SOX budget to a quarter of its prior level (vendor-published, anecdotal).
- An IT audit manager reviews every agent test result before acceptance.

Evidence: Havertys, Petual, Optro · assurance-controls-testing-19

Agent-delivered co-sourced and outsourced controls testing by audit and advisory firms

Grade B · Delegate

Problem. Firms selling SOX and internal audit testing as a labour-based service face fee pressure and clients in-sourcing to agents, while unstructured evidence must still be read, matched and documented.

Approach

- RSM Beacon offers evidence validation, natural-language test steps and outputs traced to source; in August 2026 RSM announced an Andera AI alliance.
- Riveron places agents at specific workflow steps, with a professional reviewing every result before it enters the workpaper.
- Auditors approve, refine or intervene at key stages (RSM); open items are flagged to people.
- Riveron measures review-ready workpapers, shorter cycles and earlier issue visibility rather than hours saved (self-reported); no figures.

Evidence: RSM, Riveron, Andera · assurance-controls-testing-20

Encoding SOX testing judgment into agent evaluation sets

Grade B · Assist

Problem. A model right 95% of the time is unusable if no one can tell which 5% to check, and agent conclusions must be defensible under PCAOB review.

Approach

- Vendors hire experienced SOX testers to write decision rules, define ground truth per control type and document failure modes.
- Engineers use versioned evaluation sets to run regression tests before changing prompts, models or tools.
- Experts sign off evaluation criteria before release; Fieldguide and Nace.AI recruit SOX experts for this (self-reported).

Evidence: Fieldguide, Nace.AI · assurance-controls-testing-21

Idea: AI-assisted deviation evaluation and deficiency classification using a deviation memory

Grade D · Assist

Problem. Idea, not a deployment: classifying a failure as a minor gap, significant deficiency or material weakness depends on unwritten context; IFIAR recorded 11 findings in 2025.

Approach

- Teams would record why past exceptions were accepted in one repository.
- An agent would check new exceptions against it and draft a classification once a human supplies context; the auditor classifies.
- No deployment or measured outcome was found.

Evidence: No named deployment · assurance-controls-testing-22

Idea: screen control evidence for AI fabrication and prompt injection before testing

Grade D · Assist

Problem. Idea, not a deployment: GenAI makes fake invoices, approvals and screenshots cheap, and control owners who know auditors use agents could hide instructions in evidence to steer them.

Approach

- Regulators and practitioners call for authenticity procedures: take evidence from source systems where possible, sanitise agent inputs and constrain outputs.
- The auditor escalates suspected manipulation under the fraud standards; no public deployment of a dedicated screening step was found.
- Survey: 65% of internal audit leaders cite fabricated documents as an AI fraud concern; 62% are unprepared or minimally prepared (independent).

Evidence: No named deployment · assurance-controls-testing-23

Idea: external-auditor reliance on management's or internal audit's AI-enabled control testing

Grade D · Assist

Problem. Idea, not a deployment: reliance on others' testing is the main efficiency lever in SOX audits, but the standards predate AI and no public case was found.

Approach

- Practitioners and the IIA discuss parallel pilots with the external auditor and equal criteria for supervising AI-assisted work, whoever performs it.
- KPMG argues full-population tools could lower the value of relying on management's tests, or raise it if its AI testing qualifies.
- The engagement partner decides on reliance after evaluating competence, objectivity and the AI tool's certification; no measured outcome.

Evidence: No named deployment · assurance-controls-testing-24

Idea: synthetic data and simulation agents to stress-test controls before ERP go-live

Grade D · Augment

Problem. Idea, not a deployment: the window between an ERP go-live or acquisition and a stable control environment is among the highest-risk periods, with controls untested against real volumes.

Approach

- KPMG proposes synthetic transaction populations and agents that simulate users and adversarial conditions to test access controls, approvals and rules before go-live.
- COSO separately recommends test populations to validate AI accuracy and stress-test edge cases.
- The ICFR lead or control designers approve scenarios and interpret failures; no measured outcome.

Evidence: No named deployment · assurance-controls-testing-25

Substantive testing

Journal-entry and fraud testing, evidence matching, confirmations, analytics, contracts, estimates. · 25 use cases · evidence strong (13 of 25 A/B)

Testing every journal entry with machine-learning anomaly scoring

Grade B · Augment

Problem. Journal-entry testing is a required fraud response, but rules filters on very large ledgers miss subtler patterns and flood teams with false positives.

Approach

- A tool scores every ledger entry and shows why items look unusual; auditors select from them. Users include BDO UK and KPMG.
- Regulators saw automated tools in journal-entry testing in 88% of cases in 2024 (independent); all six US network firms reported them (self-reported).
- The team follows up each high-risk item and stays alert to signs the tool is systematically flawed for the engagement.

Evidence: Buzzacott, BDO UK, KPMG, EY, MindBridge · assurance-substantive-testing-01

Idea: language-model anomaly detection with written explanations for journal entries

Grade D · Augment

Problem. This is an idea, not a deployment: rule-based journal-entry tests produce many false positives, and machine-learning scores do not explain themselves.

Approach

- Researchers prompt language models with each ledger record plus a classical anomaly score, asking for a yes/no flag and a plain-language explanation.
- On a synthetic ledger, the best open model had 12 false positives against 942 for rules-based testing, with 2 missed anomalies (independent).
- The auditor reviews each flagged entry with the model's explanation before treating it as an exception.

Evidence: No named deployment · assurance-substantive-testing-02

Evidence-linked triage of items flagged by whole-population tests

Grade C · Augment

Problem. Whole-population tests surface more items to follow up, and thin testing of outliers is among regulators' most common technology findings.

Approach

- MindBridge says its Augmented Assurance offering lets auditors drill into the entries, accounts or periods driving risk, using the system's explanations (vendor-published).
- Its Agentic Risk Assessment, announced September 2026, is positioned for audit planning, not for following up flagged items.
- The auditor investigates and documents the rationale for concluding on flagged and additional items.

Evidence: MindBridge · assurance-substantive-testing-03

Authenticating documents before relying on them, as AI makes forged evidence cheap

Grade C · Assist

Problem. Regulators warn that AI tools can create realistic false evidence, so a clean-looking invoice or vendor file no longer signals legitimacy.

Approach

- MindBridge advises matching invoice details to bank records and system metadata; a BDO practitioner advises scanning vendor masters for suspicious entries.
- Whether firms use automated authenticity-detection tools in substantive testing was not found.
- The auditor decides whether evidence is authentic enough to rely on, with out-of-band verification of suspicious items.

Evidence: MindBridge, BDO practitioner, regulators · assurance-substantive-testing-04

Idea: testing AI-generated client information, or the controls over it

Grade D · Assist

Problem. This is an idea, not a deployment: when a client uses AI to categorise expenses or prepare accruals, the auditor may not see how the output was produced.

Approach

- The AICPA practice aid (October 2026) says auditors may test AI outputs substantively; if that is not enough, they should test controls.
- Where the process is a black box, the auditor may need to relate inputs to outputs and explore non-traditional evidence sources.
- The auditor decides whether substantive tests alone suffice or controls must be tested.

Evidence: No named deployment · assurance-substantive-testing-05

Generative AI assistant helps teams design substantive procedures (KPMG Clara)

Grade C · Assist

Problem. Teams must tailor substantive procedures to assessed risks and the entity, which means reading engagement documents and methodology.

Approach

- KPMG said in July 2024 it had integrated generative AI into Clara for 90,000 auditors to develop substantive procedures.
- The assistant works with engagement documentation and methodology. No outcomes published (self-reported).
- The engagement team member stays responsible for results and documentation, and auditors remain in control of decisions.

Evidence: KPMG · assurance-substantive-testing-06

Excel agent cleans and reconciles ledger data to the trial balance

Grade C · Augment

Problem. Raw client data arrives with mixed fields, inconsistent dates and blank rows, and preparing it for testing is repetitive, slow and error-prone.

Approach

- Two University of Akron academics built a ChatGPT Excel agent that asks approval before changing data and reconciles to the trial balance.
- A simulated clean, validate and reconcile of 59,157 rows took about 10 minutes, against many hours manually (independent, per the authors).
- The auditor approves the plan and reviews the reconciliation and the generated documentation.

Evidence: University of Akron academics · assurance-substantive-testing-07

Technology-assisted selection of items to test

Grade B · Augment

Problem. PCAOB standards covered audit samples but not items chosen when testing all items or specific items, and auditors were already using technology to choose them.

Approach

- Tools identify and select journal entries, high-risk items or samples; amended PCAOB rules apply the same testing requirements however items are selected.
- All six US network firms reported tools that select samples (self-reported); a Thomson Reuters customer says they significantly improve sample selection (vendor-published).
- The auditor challenges how the tool classified items as low risk and decides what testing the unflagged remainder needs.

Evidence: US global network firms, Thomson Reuters, Oberlander · assurance-substantive-testing-08

AI risk scoring to cut substantive sample sizes (Cherry Bekaert on MindBridge)

Grade B · Augment

Problem. Firms relying only on a third-party audit methodology may need much of their assurance from sampling, tying up seniors for hours selecting or testing items.

Approach

- Cherry Bekaert adopted MindBridge in 2020 and built it deliberately: standards mapping, methodology, quality-control validation and firm-wide policy.
- The aim is more assurance from risk scoring of full populations, hence smaller samples; 66% reduction on an illustrative client (vendor-published).
- Associates keep autonomy to make decisions and exercise professional judgment.

Evidence: Cherry Bekaert, MindBridge · assurance-substantive-testing-09

Agents match sampled items to supporting documents and bank activity

Grade B · Automate

Problem. Vouching means opening many differently formatted invoices, contracts and bank records and tracing each sampled amount by hand; one customer put it at about two full days per engagement.

Approach

- Tools extract data from varied documents, match sampled items to evidence and flag gaps. Users include PwC, Thomson Reuters, Sanville & Co.
- A Kentucky firm owner reports engagement time falling from about two days to five or six hours (vendor-published).
- Auditors work the exceptions and analyse differences; each match carries an evidence trail a reviewer can check.

Evidence: PwC, Thomson Reuters, Sanville & Co, Fieldguide · assurance-substantive-testing-10

Firm-built Excel agents for evidence-heavy tests of details (FGMK on DataSnipper)

Grade B · Augment

Problem. FGMK auditors often receive unorganised client files, such as PDFs of over 100 pages, so preparers and reviewers spend significant time finding evidence for each selection.

Approach

- A pilot group at FGMK used DataSnipper Excel Agents to find evidence in client PDFs and trace revenue to contracts.
- Time per selection fell from 30-45 minutes to about 5 minutes of review (vendor-published); firm-wide adoption is planned.
- Reviewer-side agents check consistency across a workbook. The auditor signs off at the end.

Evidence: FGMK, DataSnipper · assurance-substantive-testing-11

Excel evidence snipping and AI extraction for tie-out and vouching (DataSnipper)

Grade B · Assist

Problem. Auditors reconcile numbers from invoices, bank statements and inventory documents to transactions by hand, and reviewers must re-find the evidence.

Approach

- The auditor snips values from source documents into Excel, keeping a link to the source; AI adds extraction from unstructured documents.
- DataSnipper says AI pre-validated more than two million data points from client documents in 2025 (vendor-published).
- The auditor selects and snips the evidence; the reviewer clicks through to the source.

Evidence: DataSnipper · assurance-substantive-testing-12

Automated financial-statement tie-out and testing in fund audits (PwC pilot)

Grade B · Automate

Problem. Fund audits require financial-statement tie-outs and testing of extracted data and documents, a large volume of repeat work per engagement.

Approach

- PwC's tool extracts, organises and tests financial data and documents for non-registered fund-to-fund audits, automating parts of tie-out and testing.
- In October 2025 it was being tested with certain asset and wealth management engagement teams, with a plan to expand the pilot.
- No outcomes published (self-reported); human checkpoints are not described in the source.

Evidence: PwC · assurance-substantive-testing-13

Language-model contract and lease review to target revenue and lease testing

Grade C · Augment

Problem. Checking many contracts or contracts spanning hundreds of pages is repetitive and slow, and a tool that only screens for a term can be mistaken for a complete read.

Approach

- Thomson Reuters' CoCounsel Document Analysis uses agentic AI to review client documents at scale; early adopters report up to 70% faster (vendor-published).
- The UK regulator's illustrative design extracts risk indicators from contracts and scores each one; those above a threshold form the sample.
- The auditor sees which indicators were present, tests the selected contracts, and cannot assume checking is done once AI has helped.

Evidence: Thomson Reuters, EY, RSM Australia · assurance-substantive-testing-14

Agents applied to judgment-heavy tests such as complex revenue and memo checks

Grade B · Augment

Problem. Revenue with complex terms such as rebates needs judgment-heavy testing that routine tools did not cover, and memos can describe something the data does not support.

Approach

- PwC's US assurance transformation leader said the firm was applying AI agents to assess whether US pharmaceutical rebate revenue was recorded properly.
- EY's assurance AI leader expects agents to flag memos not supported by the data; this is an expectation, not a result.
- No outcomes published (self-reported). Humans oversee agent testing and the auditor reviews flagged inconsistencies.

Evidence: PwC, EY · assurance-substantive-testing-15

Analytical procedures with technology-built expectations from detailed or unstructured data

Grade C · Augment

Problem. Year-over-year comparisons dominate substantive analytics; only 11% of 54 surveyed US firms have an automated solution, and practice has diverged on how such procedures are categorised.

Approach

- Draft ISA 520 guidance says tools may structure unstructured industry reports or model revenue against cost of sales to sharpen expectations.
- Deloitte Netherlands (internal audit) and KPMG (SOX) describe 100% transaction coverage where data quality allows.
- The auditor judges whether the expectation is precise enough, investigates differences and obtains evidence for management's explanations.

Evidence: Deloitte Netherlands, KPMG US · assurance-substantive-testing-16

Digital confirmation platforms and direct, authenticated access to bank data

Grade B · Automate

Problem. Firms prepared and chased bank, customer and supplier confirmations by hand, and external evidence often arrives as screenshots or PDFs that can be forged cheaply.

Approach

- Platforms create, send and track confirmations and authenticate responses. Users include Moore Polska and Crowe Spain; BDO NL tested direct bank feeds.
- The vendor's case study says Moore Polska saved up to 20 hours per audit (vendor-published).
- The auditor controls the confirmation request, judges response reliability and investigates anomalies that bank-data analytics flag.

Evidence: Moore Polska, Crowe Spain, BDO NL, Circit · assurance-substantive-testing-17

Drone and imaging tools for inventory counts

Grade B · Augment

Problem. Inventory observation requires auditors at counts of large warehouses and outdoor stock, which is slow and disruptive; standards are unclear on remote observation.

Approach

- EY ran a 2018 proof of concept where drones scan barcodes and labels and send data to the audit platform for reconciliation.
- An academic study found drone counts took 19 hours against 681 manually, with error rates falling from 0.15% to 0.03% (independent).
- The auditor sets scan parameters and sampling, reconciles results and judges the evidence obtained by alternative means.

Evidence: EY, academic study · assurance-substantive-testing-18

Idea: AI-generated independent expectations and challenge for accounting estimates

Grade D · Assist

Problem. This is an idea, not a deployment: accounting estimates had the highest finding rate in IFIAR's 2025 survey, 112 of 498 inspected audits (22%).

Approach

- An AI system supplies contradictory evidence or an alternative estimate that the auditor weighs against management's estimate.
- In an experiment, auditors given contradictory evidence by their firm's AI proposed smaller adjustments than those given it by a human specialist.
- The auditor evaluates the evidence, any specialist's advice and management's estimate, and decides on adjustments.

Evidence: No named deployment · assurance-substantive-testing-19

Agents run routine substantive tests, moving to orchestrated end-to-end runs

Grade B · Delegate

Problem. Routine testing such as expense vouching and unrecorded-liability searches means pulling samples, extracting data and marking pass or fail, which absorbs junior staff time.

Approach

- KPMG announced Clara agents (April 2025) for expense vouching and unrecorded liabilities; in April 2026 it described orchestration agents, piloting summer 2026.
- Fieldguide says its Field Orchestrator went live in June 2026, with the unrecorded-liabilities search as its first end-to-end test.
- The auditor confirms the plan, reviews outputs after each phase and exceptions, and signs off. No measured results (self-reported).

Evidence: KPMG, Fieldguide, DataSnipper · assurance-substantive-testing-20

Auditor and client agents exchange evidence requests, with workpapers reviewed (EY pilot)

Grade B · Delegate

Problem. Selecting items, requesting and chasing client support, and assembling workpapers is manual and slow.

Approach

- EY described pilots where its agents make preliminary selections and request support; the client's agents collect and send it back.
- EY's agents then prepare workpapers. EY says its multi-agent framework is embedded in all audit phases, with end-to-end support expected by 2028.
- Humans review the workpapers the agents prepare. No outcomes published (self-reported).

Evidence: EY · assurance-substantive-testing-21

Firm-wide agent platforms draft substantive workpapers for review (EY, Deloitte, Grant Thornton)

Grade C · Delegate

Problem. Global firms need consistent methodology across thousands of engagements, and staff fieldwork takes hours per workpaper; a benchmark team estimated 2-12 hours each.

Approach

- Deloitte (June 2026) says Omnia agents execute preliminary procedures; EY (April 2026) and Grant Thornton US (May 2026) describe similar agent platforms.
- In a benchmark, the best model strictly passed 69.17% of workpaper tasks in one attempt but 44.44% across all eight attempts (vendor-published).
- Professionals review preliminary conclusions, and Grant Thornton says professionals supervise every step.

Evidence: EY, Deloitte, Grant Thornton US · assurance-substantive-testing-22

Idea: a second AI reviews AI-performed substantive work for errors

Grade D · Augment

Problem. This is an idea, not a deployment: senior review of staff workpapers takes time and can miss errors, and AI tools could review work for omissions or inconsistencies.

Approach

- The AICPA practice aid says one AI tool may perform a procedure and another review it, without reducing the auditor's supervision duties.
- In a benchmark, the best reviewing model raised strict pass on agent-completed workpapers from 28.89% to 62.22% (vendor-published).
- A human reviewer remains responsible for the reviewed workpaper.

Evidence: No named deployment · assurance-substantive-testing-23

AI-native audit pilot testing full populations instead of samples (PwC Australia)

Grade B · Delegate

Problem. Auditors spend time on data gathering and documentation rather than analysis, and sampling limits the scrutiny applied to balances.

Approach

- PwC Australia said in October 2025 it was rolling out an AI-native platform in a global pilot, with agents testing full populations.
- It starts with five audit clients and plans to reach all by 2028. No results published (self-reported).
- The auditor investigates every item identified and the team reviews whether the tool met its objective; PwC says humans keep final judgments.

Evidence: PwC Australia · assurance-substantive-testing-24

Specialist audit firm built to test every transaction in benefit-plan audits (Ledgerline)

Grade C · Automate

Problem. The annual 401(k) audit is described as a four-month chore of requests and follow-ups, with testing a sample of contributions extrapolated to the plan.

Approach

- Ledgerline, a pre-launch specialist audit firm, says it will pull data from source systems and test the whole population, not a sample.
- Its CEO says AI agents paired with deterministic code can check every deposit and distribution and cite the plan provision tested.
- A person stays accountable for every conclusion. No outcomes published (self-reported).

Evidence: Ledgerline · assurance-substantive-testing-25

Specialists and experts

Using experts (valuation, actuarial, tax, forensic) and treating a client's AI as a specialist-like input; A/B entries are advisory, not audit. · 14 use cases · evidence thin (3 of 14 A/B)

Valuation analysts use AI to gather data and build routine model parts

Grade B · Augment

Problem. Routine valuation tasks such as importing annual-report data, adjusting multiples and benchmarking against comparable public companies previously took hours of manual effort.

Approach

- Big Four valuation leaders told a 2025 conference that AI or robotic automation tools now handle data gathering, formatting and routine modelling.
- Analysts focus on interpreting outputs and validating AI-generated results; final valuations stay with people.
- No time or cost figures were given (self-reported). Evidence comes from valuation advisory practices, not audit-employed specialists.

Evidence: PwC, Deloitte, KPMG, EY valuation leaders · assurance-specialists-01

Valuation providers build third-party AI analytics into their methods

Grade C · Augment

Problem. Fund managers are asked for faster, more frequent and more traceable valuations under investor and audit scrutiny, often without extra budget or headcount.

Approach

- CohnReznick announced it is adding 73 Strings valuation analytics to its methods to analyse large data sets (self-reported; no measurements published).
- Valutico's April 2026 release adds AI recommendations for peer and transaction selection (vendor-published; no figures published).
- Valuation professionals retain judgment on complex inputs and conclusions, and review and select peers and inputs.

Evidence: CohnReznick, Valutico, 73 Strings · assurance-specialists-02

Valuers use generative AI to draft report sections like market commentary

Grade C · Augment

Problem. Valuation reports contain narrative sections such as market commentary, which the valuation standards body counts among the more straightforward tasks AI can automate.

Approach

- The International Valuation Standards Council says some valuers already frequently use ChatGPT or other public AI to help write report parts.
- In other cases, report writing may be a fully automated process within the firm.
- The valuer verifies data sources and confirms facts before issuing the report. No outcome figures published (independent).

Evidence: International Valuation Standards Council (no named firm) · assurance-specialists-03

AI-assisted quality-control review of valuation reports (idea)

Grade D · Augment

Problem. This is an idea, not a deployment: valuation reports must use the correct basis of value, be internally consistent and rest on a complete scope of work.

Approach

- The International Valuation Standards Council paper suggests AI could review reports for the correct basis of value and for inconsistencies.
- It could also check that the scope of work contains all relevant elements.
- The valuer or reviewer remains responsible for the report.

Evidence: No named deployment · assurance-specialists-04

Agents build complete valuation models; analysts supply and review assumptions (idea)

Grade D · Delegate

Problem. This is an idea, not a deployment: the judgment in a valuation model sits in company-specific assumptions, on which professional analysts legitimately disagree.

Approach

- Researchers report that language-model agents can now construct complete financial models, and built a benchmark from 1,001 professional valuations to grade them.
- Agents are far better at building models than at deriving the company-specific assumptions that drive valuation (independent research).
- The analyst supplies and challenges the company-specific assumptions.

Evidence: No named deployment · assurance-specialists-05

Actuaries use generative AI for analysis and code under model-validation standards (idea)

Grade D · Assist

Problem. This is an idea, not a deployment: actuaries must explain methods and justify assumptions, which opaque 'black-box' language models make difficult.

Approach

- The American Academy of Actuaries treats generative AI as a model, so the US modeling standard applies and results need validation.
- A July 2026 benchmark found frontier models strong on standard actuarial knowledge but much weaker on case reasoning and jurisdiction-sensitive practice (independent).
- The actuary vets and validates AI recommendations before applying them.

Evidence: No named deployment · assurance-specialists-06

Actuarial audit specialists test a client's AI reserving model (idea)

Grade D · Assist

Problem. This is an idea, not a deployment: black-box reserving models give auditors little visibility, so usual in-model checks of claim development may no longer work.

Approach

- A Forvis Mazars Ireland actuarial director describes ten steps, including upskilling audit teams in machine learning and benchmarking against traditional reserving methods.
- Steps also include testing which inputs drove outputs, assessing model architecture and testing reproducibility (self-reported).
- Actuarial audit teams apply expert judgment and professional skepticism on when to use more sophisticated techniques.

Evidence: No named deployment · assurance-specialists-07

Actuarial auditors build AI challenger to test a client's reserving model (idea)

Grade D · Augment

Problem. This is an idea, not a deployment: if a client's black-box model claims results traditional methods cannot validate, the auditor has no independent comparison.

Approach

- The Forvis Mazars author says using one AI model to challenge another could become commonplace in actuarial audit (self-reported opinion).
- It could help identify user bias in model selection and design, and requires audit teams to build coding skills.
- The specialist judges whether differences between the client's model and the challenger are explained.

Evidence: No named deployment · assurance-specialists-08

Auditors obtain AI-use disclosures when management's expert uses AI (idea)

Grade D · Assist

Problem. This is an idea, not a deployment: a specialist's work is technical and often not fully transparent to the auditor, and AI inside an expert's valuation adds opacity.

Approach

- The valuation standards council says valuers should disclose whether, how and why AI was used; its January 2026 draft would mandate it.
- Auditors already evaluate a specialist's data, assumptions and methods, so such disclosures would feed that evaluation.
- The engagement partner and team evaluate whether the specialist's work provides sufficient appropriate evidence.

Evidence: No named deployment · assurance-specialists-09

Auditors treat a client's significant AI use like complex valuation models (idea)

Grade D · Assist

Problem. This is an idea, not a deployment: clients embed AI in financial reporting while governance is immature, with only 6% of audit partners rating it advanced at their largest client.

Approach

- The AICPA practice aid says client AI with a significant reporting role may warrant considerations like external specialists and complex valuation models.
- The Australian auditing standards board says restricted access to a third-party AI application's logic may be a scope limitation (independent sources).
- The auditor remains responsible for the audit and the opinion.

Evidence: No named deployment · assurance-specialists-10

AI and data-science experts engaged as auditor's experts (idea) (idea)

Grade D · Assist

Problem. This is an idea, not a deployment: current specialist guidance gives valuation, actuarial, environmental, legal and tax examples, not AI, yet audit teams need people who can evaluate AI systems.

Approach

- Nigeria's chartered accountants institute asked the IAASB in July 2025 to add AI and machine-learning experts to its specialist guidance examples.
- Big Four job postings requiring AI expertise rose to nearly 7% in 2025 from under 2% in 2022; hiring evidence only (independent).
- The auditor evaluates the adequacy of the expert's work for the auditor's purposes.

Evidence: No named deployment · assurance-specialists-11

Auditors use a firm-specific language model on a complex inventory valuation task

Grade C · Assist

Problem. Complex valuation tasks require auditors to produce correct documentation under time pressure.

Approach

- A field experiment gave 100 auditors at a global audit firm an inventory valuation task, with or without a firm-specific language model.
- Access significantly improved output quality and cut completion time, but not adherence to internal audit guidelines (independent; no figures in abstract).
- Gains were largest for active users and did not differ by auditor experience. Human checkpoints are not described.

Evidence: Global audit firm (unnamed), academic study · assurance-specialists-12

Tax advisers use AI tools: one in use, a generative assistant announced

Grade B · Assist

Problem. Tax professionals spend time searching and analysing tax legislation and case law.

Approach

- KPMG UK already used Blue J's AI to predict tax scenario outcomes for employees to review, in its 3,000-strong tax team.
- KPMG says the predictive tool forecasts outcomes with 90%+ accuracy (self-reported); this is not the generative product.
- In February 2024 KPMG UK and Blue J announced they will launch Ask Blue J, a generative AI tax assistant.
- Tax professionals review outputs and advise clients. This is tax advisory, not audit tax specialists.

Evidence: KPMG UK, Blue J · assurance-specialists-13

Automated recalculation and sensitivity testing of management's impairment models (Deloitte UK)

Grade B · Augment

Problem. Impairment is a judgemental, higher-risk area, and recalculating management's cash-flow models and running sensitivities by hand takes time away from the assumptions that matter.

Approach

- Deloitte UK says it deployed automated impairment modelling across its largest audits, recalculating models and running sensitivities.
- In consumer-business audits it ran the modelling across ten entities and identified several calculation inaccuracies (self-reported; error count not given).
- Practitioners apply professional judgement to flagged patterns; impairment specialists provide independent challenge. Deloitte plans to extend it to going concern.

Evidence: Deloitte UK · assurance-specialists-14

Completion and reporting

Disclosure checklists, tie-out, going concern, EQR, KAMs and CAMs, audit committee communications, the opinion. · 18 use cases · evidence thin (3 of 18 A/B)

AI first pass of the disclosure checklist, with cited answers

Grade C · Augment

Problem. Disclosure checklists run to hundreds of questions that reviewers answer by hand against the client's statements, typically taking several hours per engagement, and missed disclosures can become inspection findings.

Approach

- The tool reads the draft statements, works through each requirement, proposes a cited answer with rationale, and flags questions it cannot support.
- The auditor accepts, edits or rejects each suggestion; Caseware says only approved answers are written to the engagement file.
- Caseware beta firms saved 2.7 hours per checklist run on average (vendor-published); Thomson Reuters reports about 30% uptake among eligible customers (vendor-published).

Evidence: Caseware, Thomson Reuters, Ideagen, DataSnipper · assurance-completion-reporting-01

Disclosure-checklist and statement analysis built into Big Four audit platforms

Grade C · Augment

Problem. Auditors must complete required disclosure checklists, evaluate compliance with disclosure requirements and review draft statements before sign-off.

Approach

- KPMG announced in April 2025 a Financial Report Analyzer in KPMG Clara whose output helps auditors complete disclosure checklists.
- Deloitte announced in June 2026 Omnia agents that include evaluating disclosure compliance; PwC said it plans statement review and tie-out tools.
- Auditors complete the checklists and make the decisions; preliminary conclusions go to professionals to review. No outcomes published (self-reported).

Evidence: KPMG, Deloitte, PwC · assurance-completion-reporting-02

AI second look at a completed checklist, flagging answers that differ

Grade C · Augment

Problem. Long checklists cause reviewer fatigue and firms roll last year's checklist forward; Caseware's beta found completed checklists with answers that were wrong because a requirement was misread.

Approach

- The tool runs against the auditor's own answers and flags where its reading of a requirement differs, so effort goes to disagreements.
- Caseware reports beta firms also used its agent as a quality check on checklists already completed.
- In one beta case it surfaced questions answered incorrectly through misinterpretation (vendor-published); the auditor resolves each flagged divergence.

Evidence: Thomson Reuters, Caseware · assurance-completion-reporting-03

AI proposes 'No' and 'Not applicable' answers on disclosure requirements

Grade C · Augment

Problem. Conditional requirements such as 'if material' need professional judgment, so they lean on experienced staff and limit how much juniors can do.

Approach

- Thomson Reuters says future Disclosure Review will extend to harder calls like 'No' and 'Not applicable'; no release date given.
- Ideagen's tool already marks items it cannot find as No for the user to review.
- Human checkpoint for the future feature is not specified; today a senior or manager decides applicability and materiality. No outcomes published (vendor-published).

Evidence: Thomson Reuters, Ideagen · assurance-completion-reporting-04

AI review of management reports against statutory disclosure rules (German Big 4)

Grade C · Augment

Problem. Auditing the management report has relied on a manual, checklist-based approach; reading front-section text for inconsistencies with the statements is tedious, and late edits break cross-references.

Approach

- A task-specific AI system at a German Big 4 firm links report passages to statutory requirements, checks calculations and highlights version changes.
- Auditors review and document suggestions passage by passage, with dual-control review; the tool does not replace professional judgement.
- Surveyed auditors judged it improved effectiveness and efficiency, more for standard tasks than complex ones; perception, not a measured error rate (independent).

Evidence: A German Big 4 firm (unnamed) · assurance-completion-reporting-05

Automated checking and tie-out of draft financial statements, re-checking only changes

Grade A · Automate

Problem. HLB Mann Judd Perth reviews over 300 sets of financial statements a year, about 1,200 hours on first-draft reviews alone; its earlier Excel add-in crashed and lost review marks.

Approach

- Caseware Validate runs thousands of checks in seconds and carries earlier checks forward, so later drafts need only the changes re-checked.
- HLB Mann Judd Perth reports about 600 hours saved a year; MHA's trial cut casting from 25 to 12 minutes (vendor-published).
- Managers and seniors review the output, focusing on key risks and disclosure completeness; preparers or reviewers clear each exception before issue.

Evidence: HLB Mann Judd Perth, MHA, Caseware, Suralink · assurance-completion-reporting-06

Agents draft financial statements and keep re-validating them (Fieldguide Field Financials)

Grade C · Augment

Problem. Fieldguide says preparing financial statements has needed a fragmented mix of reports and spreadsheets.

Approach

- Fieldguide announced three agents: one drafts a rolled-forward first draft from the prior-year report and current trial balance data.
- A second validates continuously and flags stale overrides when adjustments change; a third rolls forward footnote language and fills schedule-driven disclosures.
- Practitioners stay in the reviewer's seat, per Fieldguide's CEO; how review is recorded is not described. No outcomes published (vendor-published).

Evidence: Fieldguide · assurance-completion-reporting-07

Engagement-file review assistant tracking open issues and sign-off readiness

Grade C · Augment

Problem. Manual file review re-performs work by hand, and PCAOB staff found inspected firms with at least one engagement quality review deficiency rose from 37% in 2020 to 42% in 2022.

Approach

- Caseware announced cross-file risk checks, unresolved-issue tracking and review pack generation for managers, and earlier sign-off visibility for partners (vendor-published).
- In a Caseware scenario a reviewer asks if the team missed anything; the tool surfaces a variance against board minutes.
- Fieldguide lists a reviewer agent rolling out later in 2026. The reviewer decides what holds and what goes back.

Evidence: Caseware, Fieldguide · assurance-completion-reporting-08

Tool analyses audit committee communications to surface issues earlier (PwC)

Grade C · Assist

Problem. IFIAR's 2025 survey found audit committee communications findings in 79 of 725 inspected audits, against 24 of 593 in 2024; PwC wants such issues handled sooner in audit preparation.

Approach

- In October 2026 PwC's US assurance leader said another tool analyses audit committee communications for 2026 year-end audits to surface issues sooner.
- The source does not say which communications the tool reads or who uses its output; no human checkpoint is described.
- No outcomes published (self-reported).

Evidence: PwC · assurance-completion-reporting-09

Predictive or language model gives auditors a going-concern signal (BDO Netherlands)

Grade B · Assist

Problem. Going-concern assessment is a matter of significant judgment, and traditional machine-learning bankruptcy models struggle with complex, unstructured data.

Approach

- In Spain an audit firm used a decision tree as a supplemental guide and compared its suggestions with the auditors' reports.
- In the Netherlands a language model combined financial data with audit-report text to predict bankruptcy within two years, shown to BDO accountants.
- On 20 case studies, accuracy was model 85%, control group 77%, LLM-assisted group 78%, with no speed difference (independent).
- The accountant makes the going-concern call; the prediction and summary are inputs.

Evidence: BDO Netherlands, a Spanish audit firm · assurance-completion-reporting-10

Idea: tools stress-test management's going-concern assessment and its data

Grade D · Assist

Problem. This is an idea, not a deployment: the revised going-concern standard strengthens the auditor's evaluation of management's assessment and takes effect for periods beginning on or after 15 December 2026.

Approach

- The standard's application material says automated tools may help with sensitivity analysis, such as discount or growth rates, on management's assessment.
- They may also help evaluate the reliability of large volumes of data from several sources used by management.
- The auditor evaluates management's method, assumptions and data. No outcomes published (independent).

Evidence: No named deployment · assurance-completion-reporting-11

Idea: AI proposes key audit matters for comparison with the team's

Grade D · Assist

Problem. This is an idea, not a deployment: auditors choose key audit matters from significant matters discussed with governance, a professional judgment, and views differ on how useful disclosures are.

Approach

- A 2026 University of Genoa thesis tested a language model identifying key audit matters from the annual report alone, then compared them.
- A 2024 seminar abstract reports AI predicted approximately 37% of auditor-reported critical audit matters (independent).
- The auditor decides which matters qualify; the thesis concludes AI can support the process without replacing professional judgement.

Evidence: No named deployment · assurance-completion-reporting-12

Generative AI drafts audit memos and documentation for professional review

Grade C · Augment

Problem. AI-drafted audit text can be fluent and wrong; Big4News reports EY Canada withdrew a research report with 16 of 27 references hallucinated, though not an audit document.

Approach

- PCAOB staff reported in July 2024 that some firms let staff use generative AI for initial drafts of audit memos and presentations.
- Deloitte's June 2026 announcement lists drafting documentation and developing preliminary conclusions among its Omnia agent examples.
- Professionals review the agents' conclusions; the team member stays responsible. A named person checking each cited source is only an idea.

Evidence: Deloitte, firms named by PCAOB staff · assurance-completion-reporting-13

ChatGPT used across audit preparation, fieldwork and reporting in internal audit (Uniper)

Grade B · Augment

Problem. Internal audit teams draft engagement reports and related documents as part of every audit.

Approach

- Uniper's internal audit function uses ChatGPT in audit preparation, fieldwork and audit reporting tasks.
- The function estimates efficiency gains of 50 to 80 percent from initial tests across various processes, including reporting (self-reported estimate).
- The authors also report the key risks, challenges, and rules Uniper adopted. Human checkpoints are not described in the abstract.

Evidence: Uniper internal audit · assurance-completion-reporting-14

Idea: a language model reviews financial statements for errors against accounting standards

Grade D · Assist

Problem. This is an idea, not a deployment: researchers say manual financial statement auditing is inefficient and error-prone, and auditors still miss errors despite extensive verification.

Approach

- One benchmark maps errors to violated standards; models found errors given transaction data but were weak at citing standards and completing audits.
- A separate unsupervised method flags likely misinformation using past statements and audit reports, demonstrated on 11,460 financial statements over 5 years (independent).
- The auditor explores flagged data sources and business processes to validate suggestions.

Evidence: No named deployment · assurance-completion-reporting-15

Idea: a language model checks XBRL tagging and cross-document consistency

Grade D · Assist

Problem. This is an idea, not a deployment: tagging errors in filed statements, such as sign flips and unneeded custom tags, still draw SEC comments; auditors do not attest the tagging.

Approach

- The FinAuditing benchmark of 1,102 real-filing instances tests whether language models can match concepts, extract taxonomy relations and reason across documents.
- Thirteen models showed substantial gaps in concept retrieval, relation modelling and consistent cross-document reasoning (independent).
- A named reviewer owns the tagging review.

Evidence: No named deployment · assurance-completion-reporting-16

Idea: a reviewing agent checks the preparing agent's work before humans sign

Grade D · Delegate

Problem. This is an idea, not a deployment: as agents prepare more of the file, human review becomes the bottleneck and the main control.

Approach

- The AICPA practice aid says one AI tool may help the auditor evaluate another, without reducing supervision and review duties.
- The UK Financial Reporting Council guidance says reviews may be done by humans, other language models or rules-based protocols.
- The human reviewer and partner still sign. No outcomes published (independent).

Evidence: No named deployment · assurance-completion-reporting-17

Idea: an agent completes and reviews staff-level workpapers across the engagement file

Grade D · Delegate

Problem. This is an idea, not a deployment: preparing workpapers consumes staff time before review, and limited access to proprietary audit data has constrained measuring where agents can be relied on.

Approach

- FinancialAuditBench sets 90 workpaper completion and review tasks across six synthetic engagements and evaluates eleven frontier models.
- Agents completed substantial portions of staff-level tasks well but sometimes performed inappropriate procedures or produced incorrect documentation (independent).
- Caseware has a Document Intelligence Agent in closed beta. Professional review remains necessary where agents are not reliable.

Evidence: No named deployment · assurance-completion-reporting-18

Quality management

Firm-level AI tool governance (certify, monitor, recertify) and engagement-level supervision and review of AI output; no measured outcome. · 25 use cases · evidence moderate (10 of 25 A/B)

Certify AI tools per use case, approve centrally, recertify on defined triggers

Grade B · Assist

Problem. Firm quality-management processes were built for transparent, deterministic tools, so it is hard to decide how much testing AI tools need before deployment and how to monitor them afterwards.

Approach

- UK regulator FRC says each tool is certified within a use case, testing outputs on default, edge and known-weakness cases.
- Recertification may be triggered by material change, a different use case, performance issues, changed standards or elapsed time.
- Deloitte UK's Technology Controls Board, set up in April 2026, reviews tools before pilot and deployment; no measure is given (self-reported).
- Tool owner, methodology and business sign off certification; quality leadership decides whether to recertify after a trigger event.

Evidence: FRC, Deloitte UK, IAASB · assurance-quality-management-01

Risk-tiered policy: approved AI tools, barred uses, triage and a prompt library

Grade B · Assist

Problem. Staff will use general AI tools unless told which are allowed; most of the six largest UK firms certified every tool identically, regardless of risk.

Approach

- Firms list permitted tools and uses, bar some uses and scale validation to risk, with a central triage step for new proposals.
- PwC US gave staff AI training and LLM access for pre-approved work such as administrative tasks before launching audit-specific AI.
- Deloitte UK describes risk thresholding, triage and a clearing house for GenAI use cases; no result is published (self-reported).
- A clearing house decides the tier before build or purchase; the methodology owner approves each permitted use case and prompt set.

Evidence: PwC US, Deloitte UK, FRC, PCAOB staff · assurance-quality-management-02

Inventory of approved AI tools, with controls against unapproved or outdated use

Grade C · Assist

Problem. AI tools multiply faster than firms approve them and staff can reach public chatbots; the FRC found firms generally did not monitor that teams used only authorised, current tools.

Approach

- Firms keep inventories of current certified tools and versions, relying on preventive controls such as approved repositories and blocking unauthorised installs.
- Most of the six largest UK firms kept such inventories; usage monitoring mainly counted teams using tools, typically for licensing (independent).
- More than a third of surveyed tax and audit professionals admit using unauthorised AI tools (vendor-published).
- A named function approves exceptions, unapproved tools found in use are escalated, and engagement reviews check for incorrect use.

Evidence: FRC, IFIAR, Thomson Reuters Institute · assurance-quality-management-03

Evaluation sets and parallel running before full rollout of an AI tool

Grade C · Assist

Problem. No public benchmark or firm result says how often an audit AI tool's output is wrong in live use, and tolerance for deficient output remains a professional judgement.

Approach

- Firms build representative test sets and score tool output against them before release and after model changes.
- IFIAR lists benchmarking against traditional methods and false-positive and false-negative rates versus a manual sample as emerging practice.
- FRC: tools may go to a few teams before full certification, and teams often perform the alternative procedures in parallel.
- No parallel-run results are published; methodology specialists agree pass criteria and the quality team decides when a pilot ends.

Evidence: FRC, IFIAR, AUASB · assurance-quality-management-04

Embed methodology in AI tool design and validate the assurance it provides

Grade C · Assist

Problem. Methodology can permit approaches that fail auditing standards even if a tool works; IFIAR's most frequent findings were misreading tool results and thin outlier testing.

Approach

- Methodology teams join tool development and approve how output is used as evidence; certification validates methodology against auditing standards.
- FRC example: assurance from the AI procedure rests on confidence in its risk indicators and sampling, which sets remaining substantive testing.
- Most of the six largest UK firms capture methodology-team sign-off in certification documents (independent).
- IFIAR: 31% of members (2024) and 29% (2023) reported findings that a tool was not used as intended (independent).

Evidence: FRC, IFIAR, CPAB, NFRA · assurance-quality-management-05

Due diligence and contracts for third-party AI tools, scaled for smaller firms

Grade C · Assist

Problem. Firms usually get the foundation model from a third party and often cannot evaluate its training data or logic, and smaller firms lack specialists to assess it.

Approach

- All six largest UK firms weighed vendor controls, data security and confidentiality when choosing tools (FRC finding); no outcome is published.
- Where information is unavailable, the FRC says firms may rely on independent assurance and test more themselves.
- NFRA staff call for contract terms on data protection, audit rights and continuity; CPAB suggests a SOC 2 report on IT controls.
- Procurement, security and methodology approve the vendor, and the firm re-approves the tool when the vendor changes the model.

Evidence: FRC, CPAB, NFRA, AFM, ICAEW · assurance-quality-management-06

Monitor AI tool use and audit-quality impact with metrics and dashboards

Grade C · Assist

Problem. Firms count tool usage, mostly for licensing, but do not quantify the effect on audit quality, and it is sometimes unclear who monitors globally developed tools.

Approach

- IFIAR examples: thematic reviews with metrics such as false-positive and false-negative rates against a manual sample, plus usage dashboards.
- AFM found engagement-level usage was estimated for 74% of auditing tools, actual data for 20%, unclear for 6% (independent).
- FRC: none of the six largest UK firms formally quantified audit-quality impact; one reported usage against targets for certain key tools (independent).
- Quality leaders review impact metrics and decide to restrict, retrain or recertify a tool.

Evidence: FRC, AFM, IFIAR · assurance-quality-management-07

Board-level AI oversight in the quality plan, with escalation channels

Grade B · Assist

Problem. Using AI tools reaches beyond technology resources into governance, ethics and engagement performance, and unexpected AI failures may not reach the tool owner or quality function.

Approach

- Deloitte UK's independent Audit Governance Board reviewed its quality plan, now covering AI, with a human in the loop central (self-reported).
- Deloitte UK's Chief AI Officer is responsible for embedding responsible AI governance across client services and internal operations.
- IFIAR suggests formal escalation paths for unexpected outputs, user feedback, AI oversight committees and whistleblowing procedures covering AI use.
- A committee or tool owner decides whether to pause, restrict or re-approve a tool after an incident; no outcome is published.

Evidence: Deloitte UK, IFIAR, CPAB, IAASB · assurance-quality-management-08

Get the firm's own AI management system certified to ISO/IEC 42001

Grade B · Assist

Problem. Firms need external reference points for governing their own AI use; SEC staff said there is no single authority or framework for AI governance, speaking of preparers, not audit firms.

Approach

- KPMG announced in November 2025 that it achieved ISO 42001 certification of its internal AI management systems (self-reported).
- KPMG called it a necessary precursor to AI assurance services and said it is the first Big Four firm to achieve it.
- The announcement does not say which KPMG entity was certified, and no quality measurement is published.

Evidence: KPMG · assurance-quality-management-09

Role-based AI training tied to tool access, with in-workflow micro-training

Grade B · Assist

Problem. Reviewers who cannot judge when AI output is wrong cannot review it; untrained staff was the top-ranked blocker to audit transformation in a survey of 54 US CPA firms.

Approach

- Training is tailored by user group; the FRC says it should cover reviewing tool output, automation bias (over-trusting machines) and known weaknesses.
- PwC made GenAI training mandatory before ChatPwC access and KPMG trained all auditors in prompt engineering (2024 reports, per an academic reading).
- Deloitte announced on 24 June 2026 a 'tutor mode' in Omnia giving on-demand micro-training within the work (self-reported).
- Tool access is conditional on completed training; no measure of training's effect on review quality is published.

Evidence: FRC, IFIAR, PwC, KPMG, Deloitte · assurance-quality-management-10

Connected engagement resourcing: staffing, budgets and leader review in one tool

Grade C · Assist

Problem. The quality standard ISQM 1 requires firms to assign people with the competence and capacity for each engagement; RSM describes replacing manual staffing and budgeting processes.

Approach

- RSM's Luca Resourcing is a connected tool for initial staffing requests, budget planning and engagement-leader review, giving teams visibility of planning.
- RSM lists it among its AI-related investments but does not say what AI does inside it.
- The engagement leader reviews and approves the staffing plan and budget; no outcome is published (self-reported).
- IRBA cites AI analysis of staff profiles and experience for resource optimisation as an example in audit planning.

Evidence: RSM, IRBA · assurance-quality-management-11

Firm-approved guidance assistant for audit research, grounded in the firm's own manuals

Grade B · Assist

Problem. Auditors spend time finding and applying the firm's own assurance manuals and guides and may apply them inconsistently, while generic chatbots can produce hallucinations, omissions and distortions.

Approach

- RSM US launched Ask Luca on 8 January 2026, drawing on its assurance manuals and guides for 4,000+ assurance professionals (self-reported).
- Deloitte UK launched a Research Assistant chatbot for audit research; PCAOB staff heard some firms built tools to research internal guidance.
- No time, accuracy or consistency measure is published.
- The auditor checks the source guidance and applies own judgement; complex or novel questions still go to technical consultation.

Evidence: RSM US, Deloitte UK, PCAOB staff · assurance-quality-management-12

Engage regulators early on new AI tools and keep inspection-ready tool files

Grade C · Assist

Problem. Standards do not yet address AI directly, yet regulators say they will inspect AI use and are still working out whether new standards or documentation rules are needed.

Approach

- PCAOB inspectors meet firms, generally larger ones, to understand their AI use; many invited inspectors to demonstrations while piloting.
- FRC's Audit Tech & AI Sandbox opened 4 June 2026: about three expert meetings for selected UK firms, with no endorsement.
- A central file per tool holds its purpose, development, certification and training, drawing on the FRC's split of documentation.
- Quality leadership decides what to bring to regulators and when; sandbox participants are not named and no outcome is published.

Evidence: PCAOB, FRC, IFIAR, CPAB · assurance-quality-management-13

Idea: use AI in the firm's own quality monitoring and root-cause analysis

Grade D · Augment

Problem. Idea only, no deployment: IFIAR counted 21 findings in 2025 (6 in 2024) for firms failing to identify audit performance issues in internal inspections.

Approach

- The SEC's chief accountant said the SEC asks auditors how they use AI to monitor their system of quality control.
- NFRA's staff paper calls for root-cause analysis of technology-related findings to feed the annual evaluation of the quality system.
- No firm example was found; the FRC noted tool use may appear in root-cause analysis without saying AI does the analysis.
- Quality leadership would decide which root causes are real; remediation owners would sign off actions.

Evidence: No named deployment · assurance-quality-management-14

Idea: independent validation or assurance of audit firms' own AI tools

Grade D · Augment

Problem. Idea only, not a deployment: smaller firms without in-house expertise may want someone to confirm a tool works as intended; the market is fragmented and not regulated traditionally.

Approach

- Deloitte's Martin Brown said third-party providers should be doing testing and evaluation for the use case (ICAEW podcast).
- Grant Thornton UK's Jon Morris said smaller firms would probably favour a provider partnered with a large firm; early days.
- No outcome is published; the firm would decide what weight to give a third-party validation when approving a tool.

Evidence: No named deployment · assurance-quality-management-15

Firm-wide audit programmes on an AI platform, updated centrally after inspection findings

Grade B · Augment

Problem. Sanville & Company, a 20-person firm on a legacy platform, found sample-heavy testing created bottlenecks at partner and quality review as QC 1000 approached.

Approach

- Sanville built its audit programmes in Fieldguide, referencing PCAOB standards in each step, and sent templates to every engagement at once.
- Agentic testing handled sample-heavy tracing of incoming client support.
- After a PCAOB exam flagged an issue, the partner updated the programme and pushed it to every open engagement next morning.
- First PCAOB inspection fully on the platform had zero comment forms; overhaul took under a year versus 18-24 months expected (vendor-published).

Evidence: Sanville & Company, Fieldguide · assurance-quality-management-16

Idea: plan AI use at the outset and review it before sign-off

Grade D · Assist

Problem. Idea only, no deployment: the engagement partner is responsible for direction, supervision and review, but tool outputs that are hard to explain or invite over-reliance complicate this.

Approach

- IFIAR asks engagement leaders to set expectations at the outset for how technology will be used, including planned uses of AI.
- IFIAR also asks senior team members to reflect at the end on technology use in the file and whether scepticism was maintained.
- The AICPA practice aid recommends planning intended AI use; partners must understand the tools and ensure the firm approved them.
- The engagement leader would approve the planned AI uses; IRBA places responsibility for appropriate use on the engagement partner.

Evidence: No named deployment · assurance-quality-management-17

Human control points in AI-agent audit workflows, with escalation and approval

Grade B · Delegate

Problem. Agents run multi-step procedures, so there is no single output to review; without defined review points errors compound and reviewers either redo everything or accept plausible output.

Approach

- The FRC separates final-output review from oversight at control points (intermediate results, planned actions), and lets the tool escalate when uncertain.
- IFIAR asks firms to assign specific personnel to decision checkpoints; IAASB roundtable participants called human-in-the-loop oversight non-negotiable.
- Deloitte UK says teams critically assess, corroborate and approve agent results before use; KPMG says agents work 'in concert with human review'.
- Deloitte and KPMG describe this as design intent and report no review results or control-point catches (self-reported).

Evidence: Deloitte UK, KPMG, FRC, IFIAR · assurance-quality-management-18

Review mechanics for AI output: citations, source tie-back and confirmation gates

Grade C · Augment

Problem. A confident, well-formatted AI output can pass review with less challenge than a junior's work, and fluent output without sources cannot be checked efficiently.

Approach

- FRC worked examples have the tool cite stable document identifiers for every extract, which supports review and reduces fabrication.
- AFM saw good practice where each workflow step completes only once the auditor confirms the output was reviewed and supported by evidence.
- Fieldguide says each agent run keeps a Trace of inputs, outputs and reasoning (vendor-published); PwC and RSM describe similar evidence trails.
- No measured detection or override rate is published; reviewers confirm each AI-assisted step and check cited sources.

Evidence: FRC, AFM, Fieldguide, PwC, RSM · assurance-quality-management-19

Idea: reviewers form an independent view before reading the AI's answer

Grade D · Assist

Problem. Idea only, no deployment: in an experiment, auditors relying on automated tools were less sceptical than when relying on a team member's work.

Approach

- The FRC says review may mean forming an independent view to compare, such as reading source material to confirm a GenAI summary.
- In the Peters experiment a counter-arguing mindset intervention alleviated the loss of scepticism; it concerned automated tools, not GenAI (independent).
- The AFM saw auditors make their own fraud-risk assessment first, then use a GenAI tool to challenge it.
- Reviewer records an independent view before opening AI output; a supervisor spot-checks the quality of challenge.

Evidence: No named deployment · assurance-quality-management-20

AI checks of audit files for omissions and inconsistencies before reviewer sign-off

Grade B · Augment

Problem. Reviewers spend time on completeness and consistency checks that cost attention needed for judgemental areas, and review is a bottleneck.

Approach

- Deloitte UK: GenAI tool Smart Review fully deployed in the year to 31 May 2025; all FTSE audits have access (self-reported).
- KPMG says agents in KPMG Clara can assist teams by reviewing engagement documentation.
- PIA Group's Group CIO describes hundreds, in some cases more than 1,000, AI checks per file (interview claim, not measured).
- Reviewers resolve every AI-raised exception and still review judgemental areas; neither firm describes how reviewers use the output.

Evidence: Deloitte UK, KPMG, PIA Group · assurance-quality-management-21

Idea: cross-check AI output with a second model or rules-based tool

Grade D · Augment

Problem. Idea only, no deployment: generative tools are probabilistic, the same prompt can give different outputs, and human reviewers cannot catch every deficiency in high-volume AI output.

Approach

- FRC guidance lists one AI model reviewing another's work, several models attempting a task, and rules-based checks such as schema checking.
- As reported, the AICPA practice aid says one AI tool may check another, but the auditor's review responsibility is not reduced.
- Grant Thornton UK's Jon Morris put AI reviewing AI 'a few years down the line'; no result is published.
- The process escalates to a human when components disagree or the checker is unsure.

Evidence: No named deployment · assurance-quality-management-22

Record AI use centrally per tool and on each engagement file

Grade C · Assist

Problem. Inspectors and reviewers cannot challenge AI-assisted work if the file does not show where AI was used and how the team responded; the AFM found this not always clear.

Approach

- FRC guidance keeps a tool's purpose, development, certification and training centrally; the engagement file holds version, prompts and how outputs informed conclusions.
- IFIAR asks firms to identify GenAI use in critical audit areas and to explain how auditor judgement was applied to outputs.
- FRC: firms with engagement-specific tool processes all required templates on the audit file, though some wording made completion look optional (independent).
- A named reviewer records reasons for each AI-assisted procedure; none of four UK Big Four 2024 reports stated override frequency (independent).

Evidence: FRC, AFM, IFIAR, NFRA · assurance-quality-management-23

Disclose AI use to clients and audit committees via engagement-letter terms

Grade B · Assist

Problem. Clients worry about where their data goes and whether it trains models; a Grant Thornton UK director said some clients were nervous and a few would not sign up.

Approach

- Grant Thornton UK uses clear engagement-letter terms on AI use and in some cases ring-fences work from model training.
- Deloitte's Martin Brown said very few clients had asked the firm not to use GenAI, and that transparency and education matter.
- A Foley article suggests audit committees ask what the auditor does with AI, under what controls, and how AI-assisted judgements are documented.
- The engagement leader agrees AI-use terms with the client and audit committee; no measure is published (self-reported).

Evidence: Grant Thornton UK, Deloitte, IFIAR · assurance-quality-management-24

Redesign supervision and early-career development as juniors review AI output

Grade C · Augment

Problem. If tools do the first-pass work juniors used to do, juniors lose the practice that built judgement while being asked to review tool output.

Approach

- PwC's AI assurance leader said in August 2025 that new hires would act like managers within three years by overseeing AI.
- PwC says assurance training is moving back to basics, with earlier time on critical thinking, negotiation and professional scepticism.
- IFIAR asks firms to prioritise supervision training; the Thomson Reuters Institute says juniors still need structured development and supervision.
- No outcome is published; baseline: 31 IFIAR findings on supervision and review policies in 2025, up from 10 in 2024 (independent).

Evidence: PwC, IFIAR, Thomson Reuters Institute, CPAB · assurance-quality-management-25

SOC reports and attestation

SOC 1, 2 and 3 and ISAE 3402 or 3000 end to end, compliance platforms, SOC 2 quality concerns. · 16 use cases · evidence strong (9 of 16 A/B)

AI for client acceptance, sampling and scheduling at a SOC audit firm

Grade B · Assist

Problem. A System and Organization Controls (SOC) practice must decide which engagements to accept, select samples, and schedule many concurrent audits.

Approach

- Linford & Company, an IT-audit specialist firm, says it uses AI for client acceptance, sampling of results and scheduling concurrent audits.
- The post gives no detail on tools or methods.
- Linford says the uses make audits more thorough, not faster (self-reported).
- Acceptance and sampling decisions remain with the firm; the post presents AI as a support.

Evidence: Linford & Company · assurance-soc-attestation-01

Compliance platforms draft policies, risk assessments and system descriptions for SOC 2

Grade C · Augment

Problem. A company preparing for its first SOC 2 report must write policies, a risk assessment, control narratives and a system description, and generic templates produce look-alike documents.

Approach

- Platforms supply policy templates and risk-assessment questions; Vanta's agent drafts tailored policies and compares them with what is happening in the environment.
- Comp AI says its AI learns a company's stack and risk tolerance to generate company-specific policies; Vanta describes an auto-generated system description.
- Comp AI promises 'Compliance in days' and 'SOC 2 audit-ready in weeks'; no time saving is quantified (vendor-published).
- A person approves each draft policy and management owns the description; the auditor tests whether it fairly presents the system.

Evidence: Vanta, Comp AI · assurance-soc-attestation-02

AI-generated fixes for failing controls before the examination, with expert approval

Grade C · Augment

Problem. Readiness work surfaces failing tests such as misconfigured access or missing encryption, and engineers must fix them before the observation period begins.

Approach

- Vanta's agent generates remediation snippets for tools such as Terraform, AWS CLI and CloudFormation; Secureframe sells 'Comply AI for Remediation'.
- Oneleet says its AI fixes gaps and an expert approves every fix before it counts as done (vendor-published).
- No outcome measure for remediation is published; an engineer or expert approves each change.

Evidence: Vanta, Secureframe, Oneleet · assurance-soc-attestation-03

AI mapping of controls and evidence across SOC 2 and other frameworks

Grade C · Augment

Problem. Service organisations hold several frameworks at once, and mapping each to controls and collecting evidence again for each is repetitive and a place where scope gaps arise.

Approach

- EY speakers say AI can compare an organisation's control data with frameworks, laws and regulations.
- Vanta says it supports 35+ frameworks with cross-mapping and has a Customer Commitments feature that maps customer obligations to controls (vendor-published).
- A-LIGN's platform maps existing evidence to extra frameworks and deduplicates requests, saving about 15 hours per framework on average (vendor-published).
- Management decides the scope and controls to adopt; the auditor for each framework decides what evidence it accepts.

Evidence: Vanta, A-LIGN, EY speakers · assurance-soc-attestation-04

Continuous control monitoring and AI-collected evidence on compliance platforms

Grade B · Automate

Problem. Preparing for SOC 1 or SOC 2 meant collecting screenshots and spreadsheets from many systems each period, controls drift between annual cycles, and the work falls on small security teams.

Approach

- Platforms such as Vanta and Drata connect to cloud, identity, HR and ticketing systems, run continuous tests and pull evidence.
- AI agents added in 2025 and 2026 collect and validate evidence, draft policies and flag gaps; people decide. Much monitoring is rules-based.
- Vanta cites an IDC finding that customers reduce audit prep time by 82% (vendor-published).
- WorkJam's CISO says weekly compliance effort fell to about 1 hour from 7 or 8 (vendor-published); control owners decide on exceptions.

Evidence: Vanta, Drata, WorkJam, Snyk, EY speakers · assurance-soc-attestation-05

SOC firm's audit platform screens client evidence against audit intent before fieldwork

Grade B · Augment

Problem. Clients submit evidence that fails the control's intent, which causes rework during fieldwork, and evidence is re-requested for each framework.

Approach

- A-LIGN's platform (A-SCEND with EvidenceIQ) evaluates client evidence against audit intent before auditors review it, showing coverage and gaps with explanations.
- It maps existing evidence to additional frameworks and deduplicates requests; customers can switch AI features on or off and auditors remain accountable.
- Customer Teleperformance reports evidence gathering and validation time down about 30-40% and audit preparation effort down about 25% (vendor-published).
- Auditor review and validation precede the final report.

Evidence: A-LIGN, Teleperformance · assurance-soc-attestation-06

Engagement platform and client portal replace spreadsheets and email at Weaver

Grade B · Assist

Problem. Evidence collection and review in attestation and internal audit engagements ran on spreadsheets, email chains and manual trackers, with multiple versions of documents.

Approach

- Weaver, which has its own attestation and internal audit methodologies, adopted Fieldguide as a single engagement workspace and client portal.
- Weaver kept its methodology; its next step is to embed the platform's AI agents, with a phased rollout.
- Weaver reports a 10-12% increase in realization in the first year (vendor-published).
- Reviewers work from the latest version and validate engagement output.

Evidence: Weaver, Fieldguide · assurance-soc-attestation-07

Agent-run SOC engagement: planning, evidence requests, testing and exception drafting

Grade C · Delegate

Problem. SOC examinations repeat the same request, test and document cycle for every control, and firms with a growing SOC practice are capacity-bound.

Approach

- Fieldguide describes four agents for SOC work: planner, auditor (requests, evidence validation, tests), reviewer (exceptions) and orchestrator.
- A live demonstration of an agent-run SOC 2 engagement was scheduled for 13 October 2026; the capability is announced.
- Vendor figures: 55% reduction in engagement hours, 90% time savings on testing, 4x engagement capacity (vendor-published).
- A practitioner reviews drafted exceptions, and the reviewer agent routes judgement calls to a practitioner.

Evidence: Fieldguide · assurance-soc-attestation-08

AI review of draft SOC reports for errors and inconsistencies

Grade B · Augment

Problem. Draft SOC reports are long, and a reviewer can miss a detail buried deep in the document.

Approach

- Linford & Company says it uses AI for reviewing reports, among other uses.
- The aim is a more thorough job, such as finding things on a late page of a long report.
- Linford says the AI helps catch details a human might miss and does not save time (self-reported); no figure is published.
- The post names missing walkthroughs and no partner review of the report as signs of a bargain-basement audit.

Evidence: Linford & Company · assurance-soc-attestation-09

Security questionnaire answers drafted from issued SOC reports and approved answer libraries

Grade C · Augment

Problem. A SOC report is meant to reduce customer questionnaires, but sales deals still trigger long questionnaires asking for the same facts, which security teams answer by hand.

Approach

- EY conference speakers list drafting tailored questionnaire responses that learn from issued SOC reports and approved answers.
- Vanta's AI suggests answers from a tagged knowledge base of policies, evidence and previous responses, and flags gaps.
- Vanta reports 95% acceptance of AI-suggested answers; its comparison page says up to 81% faster (vendor-published).
- The user reviews each answer set, and the security owner approves answers before they go to the customer.

Evidence: Vanta, EY speakers · assurance-soc-attestation-10

Trust centre with AI chatbot: buyers' front end for SOC reports

Grade C · Automate

Problem. Buyers repeatedly ask each vendor for its report, policies and answers by email and NDA, want current proof between annual reports, and trust pages can overstate what is in place.

Approach

- A trust centre (public or gated page of reports, policies and control status) publishes the material from one source.
- Vanta's trust centre includes an AI chatbot answering buyer questions, CRM-based gating and NDA automation.
- Vanta says the Trust Center and chatbot deflect 70-87% of inbound reviews (vendor-published).
- A security owner approves each published claim.

Evidence: Vanta, Whistic, Chiaro · assurance-soc-attestation-11

Flagging templated SOC reports by comparing language across reports (vendor-announced)

Grade C · Assist

Problem. Templated, look-alike reports are hard to spot one engagement at a time; after the Delve allegations (denied by Delve), Whistic told buyers a report is the start of a conversation.

Approach

- Whistic says its AI surfaces overly uniform language, thin operational detail and gaps between policy and questionnaire answers (vendor-announced).
- Peer reviewers may manually compare about five engagements when risk is elevated; using AI for that is an idea, not reported.
- No detection rate or false-positive figure was found.
- A vendor-risk analyst decides on follow-up; higher-risk vendors get a conversation and an operational answer to a specific control question.

Evidence: Whistic, AICPA peer review · assurance-soc-attestation-12

Platform-curated auditor networks and audit hubs that route buyers to audit firms

Grade B · Assist

Problem. Examination timelines slip on evidence requests, access provisioning and coordination between service organisation and auditor, and buyers increasingly reach SOC 2 through tool vendors.

Approach

- Platforms run an auditor portal with scoped access and comments and keep a list of audit-firm partners.
- Vanta's partner page lists 100+ audit firms and 26,000+ audits (vendor-published); Drata says it has never bundled audits.
- A-LIGN's alliances lead says organisations using Vanta cut audit completion time by 50% (vendor-published).
- The CPA firm sets scope, sampling and fee; buyers ask the CPA in writing about referral or revenue arrangements with the platform.

Evidence: Vanta, Drata, A-LIGN, AICPA · assurance-soc-attestation-13

Bundled SOC-as-a-service with a referred CPA firm and fixed fee (contested)

Grade B · Automate

Problem. SOC 2 became a gate for enterprise sales, so startups want a report fast and cheaply, and fast-turnaround offers compete on speed and price.

Approach

- Dozens of tool vendors promise results in weeks or hours, acting as a front door, sometimes through networks of small CPA firms.
- In March 2026 an anonymous whistleblower alleged that Delve generated evidence, test procedures and auditor conclusions before independent review; Delve denies this.
- No regulator or court finding found (as of 2026-10-17); the AICPA says it is looking into anonymous allegations about an unnamed vendor.
- Buyers vet the signing firm's licence and peer review; the licensed CPA firm runs its own tests, writes the conclusions and signs.

Evidence: Delve (allegations denied), AICPA · assurance-soc-attestation-14

Licensed CPA firm and compliance platform sold as one auditor-led service

Grade B · Augment

Problem. Readiness software and the audit are bought separately, so evidence is collected twice and the client manages two relationships.

Approach

- Thoropass combines a compliance platform with a licensed CPA firm, Thoropass Assurance, so the audit runs in the same platform.
- Thoropass says it uses AI to map controls, identify gaps and organise evidence, with the platform enforcing consistency in evidence collection.
- A-LIGN pairs its own audit platform with a PCAOB-registered CPA firm; Thoropass claims 1,000+ customers, with no time or cost measure (vendor-published).
- Licensed auditors perform the examination and sign the report.

Evidence: Thoropass, A-LIGN · assurance-soc-attestation-15

AI-native CPA firm with a published method and complete-population testing (Chiaro)

Grade B · Delegate

Problem. A buyer holding two SOC 2 reports often cannot tell whether one auditor inspected evidence and the other only collected screenshots, because firms do not publish their testing methods.

Approach

- Chiaro, started by a former Deloitte SOC auditor, publishes its control library, test attributes and method as openly licensed machine-readable files.
- The customer's own AI tool collects records via MCP, an AI-to-data connector, and submits them; the firm examines the evidence and signs.
- The default is complete-population testing, with sampling a disclosed fallback, because AI makes checking every item cheap at small-company scale (self-reported).
- Readiness software and the audit are sold as one product; the customer decides every control choice.

Evidence: Chiaro (Y Assurance PLLC) · assurance-soc-attestation-16

Sustainability assurance

ISSA 5000, CSRD limited assurance, GHG engagements; almost no AI evidence from assurance providers. · 13 use cases · evidence thin (0 of 13 A/B)

AI mapping of sustainability disclosures to reporting standards, with gap list

Grade C · Augment

Problem. Sustainability information is spread across many report sections and documents, and before testing the team must find each disclosure, map it to requirements and spot missing baselines, targets or methods.

Approach

- Language-model tools locate relevant passages, classify them against ESRS-type categories and produce a preliminary gap list, not a compliance conclusion.
- Analyst commentary says Deloitte has an AI-powered Omnia ESG tool automating disclosure roadmaps and tracking regulatory requirements.
- No time, accuracy or coverage result is published; the analyst describes what the tool does, not how well (vendor-published).
- The practitioner confirms each AI-identified disclosure is complete and supported by evidence; the engagement leader approves the tool for the engagement.

Evidence: Deloitte (per Verdantix), SSKG Hub prototype · assurance-sustainability-assurance-01

AI text screening of draft sustainability reports for greenwashing-type claims

Grade C · Augment

Problem. Spotting vague, promotional or unsupported claims across a long sustainability report is slow, and assurance must consider whether information is balanced and not misleading.

Approach

- Text-analysis models score tone, specificity and whether a claim is backed elsewhere in the report; flags tell the practitioner where to look.
- Analyst commentary says KPMG uses NLP and machine learning to detect potential greenwashing in clients' reports; no result is given.
- A university prototype on 150 DAX-company ESG reports found more specific wording went with stronger internal claim support (Spearman rho 0.310; independent).
- The practitioner investigates each flag and decides whether more procedures are needed; the prototype aims to prioritise review, not classify greenwashing.

Evidence: KPMG (per Verdantix), university prototype · assurance-sustainability-assurance-02

Idea: analytics over multi-year sustainability data and narrative-versus-number checks

Grade D · Augment

Problem. Idea only, not a deployment: unexplained changes, unit inconsistencies, restatements and narrative contradicting numbers are easy to miss when multi-year data arrives in many formats.

Approach

- Analytics or AI would scan reported data and narrative for unusual swings, missing values, inconsistent units and text contradicting the numbers.
- For example, a sharp emissions fall might reflect a boundary or method change; no result is published.
- The practitioner investigates each flag and decides whether it needs recalculation, source inspection, inquiry or control testing.

Evidence: No named deployment · assurance-sustainability-assurance-03

Idea: cross-check emissions and supplier claims against external data

Grade D · Augment

Problem. Idea only, not a deployment: much sustainability evidence comes from the entity or suppliers the practitioner cannot reach, leaving no independent source to compare reported claims against.

Approach

- AI tools would match reported figures with outside data: satellite images for site emissions, emission-factor databases, peer outliers, media and regulatory records.
- Results would target procedures and corroborate evidence, not replace direct evidence.
- The practitioner decides whether an external signal calls for further procedures at the entity or supplier; no result is published.

Evidence: No named deployment · assurance-sustainability-assurance-04

Idea: source-linked drafting of evidence matrices and workpaper summaries

Grade D · Augment

Problem. Idea only, not a deployment: sustainability engagements generate long reports, policies, datasets and correspondence that must be summarised and documented in the assurance file.

Approach

- Generative AI would summarise long documents, prepare a preliminary evidence matrix and draft descriptions of procedures.
- Every output would be linked to its source, logged and reviewed by the team.
- A reviewer corrects and source-checks all AI drafts before they enter the file; no result is published.

Evidence: No named deployment · assurance-sustainability-assurance-05

Idea: AI-supported risk assessment and planning priorities for sustainability engagements

Grade D · Assist

Problem. Idea only, not a deployment: ISSA 5000 asks for risk assessment across many topics, sites and value-chain components, and teams have limited time to allocate testing.

Approach

- AI would highlight high-risk areas, unusual metrics, missing evidence and inconsistent disclosures so the team can prioritise procedures and allocate resources.
- The risk assessment itself remains the practitioner's; each AI signal is evaluated for relevance, materiality and need for more procedures.

Evidence: No named deployment · assurance-sustainability-assurance-06

Idea: continuous evaluation of digital sustainability data by automated tools

Grade D · Automate

Problem. Idea only, not a deployment: annual engagements review data months after the fact, so point-in-time sampling can miss problems in continuous meter or sensor feeds.

Approach

- Automated tools would run continuously over digital data, evaluate its relevance and reliability, and raise exceptions for the practitioner.
- ISSA 5000 gives this as an example of how the practitioner may use automated tools.
- The literature frames it as a move from retrospective document review to continuous, data-driven assurance.
- The practitioner evaluates the relevance and reliability of the information and the tool's operation.

Evidence: No named deployment · assurance-sustainability-assurance-07

Reporting-team AI that checks disclosures against standards and drafts narrative

Grade C · Augment

Problem. Reporting teams compare long standards with existing content line by line, gaps that surface late can force new data under deadline, and they want drafts quickly but fear unsupported statements.

Approach

- Workiva's Sustainability Disclosure Agent marks each ESRS or ISSB requirement present, partial or missing in a scorecard and drafts a first version.
- Workiva presents it as supporting expert judgement; the team keeps sign-off.
- Preparers also use AI to draft narrative; vendors say it is valuable only if tied to verified data and human review.
- No time, accuracy or usage figure is published; the team reviews the scorecard and draft before they enter the report.

Evidence: Workiva · assurance-sustainability-assurance-08

Automated supplier data ingestion and spend-based Scope 3 classification with calculation lineage

Grade C · Automate

Problem. Scope 3 data arrives from hundreds of suppliers as PDFs, spreadsheets and inconsistent questionnaires, reconciling it takes weeks each cycle, and numbers without a traceable source are hard to verify.

Approach

- OCR extracts data from bills and supplier documents, agents standardise units and remove duplicates, and models map procurement lines to emissions categories.
- Each output is meant to trace to its source, emission factor and approval history, which assurance providers need.
- Vendor reports 90% less OCR data entry time and 65-80% less time to actionable data (vendor-published).
- Vendor says Smiths Group completed its SB 261 report in two days (vendor-published); humans review outputs before use in disclosures.

Evidence: Watershed, Smiths Group, Harris Farm Markets · assurance-sustainability-assurance-09

AI gap-filling and estimates for missing or value-chain sustainability data (preparer side)

Grade C · Augment

Problem. Value-chain data is often unavailable or unreliable; reporting rules allow estimates, and the assurance provider must evaluate the data, methods and assumptions behind them.

Approach

- Tools flag data gaps and propose gap-fill methods such as proxy data, sector averages and estimation models, recording the assumption and rationale.
- The vendor argues this record reduces friction with auditors; no result is published (vendor-published).
- The practitioner considers assumptions, method changes and comparability, and whether assumptions fit external evidence and are free of management bias.

Evidence: Watershed (vendor), ACCA · assurance-sustainability-assurance-10

PwC Germany AI tool for clients' EU sustainability data and reports (CSRD)

Grade C · Automate

Problem. CSRD reporters must gather thousands of data points across the value chain and calculate many KPIs, and manual handling is slow and error-prone.

Approach

- PwC Germany's CSRD.AI Manager, built with SAP, extracts, organises and analyses data, calculates KPIs and speeds up report generation for clients.
- It uses the firm's CSRD content and customisable data models, on SAP AI Core, HANA Cloud and Datasphere.
- A PwC product owner says it removed a heavy resource drain for clients; no figure is given (self-reported).
- The firm evaluates threats and safeguards before accepting a non-assurance service for an assurance client.

Evidence: PwC Germany, SAP · assurance-sustainability-assurance-11

AI-assisted double materiality assessment by preparers, and assurance over that process

Grade C · Augment

Problem. The materiality assessment decides what is reported; it is large, judgement-heavy and a frequent source of assurance findings, and the practitioner must consider the entity's process to identify reportable information.

Approach

- Survey respondents name AI in materiality assessments a primary use case and an investment priority for the next three years (independent).
- It was less popular than in the previous year's study, with some sign practitioners think the technology is not yet mature.
- No time or quality figure is given.
- The assurance provider must still understand and test the entity's process, whatever tool supports it.

Evidence: Thomson Reuters Institute survey · assurance-sustainability-assurance-12

Idea: assurance procedures over a client's AI-assisted sustainability reporting pipeline

Grade D · Assist

Problem. Idea only, not a deployment: as preparers draft and calculate with AI, the practitioner must obtain evidence about information from systems the team cannot easily inspect.

Approach

- Teams would extend their view of the client's information system to AI-assisted steps: tool, data, prompts, validation and route into the report.
- A vendor suggests asking for traceability and a dry run of AI-generated reports with the auditor.
- A sector site says assurance providers are developing methods for assessing AI-generated disclosures; no method is described.
- The practitioner evaluates the reliability of information used as evidence, including whether its integrity was maintained through processing.

Evidence: No named deployment · assurance-sustainability-assurance-13

Assurance over AI

Auditing an entity's AI used in ICFR, and standalone assurance over AI systems; named certifications, no measured outcome. · 24 use cases · evidence thin (6 of 24 A/B)

Idea: inventory the entity's AI and scope it to financial-reporting controls

Grade D · Assist

Problem. Idea only, not a deployment: entities adopt AI through embedded features, vendor tools and unsanctioned 'shadow AI', so auditors cannot tell which AI touches financial reporting.

Approach

- A living inventory gives each use case an owner and criticality, then maps it to financial-reporting processes, assertions and key controls.
- BDO starts the IT audit with the entity's AI use cases, related systems and service providers, and the governance around them.
- The AICPA practice aid asks auditors to establish early how far the entity relies on AI and what new risks arise.
- Management signs off ownership and criticality per use case; the engagement partner judges whether AI use affects financial reporting.

Evidence: COSO, BDO, AICPA, EY · assurance-assurance-over-ai-01

Classify AI-enabled controls by reliance to set evidence standards and IT scope

Grade C · Assist

Problem. Some AI-assisted controls are re-performed by a person, others accepted on AI output alone, yet both are called AI controls; treating them alike makes evidence demands too heavy or light.

Approach

- COSO defines reliance as management depending on AI-generated outputs as evidence for a control's design or operating effectiveness.
- Where reliance exists, COSO expects full financial-reporting control evidence, including prompt, configuration and model version; non-reliance may need less.
- BDO applies the test to IT general controls scoping, saying they matter significantly more under reliance.
- A vendor sorts controls into three classes: AI decides and executes, AI flags and a human decides, AI supplements a key control.

Evidence: COSO, BDO, a finance-technology vendor · assurance-assurance-over-ai-02

Extend IT controls to AI and choose how to test AI-operated controls

Grade C · Assist

Problem. IT general controls testing was built around applications and databases; AI adds models, data pipelines and agents that can act on ERP systems.

Approach

- BDO keeps the four IT control domains and extends them to in-scope AI components, scoped by degree of reliance.
- As reported, the AICPA aid says auditors may test AI outputs substantively or test controls, but cannot rely on control tests alone.
- KPMG says SOX programmes still mostly test around the AI and forecasts the first wave of AI-related material weaknesses in 2027 (self-reported).
- An IT audit specialist scopes components per use case; the human reviewer must have the knowledge to judge AI reliability.

Evidence: BDO, AICPA, KPMG, COSO · assurance-assurance-over-ai-03

Evidence trail for each AI-touched control: prompts, model versions, agent action records

Grade C · Assist

Problem. A control relying on probabilistic GenAI output cannot be evidenced by the output alone, and agents that trigger side effects need trustworthy records to reconstruct behaviour.

Approach

- Retain prompts, system prompts and configurations with version history, plus retained inputs, outputs, model versions and human-review records.
- For significant-impact GenAI processes, COSO says an AI 'bill of materials' should hold logs of prompts, outputs, model version, parameters and plugins.
- The 'Auditable Agents' paper proposes an Auditability Card; its tamper-evident records added little runtime cost, 8.3 ms, in feasibility tests (independent).
- A named reviewer documents what the AI concluded and why they agreed or disagreed; responsibility attribution ties agent actions to accountable people.

Evidence: COSO, Baker Tilly, Auditable Agents authors · assurance-assurance-over-ai-04

Idea: use management's AI monitoring metrics and remediation logs as control evidence

Grade D · Augment

Problem. Idea only, not a deployment: point-in-time testing misses gradual model drift and vendor-driven changes, and Deloitte says 'set-and-forget' does not work for GenAI in financial reporting.

Approach

- COSO expects continuous monitoring of accuracy, coverage, latency and exception volumes, plus a remediation log of issue, root cause and follow-up.
- Deloitte lists transaction volume, size and override percentages as drift indicators with root-cause review of prompts, retrieval and vendor changes.
- COSO says its illustrative metrics serve both operational monitoring and audit evidence; no result is published.
- Control owners review drift alerts and root causes and sign off tolerance changes; material deficiencies escalate to governance bodies.

Evidence: COSO, Deloitte · assurance-assurance-over-ai-05

Idea: re-perform AI-operated control outputs with independent test populations or challenger models

Grade D · Augment

Problem. Idea only, not a deployment: an auditor cannot inspect a probabilistic model's reasoning, and less insight into how an output was produced makes comfort harder.

Approach

- COSO lists methods the assurance community now discusses: human review from full re-performance to risk-based sampling, and performance testing on test populations.
- It also lists multi-model validation comparing outputs across independent AI models or deterministic benchmark algorithms, drift analytics and third-party validation.
- KPMG's summary of the COSO roadmap lists these as evolving approaches; no result is published.
- Human reviewers handle disagreements between the model and the challenger.

Evidence: COSO, KPMG · assurance-assurance-over-ai-06

Idea: evidence over vendor-supplied AI via service-auditor reports and AI-specific representations

Grade D · Assist

Problem. Idea only, not a deployment: with a service organisation's AI, user auditors' procedures may be limited, and vendor GenAI limits visibility into training data and model updates.

Approach

- The AICPA aid, as reported, says a service auditor's report often becomes important audit evidence.
- If it is not sufficient, extra procedures may include AI-related management representations, such as identifying the AI the entity uses.
- It also asks whether the entity has a process to identify AI used by vendors and evaluate the effect on financial reporting.
- The user auditor evaluates whether the service-auditor report covers the relevant AI controls.

Evidence: No named deployment · assurance-assurance-over-ai-07

Idea: extend fraud-risk assessment to AI manipulation and AI-generated evidence

Grade D · Assist

Problem. Idea only, not a deployment: COSO says AI creates new routes for fraud, such as deepfakes, synthetic records, model manipulation through crafted prompts, and agents with authorisation risks.

Approach

- COSO asks fraud risk assessment to identify how these threats could be used and whether existing fraud controls would catch them.
- The AICPA aid, as reported, adds examples: altering training data or the algorithm to create bias, and generating fictitious supporting documents.
- The engagement team's fraud-risk discussion would cover AI-enabled schemes; no result is published.

Evidence: No named deployment · assurance-assurance-over-ai-08

Audit committee oversight of AI in financial reporting via auditor dialogue

Grade C · Assist

Problem. Audit committees are taking on AI oversight faster than they feel able to carry it: 75% named AI governance a top-three priority, only 56% felt confident overseeing it.

Approach

- KPMG's Board Leadership Center tells audit committees to ask the auditor how the audit plan assesses risks from the company's AI use.
- It also suggests tasking management to reassess whether disclosure controls support statements about the company's AI use, risks and governance.
- Committees with primary AI governance responsibility rose from 20% to 29%; 82% call their AI oversight emerging or limited (independent).
- About two-thirds of audit partners say their committee proactively raised AI use in operations or financial reporting (independent).

Evidence: Deloitte and CAQ survey, KPMG · assurance-assurance-over-ai-09

Internal audit assurance over AI governance using IIA and COSO frameworks

Grade C · Assist

Problem. Internal audit is not ready: in a vendor survey, 63% of organisations lacked formal AI risk appetites or governance frameworks and only 28% of respondents were confident auditing AI risks.

Approach

- The IIA framework (updated 13 Sep 2024) gives internal auditors a principles-based way to assess AI governance, risks and controls.
- COSO's February 2026 publication groups GenAI use into eight capability types with minimum control expectations, illustrative metrics and starter templates.
- EY recommends chief audit executives include AI systems with financial-reporting impact in the audit universe.
- The chief audit executive decides whether internal audit acts as adviser or assurance provider; a named human reviews AI-assisted audit work.

Evidence: IIA, COSO, EY, Optro/Panterra survey · assurance-assurance-over-ai-10

Idea: continuous, AI-assisted assurance over AI systems instead of an annual cycle

Grade D · Augment

Problem. Idea only, not a deployment: annual audit plans cannot keep pace with continuously changing AI systems, which drift, and agents may change behaviour to work around anomalies.

Approach

- Move from point-in-time assessment to continuous monitoring with real-time dashboards and dynamic audit planning.
- EY conference speakers said AI can monitor AI system performance and detect problems such as drift early.
- They advised starting with simple automations in controlled environments before multi-agent set-ups under close oversight.
- AIUC-1's quarterly agent re-testing is one live example of the cadence; human oversight of AI-generated outputs remains.

Evidence: No named deployment · assurance-assurance-over-ai-11

Scope an AI assessment as governance, conformity or performance, and say which

Grade C · Assist

Problem. Terms like assurance, audit and certification are at times used interchangeably for different AI assessments, and misusing 'assurance' can be a problem in some jurisdictions.

Approach

- The ACCA and EY paper describes three types: governance assessments, conformity assessments against laws and standards, and performance assessments against predefined metrics.
- EY recommends each assessment state what is assessed, use a clear methodology and suitable criteria, and be done by a qualified provider.
- AICPA and Caseware voices say scope and criteria are negotiated because no comprehensive framework exists.
- The practitioner scopes, selects criteria and gives the opinion; no result is published.

Evidence: ACCA, EY, AICPA, Caseware · assurance-assurance-over-ai-12

AI governance gap assessments against ISO/IEC 42001 and the NIST AI framework

Grade C · Assist

Problem. Clients adopting AI need to know where their governance falls short of a benchmark standard before an auditor, certifier or customer asks.

Approach

- Deloitte UK describes a five-pillar framework aligned to ISO/IEC 42001, with 'no-regret' steps such as an AI governance committee and inventory.
- Its AI Assurance page offers third-party challenge over AI risk, governance and control maturity, including certification readiness.
- A Deloitte Singapore job posting (25 Jun 2026) shows consultants maintaining client AI risk registers and supporting gap analyses and remediation roadmaps.
- KPMG Nederland offers AI governance support, gap analyses and readiness scans; senior consultants review risk and quality reports.

Evidence: Deloitte UK, Deloitte Singapore, KPMG Nederland · assurance-assurance-over-ai-13

Reasonable-assurance opinion on an organisation's AI governance and controls (SOC 2+)

Grade C · Assist

Problem. Customers, boards and procurement teams cannot see whether a supplier's AI is governed in practice rather than only on paper, and no prescriptive regulatory framework mandates external AI assurance.

Approach

- KPMG UK gives an opinion on AI governance and controls under ISAE (UK) 3000, using its Trusted AI framework and SOC principles.
- It tests whether controls are defined, suitably designed and operating effectively, with a report the client can share with customers.
- KPMG's January 2026 paper calls it 'SOC 2+' reasonable assurance; CSA published CPA guidelines for SOC 2+ attestation in March 2026.
- KPMG UK says, from its own experience, AI assurance is increasingly requested by procurement teams (self-reported); no figure is given.

Evidence: KPMG UK, CSA, Baker Tilly · assurance-assurance-over-ai-14

ISO/IEC 42001 certification of an AI management system by an accredited body

Grade B · Assist

Problem. Customers, banks and defence buyers want evidence that an AI developer's governance works but cannot inspect its models; ISO/IEC 42001 certifies a management system, not individual AI systems.

Approach

- A certification body audits the AI management system in two stages, then runs annual surveillance audits over a three-year cycle.
- Schellman became the first ANAB-accredited body after eight months; Anthropic, Sierra and Zendesk posted certificates in the CSA STAR Registry.
- Schellman's CEO said in October 2024 it had signed 26 client contracts for certification (self-reported).
- BSI research cited in its release says 26% of organisations report taking steps to align with the standard (vendor-published).

Evidence: BSI, Schellman, Umony, CSA · assurance-assurance-over-ai-15

Accredit and oversee AI management system certifiers against ISO/IEC 42006

Grade B · Assist

Problem. A certificate is only as trustworthy as the body that issues it, and the CSA note assesses that AI assurance suppliers are growing faster than accreditation can vet entrants.

Approach

- ISO/IEC 42006 adds requirements, beyond ISO/IEC 17021-1, for bodies that certify AI management systems, and for the accreditation bodies assessing them.
- A compliance vendor's summary lists collective audit-team competence across AI and law, and a calculated minimum audit time.
- BSI announced ANAB accreditation on 10 Mar 2026, adding to UKAS and RvA, calling itself the first with all three (self-reported).
- Accreditation bodies assess certifiers' competence, impartiality and consistency, including by witnessing audits the certifier performs.

Evidence: BSI, Schellman, CSA, UK DSIT · assurance-assurance-over-ai-16

Audit firms certify their own AI management systems before selling AI assurance

Grade B · Assist

Problem. A firm selling AI governance advice or assurance must show it holds itself to the same standard, and clients ask who has been through the process.

Approach

- Firms obtain ISO/IEC 42001 certification for their own AI systems from an accredited body and publicise it.
- KPMG LLP (US) announced certification on 18 Nov 2025 from Schellman Compliance; KPMG International followed in December 2025.
- SGS issued PwC Taiwan its certificate (15 Jun 2026); two EY Italian entities hold certificates, issued by Certiquality and ACM Cert.
- Firms present the certificate as proof of experience and a basis to help clients with their own certification (self-reported).

Evidence: KPMG, PwC Taiwan, EY Italy, Schellman · assurance-assurance-over-ai-17

Audit firms build AI assurance service lines and ISO/IEC 42001 offers

Grade C · Assist

Problem. Realtid, summarising the Financial Times, reports AI assurance has no clear standards, quality ranges from superficial advice to technical reviews of single legal requirements, and many providers are developers themselves.

Approach

- June 2025 press reports said Deloitte, EY, PwC and KPMG were positioning to offer AI assurance, as they had for ESG assurance.
- EY's 7 Apr 2026 release describes AI assurance services across diagnostics, governance and controls; EY CertifyPoint certifies AI management systems.
- PwC Canada launched ISO/IEC 42001 certification on 16 Feb 2026, claiming to be the first Big Four offering accreditation services (trade press).
- By September 2026 KPMG UK marketed an AI governance assurance product; partner sign-off on opinions is not described in the sources.

Evidence: Deloitte, EY, PwC, KPMG · assurance-assurance-over-ai-18

Certify AI agents through adversarial testing, an authorised auditor and insurance (AIUC-1)

Grade B · Augment

Problem. Enterprise security and procurement teams run bespoke risk assessments of AI agents, liability is uncertain, and agent behaviour changes after a point-in-time audit.

Approach

- AIUC-1 is a security, safety and reliability standard for AI agents; AIUC runs adversarial evaluations and issues the certificate.
- Schellman, first authorised auditor (3 Feb 2026), collects evidence; agents are re-tested at least quarterly, with a full annual audit.
- KPMG LLP's aIQ Capture platform was certified on 27 Aug 2026 after more than 900 technical tests (vendor-published).
- The first AIUC-1-backed insurance policy (ElevenLabs) was reported at $50 million of cover (vendor-published); UiPath says testing produced new guardrails.

Evidence: AIUC, Schellman, KPMG, ElevenLabs, UiPath · assurance-assurance-over-ai-19

System-level technical assurance of a specific AI system's performance, robustness and bias

Grade C · Assist

Problem. Governance certification does not tell a buyer whether an individual AI system performs as claimed, and much UK AI assurance is supplied by AI developers themselves, raising independence questions.

Approach

- Engagements borrow the practitioner, responsible-party and intended-user model of financial audit: select criteria, gather evidence by inspection, inquiry, reperformance and analytical testing.
- A Babl AI session used New York City bias audits, LLM testing and EU AI Act risk-management engagements as worked examples.
- Deloitte UK offers third-party challenge over AI technical build and performance; KPMG Nederland added AI Assurance in September 2025, including robustness tests.
- Independent studies: UK AI assurance market about GBP 1.01 billion GVA (2024); AI audit tools often fall short of supporting accountability.

Evidence: Babl AI, Deloitte UK, KPMG Nederland, BSI · assurance-assurance-over-ai-20

Mandated independent bias audits of automated hiring tools in New York City

Grade B · Assist

Problem. Employers using automated employment decision tools must obtain annual independent bias audits, but the law leaves 'auditor' and 'tool' loosely defined.

Approach

- Since July 2023, New York City employers using automated employment decision tools must undergo annual bias audits by an independent auditor.
- An interview study of 16 experts and practitioners found auditors, tool vendors and employers defined practice themselves, producing four distinct auditor roles.
- The researchers concluded the law has not established an effective audit regime (independent).
- An independent auditor signs the bias audit.

Evidence: NYC Local Law 144, Groves interview study · assurance-assurance-over-ai-21

EU AI Act conformity assessment and compliance assurance for high-risk AI

Grade C · Assist

Problem. Providers of high-risk AI systems must show conformity with the Act, but harmonised standards and conformity-assessment capacity are not ready.

Approach

- Under Article 43, some high-risk providers may choose internal control or assessment with a notified body; others follow the internal-control procedure.
- The first harmonised AI standard, prEN 18286 on quality management, entered public enquiry on 30 Oct 2025.
- The AI Omnibus moved Annex III obligations to 2 Dec 2027 and Annex I obligations to 2 Aug 2028.
- Deloitte UK offers third-party challenge over Act compliance, including conformity assessment; the provider or notified body signs off conformity.

Evidence: European Commission, Deloitte UK, KPMG UK · assurance-assurance-over-ai-22

Buyers verify AI assurance evidence through certificate registers and trust-mark registries

Grade C · Assist

Problem. Procurement teams receive certificates and reports whose meaning depends on who issued them and against what criteria, and without AI-specific criteria two SOC 2 reports can cover different control sets.

Approach

- A five-minute register check is recommended for ISO 42001 certificates: who accredited the certifier, and is the scope right.
- KPMG UK says procurement and supplier-risk teams increasingly request and assess AI assurance; techUK says investors and insurers do too.
- CSA STAR for AI Level 1 is a self-assessment; Level 2 (November 2025) adds an accredited third-party ISO/IEC 42001 certificate.
- A procurement or risk reviewer confirms the scope covers the AI system being bought.

Evidence: CSA, KPMG UK, techUK, Coalfire · assurance-assurance-over-ai-23

Professionalise AI assurers: credentials, skills frameworks, ethics code, information-access rules

Grade B · Assist

Problem. UK government says the quality of AI assurance certifications is hard to judge, none is issued by a UKAS-accredited organisation, and assurers often struggle to obtain the information they need.

Approach

- UK government's September 2025 roadmap set four actions: a professionalisation consortium, skills framework, information-access map and innovation fund.
- At one year techUK says the BCS-chaired consortium has three workstreams under way: ethics code, skills framework, information-access map (self-reported).
- ISACA offers an Advanced in AI Audit (AAIA) credential for CISA holders or holders of another qualifying designation.
- Exam and experience requirements apply to the credential; DSIT judged an immediate regulated industry body and professional standard premature.

Evidence: UK DSIT, techUK, ISACA, ICAEW · assurance-assurance-over-ai-24

Tax

Tax compliance, provision and Pillar Two, indirect tax, transfer pricing, controversy, research and advisory, and tax data; firms and in-house tax departments.

Focus area	What it covers	Evidence
Individual and small-business compliance	1040, 1041, 1065 and 1120-S preparation by CPA firms, EAs and retail preparers: organizers, extraction, agent-prepared returns, review, consent, pricing.	**moderate** 10 of 25 A/B
Corporate compliance	Corporate federal and state returns, international forms, R&D credit and Section G, calendar; in house and at large firms.	**thin** 3 of 24 A/B
Tax provision and Pillar Two	ASC 740 and IAS 12 provision, ASU 2023-09 disclosures, GloBE calculations and the GIR XML pipeline.	**thin** 0 of 16 A/B
Indirect tax	VAT, GST and sales and use tax: determination, product mapping, certificates, nexus, returns, e-invoicing and CTC, agentic commerce.	**thin** 4 of 22 A/B
Transfer pricing	Policy, agreements, benchmarking, local and master files, operational TP, audit defence, APAs; A/B entries are rules-based automation.	**thin** 3 of 22 A/B
Controversy and tax authorities	Notices, exams, Appeals and litigation from the taxpayer side, plus tax authorities' AI; nearly all A/B entries are authority-side.	**moderate** 10 of 25 A/B
Research and advisory	Research, memos, written advice, planning and M&A tax diligence; firm and in-house buyers.	**moderate** 11 of 25 A/B
Tax data and technology	In-house tax data layer, automation and its sustainment, real-time reporting interfaces, MCP access, the tax technology team.	**moderate** 8 of 24 A/B

Individual and small-business compliance

1040, 1041, 1065 and 1120-S preparation by CPA firms, EAs and retail preparers: organizers, extraction, agent-prepared returns, review, consent, pricing. · 25 use cases · evidence moderate (10 of 25 A/B)

AI-prefilled organizers and automatic chasing of missing client documents

Grade C · Augment

Problem. Collecting client information and documents means repeated emails and late files, and one missing brokerage statement can hold up a whole return.

Approach

- Canopy offers AI-prefilled questionnaires that clients confirm or change, plus AI file classification; Basis and ApariPro describe agents that chase clients.
- Canopy says firms can save as much as 20 minutes per client (vendor-published).
- Staff review request lists and open items; the preparer still conducts the due-diligence interview and signs Form 8867.

Evidence: Canopy, Basis, ApariPro · tax-compliance-individual-business-01

Reading tax documents and K-1 footnotes with confidence flags and exception review

Grade B · Automate

Problem. K-1 packages and multi-tier partnerships defeat template scanning and manual keying, and an extraction error can flow into a return without any flag.

Approach

- CCH Axcess Scan (Wolters Kluwer) extracts figures and surfaces only exceptions; Wolters Kluwer says K-1 extraction averages 97.5% accuracy (vendor-published).
- PwC agents rate each K-1 footnote item with a confidence level and flag it; one reviewer now replaces three people (self-reported).
- Reviewers override low-confidence mappings with a recorded reason and compare extracted figures to source documents.

Evidence: PwC, Wolters Kluwer, Intuit ProConnect · tax-compliance-individual-business-02

Retail tax offices use AI to cut data entry for advice

Grade B · Automate

Problem. Preparers in assisted-tax offices spend much of an appointment collecting and entering information, leaving less time for advice.

Approach

- H&R Block management said it is automating mechanical tax preparation work, from manual data entry to the initial review of prior-year returns.
- The advice-focused model runs in pilot offices; H&R Block reported higher client satisfaction, with no figures given (self-reported).
- Tax pros remain responsible for the returns and the client guidance.

Evidence: H&R Block · tax-compliance-individual-business-03

Agent drafts a simple personal tax return for CPA review

Grade B · Augment

Problem. Preparing even simple personal returns means sorting documents, keying data and building the return by hand, which crowds out higher-value work in a short season.

Approach

- Thomson Reuters' Ready to Review uses agents to extract data from documents and prior returns and draft returns linked to sources.
- An early-adopter partner at CLH CPAs and Consultants said it saves about an hour per simple return (vendor-published).
- Professionals review the draft, diagnostics and source links before delivery; the taxpayer reviews before signing the e-file authorisation.

Evidence: Thomson Reuters, CLH CPAs and Consultants · tax-compliance-individual-business-04

Agent prepares complex personal returns end to end for CPA sign-off

Grade A · Delegate

Problem. Complex returns with many K-1s, brokerage statements and multiple states take days of preparer and reviewer time, and firms are short of staff in busy season.

Approach

- Black Ore, Basis, Accrual and OpenAI describe agents that extract data, apply tax logic, build workpapers and feed the firm's tax software.
- OpenAI says Tax AI processed 7,000 returns in a Crete pilot and saves about a third of preparation time (vendor-published).
- Boulay's partner says returns with 60-70+ K-1s fell from over 100 hours to about 15-20 hours (vendor-published).
- A CPA reviews and signs off, ties workpapers to source documents and answers questions the system cannot resolve.

Evidence: Black Ore, Basis, Accrual, OpenAI, Crete · tax-compliance-individual-business-05

Agent prepares partnership, S corporation and trust returns through to K-1s

Grade B · Delegate

Problem. Partnership and trust returns need trial-balance import, allocations, depreciation and basis tracking, and K-1 tie-out, much of it built in spreadsheets, so review burden multiplies.

Approach

- Accrual describes preparing partnership and trust returns through to K-1s, with Armanino named as customer; Basis demonstrated an agent completing a 1065.
- Armanino statistics on Accrual's page show an estimated 50% reduction in federal preparation and review effort (vendor-published).
- Practitioners review drafts and open items, approve agent changes and sign the return.

Evidence: Accrual, Armanino, Basis · tax-compliance-individual-business-06

Trial balance to tax workpapers for pass-through business returns

Grade C · Augment

Problem. Business returns start with mapping the client's trial balance to return lines and building book-to-tax and fixed-asset workpapers by hand.

Approach

- Basis agents map client accounts to return lines, flag unmapped accounts and draft book-to-tax and fixed-asset workpapers with figures cited to source.
- A Whitcomb & Sheridan partner says a 2-3 hour task takes about 30 minutes (vendor-published); the quote does not name this step.
- Staff review mapping exceptions and workpaper drafts.

Evidence: Basis, Whitcomb & Sheridan · tax-compliance-individual-business-07

Agent works inside the firm's own tax software and documents each entry

Grade C · Delegate

Problem. Pre-preparation tools push data into the tax engine, so the firm still does the final steps by hand.

Approach

- TaxGPT's agent signs in to the firm's tax software, enters data, works through diagnostics and documents every entry back to its source.
- TaxGPT claims a 50% cut in first-pass preparation time on its product page (vendor-published).
- The firm's team reviews and signs off, and the firm's software stays the system of record.

Evidence: TaxGPT · tax-compliance-individual-business-08

General-purpose agents run practitioner-taught routines and build return workpapers

Grade C · Delegate

Problem. Multi-source follow-up on a return, such as call notes, open issues, binders and signature requests, is done by hand across systems.

Approach

- Accrual's Arc, unveiled September 2026, drafts a plan, asks approval, then updates workpapers with an audit trail; no outcome figures are published.
- A practitioner, Sam Leon, uses Claude Cowork to prepare returns; the episode title claims 5x faster (self-reported).
- The practitioner approves the plan and each proposed change.

Evidence: Accrual, Sam Leon (practitioner) · tax-compliance-individual-business-09

Use a deterministic engine to calculate returns; language model for intake

Grade D · Augment

Problem. This is an idea, not a deployment: unaided language models calculate returns unreliably, so calculation errors, wrong tax tables and eligibility mistakes are costly and hard to audit.

Approach

- Researchers recommend pairing the model with a deterministic calculation engine or symbolic solver, with the model handling intake, explanation and orchestration.
- In a benchmark of 51 simplified returns, the best of four models computed 32.35% correctly under the strict test (vendor-published).
- The preparer reviews the engine-calculated return and any model-supplied inputs.

Evidence: No named deployment · tax-compliance-individual-business-10

Grounded assistant for tax preparers, with every cited authority checked

Grade B · Assist

Problem. Tax pros must keep up with code changes and answer unusual client questions, and general models can invent authorities, as a 2026 Tax Court case about hallucinated citations showed.

Approach

- H&R Block and OpenAI said in April 2025 they were building an assistant grounded in Tax Institute data; management later reported adoption.
- No usage counts or accuracy figures were published (self-reported).
- The tax pro decides how to answer the client; a reviewer opens and reads each cited authority.

Evidence: H&R Block, OpenAI · tax-compliance-individual-business-11

AI-assisted return review with source tie-out, diagnostics and prior-year comparison

Grade B · Augment

Problem. Reviewers must check figures against source documents and prior years, which takes senior time, and review becomes the bottleneck when preparation gets faster.

Approach

- Intuit ProConnect runs an AI assistant against thousands of diagnostics; Basis, Accrual and Thomson Reuters tie figures to source and flag exceptions.
- TaxGPT launched a return-review agent that surfaces audit-sensitive items; PwC lists tax diagnostics among its deployed agents.
- No error counts are published; one user says the checks give it confidence (vendor-published).
- The reviewer inspects flagged exceptions and decides treatments; the preparer or reviewer signs.

Evidence: Intuit, Basis, Accrual, Thomson Reuters, TaxGPT, PwC · tax-compliance-individual-business-12

Review controls for AI-assisted returns: decision logs, override monitoring, escalation

Grade D · Augment

Problem. This is an idea, not a deployment: as AI raises volume, partners may spend less time per return, and a firm with no record cannot show what the tool suggested.

Approach

- Log every AI suggestion and the preparer's decision (accept, modify, reject) with rationale, and review override rates by preparer monthly.
- Scale sampling and spot checks to volume, and escalate novel or uncertain positions to senior review regardless of the AI's confidence.
- Sign-off must evidence real analysis; regulators such as Australia's TPB and the IRS OPR expect AI steps to be verified and documented.

Evidence: No named deployment · tax-compliance-individual-business-13

Automated look-back review of prior-year returns offered to every new client

Grade B · Automate

Problem. Second Look, a review of a new client's last three years of returns for missed opportunities, was manual, so tax pros rarely offered it to new clients.

Approach

- H&R Block management said it automated Second Look over about 18 months with newer AI, so many more new clients opt in.
- Management said Second Look clients returned at a rate over 600 basis points higher; uncontrolled, not due to automation alone (self-reported).
- Tax pros focus on the returns with the greatest opportunity.

Evidence: H&R Block · tax-compliance-individual-business-14

AI-drafted client messages and return explanations, reviewed before sending

Grade C · Augment

Problem. Clients call to ask where their return stands, preparers write explanatory letters by hand, and firms cannot paste client data into public AI tools.

Approach

- Short status messages are generated when a job changes stage, and practitioners use AI to draft correspondence.
- WCG plans a SOC 2-compliant, zero-data-retention sandbox for client narratives, quotes and tax-plan comparisons from returns; Intuit lists an AI Client Briefing.
- The preparer reads and edits every client communication before it is sent; no outcome figures are published.

Evidence: WCG CPAs & Advisors, Intuit · tax-compliance-individual-business-15

Automating return assembly, delivery and e-signature authorisation

Grade C · Automate

Problem. Assembling the return package, collecting signatures, including the Form 8879 e-file authorisation, and taking payment are manual and error-prone.

Approach

- SafeSend and SurePrep from Thomson Reuters are mostly workflow automation; the vendor claims an AI layer that recognises documents and flags discrepancies.
- Thomson Reuters says firms using SafeSend save about 15 minutes per return (vendor-published).
- The preparer signs the return and the taxpayer reviews it before signing Form 8879.

Evidence: Thomson Reuters · tax-compliance-individual-business-16

UK self assessment and Making Tax Digital preparation with AI document processing

Grade C · Augment

Problem. UK firms chase clients for information, review documents manually and re-key data into tax software for self assessment returns and quarterly Making Tax Digital submissions.

Approach

- ApariPro says it automates client information collection, AI processing of documents such as P60s, return population and submission, integrating with CCH iFirm.
- No figures are published; anonymous testimonials say manual data entry fell (vendor-published).
- The team reviews and approves all information before submission.

Evidence: ApariPro · tax-compliance-individual-business-17

Phased adoption: simple returns first, scope gates, parallel runs on prior-year returns

Grade C · Augment

Problem. Firms adopt AI preparation on vendor claims and cannot say whether time, quality or cycle time improved, and vendors bundle extraction, deduction suggestion and position drafting together.

Approach

- Practitioners advise starting with simpler returns, rerunning last year's returns to compare with what was filed, and recording cycle times first.
- An AICPA case study (an idea) authorises the tool in phases, with gates such as a hallucination rate of 2% or less.
- A reviewer compares the AI's version with the filed return; named partners sign off each phase. No parallel-run result is published.

Evidence: Practitioner advice; AICPA case study · tax-compliance-individual-business-18

Firm AI policy, approved-tool list and vendor due diligence for tax practices

Grade C · Assist

Problem. Staff use AI tools whether or not the firm has sanctioned them, nobody owns AI, and firms cannot show how outputs were verified or what happens to sensitive return data.

Approach

- The IRS Office of Professional Responsibility says firms should have AI policies covering training, data handling and accuracy monitoring, and vet vendors.
- Guidance adds an approved-tool list, an AI lead or committee, and client data restricted to enterprise-approved AI under the written security plan.
- Thomson Reuters reports more than one-third of professionals use AI tools their firm has not sanctioned (vendor-published).
- A principal or AI committee approves tools before client use; the managing partner and counsel sign off vendor contracts.

Evidence: IRS OPR, Thomson Reuters, Wolters Kluwer, AICPA · tax-compliance-individual-business-19

Dedicated AI team, champion network and training that protects the junior pipeline

Grade B · Assist

Problem. Tools change faster than firm processes, regulators make AI competence personal to the preparer, and AI is automating the entry-level tasks juniors learn on.

Approach

- PwC reports a governance committee, an Agent OS controlling agent tools, more than 3,200 AI champions and a training programme (self-reported).
- WCG says its AI Tax Prep Pod launches in November 2026 to design workflows, test tools and document best practice.
- An AICPA framework proposes tool-independent tax-law training and an annual check that staff can handle complex matters without the tool.

Evidence: PwC, WCG CPAs & Advisors, Basis · tax-compliance-individual-business-20

Client disclosure and consent wording before AI touches return information

Grade C · Assist

Problem. Section 7216 requires written consent for some uses of return information, and it is unsettled whether an AI tool counts as software or as a third party.

Approach

- Practitioners and the AICPA advise a signed stand-alone AI consent, an inventory of AI tools touching client data and security-plan governance.
- Consent must be knowing, voluntary, signed, dated and not retroactive; no rule requiring disclosure of AI use was found.
- The client signs and dates before any use; counsel reviews the language before the tool touches any client matter.

Evidence: IRS OPR, AICPA, Tax Practitioners Board · tax-compliance-individual-business-21

Reprice return work from hours to value or bundled fees

Grade D · Assist

Problem. This is an idea under dispute: hourly billing shrinks when AI cuts preparation time, and billing for time not spent may breach the bar on unconscionable fees.

Approach

- Price by value, bundle preparation with advisory services, and disclose and credit AI efficiencies, as the IRS Office of Professional Responsibility describes.
- The AICPA disputes that language, saying it does not appear to allow value pricing and overlooks software and governance costs.
- The partner approves the fee basis and the client agrees it in the engagement letter.

Evidence: No named deployment · tax-compliance-individual-business-22

Replace offshore or contract data entry and first-pass preparation with AI

Grade C · Automate

Problem. Busy-season volume is met with outsourced, contract and offshore preparers, which raises onboarding, quality and disclosure concerns.

Approach

- Firms bring first-pass preparation onshore through AI products instead of staffing it offshore or with contractors.
- A vendor founder says users talk of bringing work onshore; a consultant says AI affects outsourcing more than onshore staff. No figures.
- A partner reviews the AI-prepared return.

Evidence: Vendor claim · tax-compliance-individual-business-23

AI-native roll-up buys small tax practices and runs them on in-house AI

Grade B · Delegate

Problem. Small tax practices carry heavy manual workloads and thin margins and find it hard to adopt new processes, while buyers look for recurring-revenue service businesses.

Approach

- Multiplier acquired Citrine International Tax, a 12-person cross-border tax boutique, and applied AI tools it built in-house.
- TechCrunch reports the tools helped Citrine more than double its profit margins (self-reported).
- The source does not describe human checkpoints.

Evidence: Multiplier, Citrine International Tax · tax-compliance-individual-business-24

Taxpayers use general-purpose AI agents to draft or check their own returns

Grade C · Delegate

Problem. Self-filers face cost, jargon and complex forms, and some now ask general-purpose AI for help before, or instead of, hiring a preparer.

Approach

- Perplexity announced Computer for Taxes in April 2026, which maps uploaded documents to IRS forms and drafts a federal return.
- A TaxSlayer test of four chatbots found refund errors averaging more than $2,000 across eight scenarios (vendor-published).
- By design there is no human checkpoint for self-filers; practitioners are asked to validate client-brought AI conclusions.

Evidence: Perplexity, TaxSlayer, PYMNTS, Taxfix · tax-compliance-individual-business-25

Corporate compliance

Corporate federal and state returns, international forms, R&D credit and Section G, calendar; in house and at large firms. · 24 use cases · evidence thin (3 of 24 A/B)

AI maps ledger and trial-balance data to tax accounts, with tie-out checks

Grade C · Augment

Problem. Ledger data from many entities and countries must be extracted, mapped to tax accounts and checked before a return is prepared, and a misclassified figure can flow through unflagged.

Approach

- EY describes a GenAI tool that standardises ledger data and maps it with pre-vetted prompts; Thomson Reuters aims for agentic mapping.
- EY says the multi-country mapping step can become a two-day process in place of weeks (vendor-published; no client named).
- A qualified team member reviews the mapping before loading, and the preparer ties a sample of figures to source documents.

Evidence: EY, Thomson Reuters · tax-compliance-corporate-01

Agents read K-1 footnotes, map tax treatments and learn from logged overrides

Grade B · Augment

Problem. Data arrives from several systems in different formats, and K-1 footnotes needed trained staff, heavy human review and group discussion when a footnote was unfamiliar.

Approach

- PwC says agents assess a footnote, state how they interpreted it and give a confidence level, working within its Agent OS.
- PwC's AI tax leader says one person now reviews where three might have gathered; no figures published (self-reported).
- The reviewer checks flagged items, and every override carries a recorded reason the agent learns from.

Evidence: PwC · tax-compliance-corporate-02

AI compares returns and source data year on year, flagging anomalies

Grade C · Augment

Problem. Reviewers of corporate returns compare against prior years and source schedules by hand, while tax authorities increasingly use real-time analytics to find errors.

Approach

- EY says AI-enabled comparison can pinpoint inconsistencies; Baker Tilly describes AI flagging unusual effective tax rate movements across entities.
- Deloitte cites agents flagging anomalies in source data and reconciliations for human review; Corptax lists PDF comparison on its roadmap.
- The reviewer decides which flagged items matter, and the preparer resolves each before sign-off. No outcome figures are published.

Evidence: EY, Baker Tilly, Deloitte, Corptax · tax-compliance-corporate-03

Validation agents critique other agents' output; reviewers do first-level review

Grade C · Augment

Problem. Reviewers face rising volumes of work in which errors are quiet and technical, and now receive conclusions to review rather than subtotals to check.

Approach

- A Thomson Reuters Institute recap says some seminar attendees use validation agents to critique their own agents' outputs.
- OpenAI's 2026 job listing includes first-level review and validation of automated provision outputs. No outcome figures are published.
- A named reviewer signs off the compliance output and samples both AI-flagged and unflagged items.

Evidence: Seminar attendees, OpenAI (job listing) · tax-compliance-corporate-04

Preparation shifts to AI and staff review it, with fewer review layers

Grade C · Augment

Problem. Today a staff-level team member does most compliance preparation, followed by layers of review.

Approach

- EY says AI will in future do much of the preparation while staff monitor it, and fewer review levels may be needed.
- PwC says complex outputs such as tax calculations keep multi-eye review, while simple diagnostics may not need three layers.
- A qualified professional reviews AI-prepared output. No outcome figures are published.

Evidence: EY, PwC · tax-compliance-corporate-05

Agents roll forward prior-year workpapers and prepare review-ready business returns

Grade C · Delegate

Problem. Business-return preparation involves inconsistent client data and review-heavy processes, and most CPA automation had focused on personal returns because business returns were too complex.

Approach

- Byron says agents roll prior-year workpapers into a current-year workbook, request missing information and produce source-linked, confidence-scored output.
- Byron says its extraction is more than 97% accurate (vendor-published); Thomson Reuters and RSM describe similar plans.
- Accountants verify outputs and a professional gives final review before filing.

Evidence: Byron, Thomson Reuters, RSM · tax-compliance-corporate-06

In-house tax team moves from outsourced preparation to agent-driven return computation

Grade B · Delegate

Problem. A company sending its income, gross receipts and property tax compliance to outside preparers must manage vendors, reconcile provision to return and track deadlines through spreadsheets and email.

Approach

- OpenAI's tax team listed a 2025 role to move to internal, agent-powered return computation on version-controlled tax-logic libraries, with a Corptax implementation.
- OpenAI tax staff demonstrated live automation pipelines in 2026; a 2025 listing states a 12-month goal to automate the tax stack (self-reported).
- A manager oversees vendors during the transition, and reviewers perform first-level review of automated outputs.

Evidence: OpenAI · tax-compliance-corporate-07

Large firms build agent platforms to create and manage tax agents

Grade C · Delegate

Problem. Firms and clients need many agents for data collection and compliance tasks, and dozens of unmanaged agents lack performance tracking and coordination.

Approach

- EY describes a Tax Agent Factory to build and manage agents at scale; KPMG and Anthropic put Claude inside KPMG's client platform.
- EY said in March 2025 it planned as many as 150 agents for 80,000 tax professionals (self-reported); no usage data published.
- Human review of agent outputs continues inside client engagements, with firm-level governance committee oversight at PwC.

Evidence: EY, KPMG, Anthropic, PwC · tax-compliance-corporate-08

AI builds R&D credit evidence from project, payroll and ledger systems

Grade C · Augment

Problem. Form 6765 Section G, a business-component breakdown of research expenses, becomes required for tax years after 2025, and interview-based after-the-fact studies struggle to meet that standard.

Approach

- Thomson Reuters says Neo.Tax links project, payroll and ERP systems, groups tickets into components, applies the four-part test and populates Form 6765.
- Thomson Reuters says filing time falls from weeks to days and companies report 50-75% savings versus accounting-firm fees (vendor-published).
- An R&D tax lead confirms each component qualifies; project owners confirm data; the preparer reviews Section G narratives and cost allocation.

Evidence: Thomson Reuters, Baker Tilly, EY · tax-compliance-corporate-09

In-house tax team uses a governed AI platform for data reconciliation

Grade B · Automate

Problem. Vendor Kognitos argues the binding constraint in corporate tax is now assembling and reconciling source data from ledgers and systems, not the calculation itself.

Approach

- Savant says its platform turns messy data into governed outputs with an audit trail, and planned a 2026 session with Oxford Industries.
- Savant's demonstrations covered multi-system reconciliation, document extraction and reporting with lineage; no outcome figures are published for Oxford (vendor-published).
- Tax staff review reconciliation exceptions, and a data owner approves write-backs or reviews a log of them.

Evidence: Oxford Industries, Savant, Kognitos · tax-compliance-corporate-10

Cited AI tax research inside compliance tools, with every authority verified

Grade C · Assist

Problem. Compliance staff leave their return or workpaper tool to research positions, and general chatbots can invent authorities, creating a professional-conduct risk.

Approach

- Thomson Reuters embedded CoCounsel Tax in ONESOURCE in late 2024; Bloomberg Tax added AI insights to Workpapers and Compliance Tracker.
- Thomson Reuters says junior staff can handle more complex questions with cited sources; no figure is published (vendor-published).
- The preparer reads each cited authority before relying on it, and a reviewer cross-checks authorities in supporting memos.

Evidence: Thomson Reuters, Bloomberg Tax · tax-compliance-corporate-11

Agents track filing calendars and rule changes, reporting to the tax team

Grade C · Augment

Problem. Corporate departments track due dates, extensions and rule changes across many entities, often in spreadsheets, while forms and instructions change frequently.

Approach

- Bloomberg Tax announced an AI Assistant in its Compliance Tracker; Orbitax's XatBot tracks regulatory changes and sends comparison reports.
- Bloomberg Tax says the assistant saves time and reduces risk, without a measurement (vendor-published).
- A tax technical lead decides which changes affect returns or payments, and a person approves any filing or payment action.

Evidence: Bloomberg Tax, Orbitax, Corptax · tax-compliance-corporate-12

Pre-filing audit-risk prediction and anomaly screening of the return

Grade C · Assist

Problem. The IRS already uses machine learning to score corporate returns line by line, but preparers get no equivalent signal before filing.

Approach

- Corptax lists audit prediction to address potential triggers early on its AI roadmap; no outcome figures are published (vendor-published).
- Deloitte's framework says low company AI adoption against a high-adoption tax authority brings heightened audit and dispute exposure.
- The reviewer decides whether a flag is an error, a reportable position or a documentation gap; tax decides whether to change course.

Evidence: Corptax, Deloitte · tax-compliance-corporate-13

Continuously updated effective-tax-rate and cash-tax modelling with what-if scenarios

Grade C · Augment

Problem. Static spreadsheet models are slow to update when entity structure, transfer pricing or supply chains change, so the effect on cash taxes is seen late.

Approach

- Baker Tilly describes AI engines that ingest financial data and entity structures to calculate effective rates continuously and run what-if scenarios.
- It also describes agents that download ERP trial balances, summarise them and compare to prior calculations; no figures published (vendor-published).
- Tax reviews scenario outputs before decisions are made.

Evidence: Baker Tilly, Kognitos · tax-compliance-corporate-14

Compliance bought as an AI-enabled managed service, with AI use disclosed

Grade C · Delegate

Problem. Corporate tax departments outsource return work, and 77% want providers to use GenAI while 59% are not sure whether their own companies do (vendor-published).

Approach

- Deloitte says some companies look to outsourcing to gain AI-powered solutions without capital outlay and upgrade costs.
- The IRS Office of Professional Responsibility says practitioners should disclose AI activities; in-house teams can ask providers what AI is used.
- Client and provider agree what AI does and who reviews it, and the tax director reviews disclosures at renewal.

Evidence: Thomson Reuters survey, Deloitte · tax-compliance-corporate-15

Idea: value-based or fixed-fee pricing for AI-enabled compliance work

Grade D · Augment

Problem. This is an idea: AI cuts preparation time, and IRS guidance says billing for manual time not spent, or double billing AI-assisted tasks, may breach the fee rule.

Approach

- Bloomberg Tax reports top firms exploring value- and outcome-based fees as AI cuts billable hours.
- The AICPA is seeking IRS clarification, saying the guidance does not appear to allow value pricing and overlooks software and governance costs.
- An RSM partner illustrated a 20-hour advisory report taking 10 hours with AI (self-reported); the engagement partner sets the fee basis.

Evidence: No named deployment · tax-compliance-corporate-16

Tax analysts build own pipelines and agents with low-code and AI tools

Grade C · Assist

Problem. Data-integration pipelines would otherwise sit in an IT queue for about two months, and only half of corporate tax departments provided technology training in 2025.

Approach

- Seminar attendees described prompting AI tools to build data pipelines in about 15 minutes instead of a two-month IT queue (self-reported).
- Orbitax's Autopilot is a conversational workflow builder inside its international tax platform.
- Any pipeline is independently reviewed and documented before it feeds a return, and each automation has a named owner.

Evidence: TEI seminar attendees, Orbitax · tax-compliance-corporate-17

A tax model explains its inputs and assumptions; approved logic is locked

Grade C · Augment

Problem. CFOs ask whether AI-prepared tax work will hold up under IRS scrutiny; PwC says explainability, traceability and auditability are the test.

Approach

- PwC says a model it uses for effective tax rates explains inputs, output and assumptions, so the logic chain replaces a memo.
- Once approved, logic is locked and people suggest improvements instead of making ad hoc changes; no figures are published (self-reported).
- Tax calculation outputs keep multi-eye human review, and an approval step precedes locking.

Evidence: PwC · tax-compliance-corporate-18

Keep a record of AI use and verification with each AI-assisted item

Grade C · Assist

Problem. If no record shows what an AI tool did and what a person checked, the team cannot show the process behind an output when it is later challenged.

Approach

- Wolters Kluwer advises recording the prompt, output, citations, validation steps and conclusion; Thomson Reuters CoCounsel Tax returns cited sources and reasoning.
- The IRS Office of Professional Responsibility lists documenting AI use and verification as a best practice. No outcome is published.
- The preparer records what was verified and signs off; the reviewer confirms the record exists before sign-off.

Evidence: Wolters Kluwer, Thomson Reuters, IRS OPR · tax-compliance-corporate-19

Approved enterprise AI tools, vendor contract terms and revalidation after model changes

Grade C · Assist

Problem. Preparers use public AI tools with return data, risking exposure under disclosure law, and silent vendor model changes can alter outputs without triggering review.

Approach

- The IRS Office of Professional Responsibility says practitioners must use only secure, enterprise-approved AI for client data.
- An AICPA framework lists contract terms: accuracy service level with remedy, 60 days' notice of material model changes, audit rights, error notice.
- The tax director approves the tool list, and tax technology staff revalidate outputs after each notified vendor change.

Evidence: IRS OPR, AICPA, KPMG Germany survey · tax-compliance-corporate-20

Gated rollout of AI-drafted return work with logging, thresholds and unaided-competence checks

Grade C · Augment

Problem. Faster AI preparation can make review less rigorous in practice, few teams measure what AI does, and juniors who never draft may not learn to review.

Approach

- An AICPA framework phases adoption from research and summarisation to AI-drafted positions, each gated by full logging, override-rate review and error thresholds.
- Thomson Reuters suggests tracking baselines for cycle time, documentation hours and audit exposure; one survey found only 20% measure GenAI return (vendor-published).
- The signing preparer verifies every AI-drafted position; novel positions escalate to senior review; managers run an annual unaided-capability check.

Evidence: AICPA framework, Thomson Reuters · tax-compliance-corporate-21

Idea: deterministic engine computes the return; language model writes checked rule logic

Grade D · Augment

Problem. This is an idea: language models asked to compute a return directly do so unreliably, and returns must be computed exactly while rules keep changing.

Approach

- Researchers propose using the model to translate statutes and forms into executable logic checked against test returns, with a deterministic engine computing.
- One such system matched all 51 held-out benchmark returns against 66% for the strongest language model alone (independent research).
- Tax technology staff review generated logic and test coverage; the preparer reviews the computed return and flagged exceptions.

Evidence: No named deployment · tax-compliance-corporate-22

Idea: an input-check gate holds contradictory cases for a person before computing

Grade D · Automate

Problem. This is an idea: real inputs are often incomplete or contradictory, and a model computing straight through a contradiction returns a confident number with no warning.

Approach

- Researchers add one extra model call that checks the input for conflicts before computing, and abstain when it finds one.
- In tests, strong models computed through injected contradictions without signalling the conflict in 63% to 76% of cases (independent research).
- A person resolves every case where the gate abstains.

Evidence: No named deployment · tax-compliance-corporate-23

Idea: always-on compliance monitoring replaces periodic batch preparation

Grade D · Automate

Problem. This is an idea: compliance is prepared in periodic batches so issues surface at deadlines, while some authorities already see transactions as they happen.

Approach

- EY practitioners describe AI agents that analyse compliance metrics continuously and trigger alerts or remediation before deadlines.
- Deloitte's fourth scenario envisions near real-time compliance with preventive AI-driven controls. No outcome figures are published.
- A person reviews alerts and decides on remediation.

Evidence: No named deployment · tax-compliance-corporate-24

Tax provision and Pillar Two

ASC 740 and IAS 12 provision, ASU 2023-09 disclosures, GloBE calculations and the GIR XML pipeline. · 16 use cases · evidence thin (0 of 16 A/B)

Cited research and AI insights built into provision and direct-tax workflows

Grade C · Assist

Problem. After the books close, tax teams face immediate pressure to finish the provision, and research interruptions slow the work.

Approach

- Bloomberg Tax places AI insights and rates inside Workpapers spreadsheets; Thomson Reuters embedded CoCounsel Tax in ONESOURCE direct tax in late 2024.
- Thomson Reuters says research that took hours now takes minutes (vendor-published); neither source names a customer.
- The preparer reads the linked primary sources before relying on an answer.

Evidence: Bloomberg Tax, Thomson Reuters · tax-provision-pillar-two-01

Idea: AI analysis of Excel-based provision workpapers

Grade D · Assist

Problem. This is an idea: many provision teams still build workpapers in Excel, which vendor Finrep calls a control risk auditors are increasingly unwilling to accept.

Approach

- An AI assistant would read provision workbooks to explain formulas, check tie-outs and answer questions.
- A 2026 Tax Executives Institute programme scheduled an AI-for-Excel lab; no provision team is shown doing this.
- No source describes the review step.

Evidence: No named deployment · tax-provision-pillar-two-02

Provision data assembly and the close-to-tax handoff

Grade C · Automate

Problem. The provision runs on close data, and vendor Kognitos calls the handoff from close to tax a manual, error-prone junction where accuracy is decided.

Approach

- Bloomberg Tax describes automated data cleansing, rollforwards and book-to-tax adjustments in Workpapers that push into Provision.
- Thomson Reuters aims for agentic data import, validation and mapping; Kognitos describes an upstream agent layer that reconciles ledger data.
- No source says who reviews exceptions; direct tax professionals keep oversight of import, validation and mapping.

Evidence: Bloomberg Tax, Thomson Reuters, Kognitos · tax-provision-pillar-two-03

Pre-close anomaly flagging and document comparison in provision review

Grade C · Augment

Problem. Reviewers must catch outliers in deferred tax balances, rate reconciliation lines and source documents before the provision is final.

Approach

- Finrep describes comparing deferred tax balances with historical patterns and flagging outliers; CSC Corptax lists PDF comparison on its AI roadmap.
- Thomson Reuters advertised for a specialist to build anomaly detection into ONESOURCE Tax Provision; these are development signals, not shipped features.
- Flagged outliers go to human review before close.

Evidence: Finrep, CSC Corptax, Thomson Reuters · tax-provision-pillar-two-04

Assembling the rate reconciliation and taxes-paid disclosure under the new accounting standard

Grade C · Augment

Problem. ASU 2023-09 requires public entities to give a detailed tabular rate reconciliation and split income taxes paid by federal, state and foreign jurisdiction.

Approach

- Finrep says AI-assisted categorisation of reconciling items from ERP data is the answer; vendor pages do not confirm this.
- Neither vendor's own page was found to confirm this; no outcome figures are published (vendor-published).
- The tax director reviews and approves the categorisation and the narrative.

Evidence: Finrep (vendor claim) · tax-provision-pillar-two-05

Idea: generative AI first draft of income tax footnote disclosures

Grade D · Augment

Problem. This is an idea: tax disclosures must be company-specific and consistent with the provision, and Finrep says generic AI language risks SEC comment letters.

Approach

- Generative AI would draft disclosure language from provision data; Finrep says Big Four firms are piloting this, without a source.
- The PCAOB found preparers using generative AI for first drafts of internal documents, not specifically tax disclosures.
- A tax professional reviews, edits and approves every draft.

Evidence: No named deployment · tax-provision-pillar-two-06

Live R&D credit data feeding provision estimates

Grade C · Automate

Problem. R&D credit amounts in the provision can rest on estimates or prior-year placeholders rather than live data, and revised Form 6765 adds business-component reporting.

Approach

- Thomson Reuters says Neo.Tax links project tools, groups data into components, applies the four-part test and allocates costs.
- Thomson Reuters says live data makes the credit visible in real time and can reduce return-to-provision adjustments; no figures (vendor-published).
- No source describes the review step.

Evidence: Thomson Reuters · tax-provision-pillar-two-07

Law-change monitoring feeding the provision and Pillar Two compliance

Grade C · Augment

Problem. Enacted-law changes drive deferred tax remeasurement, and Pillar Two rules keep moving, with new OECD packages in January and September 2026.

Approach

- Orbitax's Tax Flows mode tracks regulatory changes and sends comparison reports; CSC Corptax lists tax code version tracking on its roadmap.
- KPMG US's tax vice chair says building an agent for changing tax rules went from weeks to minutes (self-reported).
- No source describes the review step beyond reports going to stakeholders.

Evidence: Orbitax, CSC Corptax, KPMG · tax-provision-pillar-two-08

Pillar Two data collection seeded from validated country-by-country reporting data

Grade C · Automate

Problem. Pillar Two data drives actual tax and needs more granular data than finance and country-by-country reporting held; the first return needed over 100 data points.

Approach

- AMG Critical Materials loaded validated reporting XML into Orbitax's Accelerator, then added extra data; sources describe software automation, not AI.
- Orbitax's case study says AMG's path to implementation shortened to around 10 days (vendor-published).
- The tax team completes and reviews the additional information; AMG says it kept control of the financial data.

Evidence: AMG Critical Materials, Orbitax · tax-provision-pillar-two-09

Idea: AI-assisted mapping of ERP data to global minimum tax data points

Grade D · Augment

Problem. This is an idea: Pillar Two needs jurisdiction-level calculations built from entity data held in several ERP systems, a substantial change from single-entity income tax work.

Approach

- EY's technology leader says AI can assist in mapping ERP data to common standards, but standardisation is long-term and needs governance.
- Intrinsic data-quality issues still need human correction; flagged data issues get manual review and correction.

Evidence: No named deployment · tax-provision-pillar-two-10

Pillar Two computation with safe-harbour tests, scenarios and interim estimates

Grade C · Automate

Problem. Global minimum tax calculations must be run by jurisdiction while the rules keep changing, including new safe harbours and a revised information return in 2026.

Approach

- EY's GloBE Engine and Deloitte's Pillar Two Agent hold the rules and run compliance and scenarios; sources call them rules-based, not AI.
- A Swiss-parented insurer ran Orbitax as an independent check on its Excel calculations, surfacing data issues before filing (vendor-published).
- The team reviews dashboards and reports before filing, and in-scope groups must assess the safe-harbour components themselves.

Evidence: EY, Deloitte, Orbitax, Swiss-parented insurer · tax-provision-pillar-two-11

Pillar Two return population, XML generation, validation and direct filing

Grade C · Automate

Problem. For many groups the first return season was an XML problem more than a tax-law problem, with country schema variants, early portal gatekeeping and errors in the OECD schema.

Approach

- Platforms populate the return, generate and validate XML, and file by machine link where allowed; sources describe rules-based tooling, not AI.
- Orbitax says it prepared or submitted more than 1,700 Pillar Two filings across 34 jurisdictions (vendor-published).
- The tax team reviews validation results and resolves errors, which an insurer called the most demanding part of the season.

Evidence: Orbitax, EY, Deloitte · tax-provision-pillar-two-12

Correction and amendment management for Pillar Two returns

Grade C · Automate

Problem. Corrections to the Pillar Two return work only against accepted messages and need reference tracking; more corrections are expected as rules change.

Approach

- Law firm FGS says its Pillar 2 Management App supports correction returns and largely automates correction references; rules-based, no AI claimed.
- FGS names no client and publishes no figures (vendor-published).
- No source describes the review step.

Evidence: Flick Gocke Schaumburg · tax-provision-pillar-two-13

Conversational assistant over live Pillar Two scenarios

Grade C · Augment

Problem. After calculations are done, the remaining work is reviewing data, answering finance and audit-committee questions, validating XML and documenting decisions.

Approach

- Orbitax says its XatBot assistant reads live scenarios, answers questions in plain language, analyses uploaded files and drafts audit-committee updates.
- In Autopilot mode it can create and navigate scenarios from a conversation; no outcome figures are published (vendor-published).
- The user can review the generated workflow before it runs, and professional judgment applies to anything entering a filing.

Evidence: Orbitax · tax-provision-pillar-two-14

Firm-run Pillar Two platform with specialist team, sold as co-sourcing

Grade C · Automate

Problem. Heads of Tax must run Pillar Two compliance quickly with audit-ready transparency; 70% of surveyed leaders expect to pay over US$500,000 a year to comply.

Approach

- Deloitte offers its Pillar Two Agent only with its tax team, which collects data, calculates top-up tax and files; EY offers similar.
- The sources do not describe AI, and no outcome figures are published (vendor-published).
- The platform offers clients options for reviewing and signing off on data.

Evidence: Deloitte, EY, Flick Gocke Schaumburg · tax-provision-pillar-two-15

Bringing Pillar Two compliance in-house on a platform instead of outsourcing

Grade C · Automate

Problem. AMG's small tax function could not add headcount for Pillar Two and had to choose between outsourcing and building the capability itself.

Approach

- AMG chose software run in-house, as did a Swiss-parented insurer with a lean tax team; the sources describe software, not AI.
- Orbitax says AMG's two-person tax function delivered first-year compliance across 70-80 entities in 25 jurisdictions with no added headcount (vendor-published).
- AMG's vice president of tax reviewed and filed the returns.

Evidence: AMG Critical Materials, Orbitax · tax-provision-pillar-two-16

Indirect tax

VAT, GST and sales and use tax: determination, product mapping, certificates, nexus, returns, e-invoicing and CTC, agentic commerce. · 22 use cases · evidence thin (4 of 22 A/B)

AI-proposed product tax codes with confidence scores, reviewed by a person

Grade A · Augment

Problem. Mapping thousands of products to the right tax code by hand is slow and inconsistent, and wrong mappings produce wrong tax that is hard to defend in an audit.

Approach

- A model proposes a tax code with a confidence score; Vertex, Thomson Reuters, Sovos and Avalara offer this; Dell trained small models.
- Vertex's CEO says categorisation fell from over a minute and a half to seconds per product (vendor-published).
- A person confirms or overrides each suggested code; low-confidence suggestions are reviewed or sent back for more product detail.

Evidence: Vertex, Thomson Reuters, Sovos, Avalara, Dell · tax-indirect-tax-01

Agent-prepared sales tax and VAT returns, filed only after human approval

Grade C · Delegate

Problem. US sales tax reporting spans more than 19,000 jurisdictions, and 71% of surveyed indirect tax teams have not fully automated a single workflow end to end.

Approach

- Agents ingest transaction data, validate it, map it to returns and present them for approval; Thomson Reuters, Avalara and Deloitte describe this.
- Thomson Reuters states routine reporting time falls by up to 65% and compliance cycles from 30 days to 11 (vendor-published).
- Final review and approval come before filing, and agents notify a person for novel situations.

Evidence: Thomson Reuters, Avalara, Deloitte · tax-indirect-tax-02

AI validation and routing of exemption certificates as they arrive

Grade C · Augment

Problem. Exemption and resale certificates are among the most manual areas of compliance, and certificate errors can lead to audit exposure and penalties.

Approach

- Avalara says its Exemption Certificate Management ingests, classifies, validates and routes certificates with document processing, spots missing fields and flags errors.
- Avalara says AI review is faster and more accurate than manual review; no figure is published (vendor-published).
- Flagged or failed certificates route to a person; Avalara says agents ask a human for novel situations.

Evidence: Avalara · tax-indirect-tax-03

Re-checking every exemption certificate already on file

Grade C · Automate

Problem. Certificates are collected, stored and checked by hand, so invalid or expired certificates stay undiscovered until an audit.

Approach

- Document intelligence extracts and validates every certificate on file; Avalara describes agents that cross-check certificates against authoritative registries.
- Numeral reports that 30% to 40% of certificates moved onto its platform fail validation (vendor-published).
- The source does not describe the review step for certificates; Avalara says human approval checkpoints exist across its agent platform.

Evidence: Numeral, Avalara · tax-indirect-tax-04

Grounded taxability and regulatory Q&A assistant inside the tax platform

Grade B · Assist

Problem. Staff spend time finding taxability answers across jurisdictions, and a general chatbot can be confidently wrong, as in one Avalara example of a wrong local rate.

Approach

- Platform assistants answer from a curated knowledge base: Sovos's Ask Sovi, Avalara Aviator and Vertex Copilot.
- A beta customer at Singer Equipment Company says Aviator surfaces considerations she might have missed; no figures published (vendor-published).
- The user decides what to do with an answer; Sovos plans guided, human-approved actions.

Evidence: Sovos, Avalara, Vertex, Singer Equipment Company · tax-indirect-tax-05

VAT place-of-supply assistant grounded in law, answers verified by a tax adviser

Grade A · Augment

Problem. Clients describe VAT cases in free-text emails, and advisers must determine the place of supply and justify it from statute, where errors carry significant financial consequences.

Approach

- A language model retrieves passages of Austrian and EU VAT law and returns a place-of-supply decision citing its legal sources.
- On textbook cases retrieval scored 93.24% against 68.92% for the plain model; on 20 real inquiries it got 16 right (independent research).
- A tax adviser checks every cited paragraph and approves the analysis before it reaches the client.

Evidence: Austrian university researchers · tax-indirect-tax-06

Plain-language drafting of tax-engine rules, simulated on past transactions first

Grade C · Augment

Problem. Configuring custom tax rules in a tax engine needs specialist knowledge of the product and the law, and changes can conflict with other rules.

Approach

- Avalara's agent drafts a rule from a plain-language request, simulates it on past transactions and flags conflicts; Vertex showed similar plain-language configuration.
- Avalara claims Aviator turns days of manual work into minutes of oversight (vendor-published).
- The customer reviews and approves the drafted rule before the agent activates it.

Evidence: Avalara, Vertex · tax-indirect-tax-07

E-invoice rejection diagnosis, with corrections made after a user approves

Grade C · Augment

Problem. Under clearance e-invoicing an invoice has no legal force until the authority accepts it, so a wrong VAT ID or malformed schema means rejection and stalled goods and payment.

Approach

- Sovos's Sovi AI diagnoses root causes of compliance errors, proposes fixes and executes them once a user approves, logging each action.
- Thomson Reuters demonstrated AI exception handling in ONESOURCE; Sovos reports a 1.6% rejection rate in French production, not credited to AI (vendor-published).
- A user approves each proposed correction before it executes, and tax reviews recurring root causes.

Evidence: Sovos, Thomson Reuters · tax-indirect-tax-08

Continuous regulatory-change monitoring with alerts linked to primary sources

Grade C · Augment

Problem. Monitoring often relies on one person watching a few countries and forwarded newsletters, so rule changes frequently surface only at filing time.

Approach

- Fonoa Knowledge monitors centrally, filtered to the company's jurisdictions, with each alert linked to the primary source and a confidence score.
- Sovos assesses how rule changes affect each customer's configuration; Avalara's research agents summarise primary sources with citations. No outcome figures are published.
- Fonoa says deciding whether a change applies to the business may need a human's deterministic application.

Evidence: Fonoa, Sovos, Avalara, Thomson Reuters · tax-indirect-tax-09

AI extraction of invoice and expense data for VAT recovery and e-invoicing

Grade C · Automate

Problem. Fragmented travel, expense and payables data must be cleansed and enriched before eligible input VAT can be recovered, and e-invoicing regimes need accurate onboarding and data extraction.

Approach

- Blue dot's platform extracts, cleanses and validates invoice and expense data; Sovos bought it in September 2026 and plans to embed it.
- Vertex bought AI e-invoicing start-up Brinta in Q1 2026; Sovos says Blue dot has shown accuracy above 98% (vendor-published).
- The sources do not describe the human review step.

Evidence: Sovos, Blue dot, Vertex, Avalara · tax-indirect-tax-10

Pre-filing anomaly detection and exception triage across invoice and tax data

Grade C · Augment

Problem. Misapplied rates, address mismatches and unusual swings in tax amounts need catching before filing, but manual review samples only a small share of transactions.

Approach

- Models flag outliers in tax data before filing and route exceptions to reviewers; Thomson Reuters, Sovos and Fonoa describe this.
- Thomson Reuters says some indirect tax teams use AI to triage invoice exceptions; no outcome figures are published (vendor-published).
- Flagged items go to review, and a tax manager verifies flags against known rules.

Evidence: Thomson Reuters, Sovos, Fonoa, Saffery · tax-indirect-tax-11

Idea: validate and repair tax-relevant master and transaction data at entry

Grade D · Augment

Problem. This is an idea: most indirect-tax errors start upstream in missing fields and inconsistent configuration, and only 23% of surveyed multinationals say their ERP is fit for purpose.

Approach

- Practitioners discuss agents near master-data setup and payables flows that extract, enrich and validate data as transactions occur, not at return time.
- In KPMG's survey about 49% said improving data quality will be their primary AI use case, an intention (independent survey).
- AI surfaces results for human review where judgment is required, and the tax team approves rule changes.

Evidence: No named deployment · tax-indirect-tax-12

Nexus monitoring, nexus questions and registration agents

Grade C · Delegate

Problem. Companies cross economic-nexus thresholds or start selling into new countries without registering in time, and registration is paper-heavy and multi-authority.

Approach

- Avalara registration agents prepare and file registration documents and track them to signed storage; Numeral supports nexus monitoring and registrations.
- Numeral states customers can cut time on filings and registrations by up to 80% (vendor-published).
- Avalara states human review checkpoints at every stage, and Deloitte's agent flags patterns for tax professionals to consider.

Evidence: Avalara, Numeral, Deloitte · tax-indirect-tax-13

Intake, data extraction and routing of tax-authority notices

Grade C · Automate

Problem. Tax-authority notices arrive in many forms and jurisdictions and must be received, classified, routed and tracked to deadlines.

Approach

- Avalara describes notice-management agents that automate receipt, classification, routing and tracking of notices across jurisdictions.
- Seminar attendees described using image-to-text AI to pull structured data out of state tax notices. No outcome figures are published.
- Avalara states review and approval checkpoints at every stage; notice-specific checkpoints are not described.

Evidence: Avalara, TEI seminar attendees · tax-indirect-tax-14

Audit-ready decision records for AI-assisted tax determinations, overrides and filings

Grade C · Augment

Problem. In one survey, 57.4% of indirect tax leaders would not be confident defending AI-assisted decisions to a tax authority, and few run formal documented sign-off.

Approach

- Log each AI-assisted determination, override and approval with rule version, inputs, rationale and reviewer; Fonoa, Thomson Reuters, Sovos and Avalara describe this.
- Fonoa's survey found organisations with formal human-in-the-loop governance were more than twice as likely to be confident (vendor-published).
- A named human owns each AI-supported decision; tax professionals answer the authority while agents prepare documentation.

Evidence: Fonoa, Deloitte, Thomson Reuters, Sovos, Avalara · tax-indirect-tax-15

Tax engines callable by customers' own AI agents through standard protocols

Grade C · Automate

Problem. Tax calculation, classification, registration and filing sit inside tax applications, but compliance work may now start in an ERP, a finance system or an AI agent.

Approach

- Avalara described MCP servers letting customers' agents validate taxes and start registrations; Sovos is developing a governed gateway; Vertex builds ERP agents.
- Avalara says its Versori unit builds connectors in days rather than months (vendor-published).
- Avalara says agents notify a human for novel situations and decisions that affect the compliance footprint.

Evidence: Avalara, Sovos, Vertex, Taxually · tax-indirect-tax-16

Tax calculation and holiday rules when an AI agent checks out

Grade C · Automate

Problem. When an AI agent completes a purchase there may be no human at checkout, so who must collect tax is unclear, and tax holidays need exact timing and category rules.

Approach

- Keep tax calculation in the merchant's existing tax engine, called from the agent's checkout; the Sales Tax Institute says Shopify did this.
- Make holiday rules machine-readable and give agents correct catalogue data; no outcome figures are published (independent).
- Controls move to the tax engine and data, and tax and e-commerce teams confirm configuration before peak events.

Evidence: Sales Tax Institute, Shopify, Stripe (commentary) · tax-indirect-tax-17

Finance agents that embed VAT and e-invoicing rules in payables and invoicing

Grade C · Delegate

Problem. Companies bolting separate finance and tax applications onto ERPs face integration and governance burdens, while authorities require real-time clearance against local rules.

Approach

- Sovos bought Flowie on 1 October 2026; its agents run payables, procure-to-pay and invoicing on an ERP using Sovos's regulatory data.
- Sovos cites an EY figure of up to 40% for agentic finance implementations; the EY source was not opened (vendor-published).
- Human checkpoints are not described in the release.

Evidence: Sovos, Flowie · tax-indirect-tax-18

AI-enabled managed sales tax and VAT compliance delivered as a service

Grade C · Delegate

Problem. Software, distribution and manufacturing companies face changing multi-state and multi-country tax obligations and want them handled without adding manual work.

Approach

- Providers such as Numeral run the lifecycle (nexus, registration, filing, certificates) on an AI-native platform covering VAT/GST in more than 90 countries.
- Numeral reports transaction volume growth of 327% year over year and Taxually reports client growth of almost 40% (vendor-published).
- Complex issues go to tax experts at the provider.

Evidence: Numeral, Taxually · tax-indirect-tax-19

General-purpose AI for first-pass analysis and month-end summaries in an approved workspace

Grade B · Augment

Problem. An in-house indirect tax manager owns compliance in several countries, and 60.8% of surveyed organisations rely mainly on individuals using public AI tools without governance.

Approach

- A Plusgrade job posting says AI handles first-pass recurring data analysis and month-end tax summaries so the manager focuses on judgment (self-reported).
- The recommendation is to provide approved, grounded tools with logging and a use policy; no outcome figures are published.
- The Tax Manager owns the final call, and a reviewer checks AI research output against primary sources.

Evidence: Plusgrade · tax-indirect-tax-20

Idea: ongoing indirect-tax exposure, accrual and scenario analysis by agents

Grade D · Augment

Problem. This is an idea: indirect-tax teams answer ad hoc questions about supply-chain changes and pricing, and book conservative accruals because of data gaps.

Approach

- Practitioners suggest agents run ongoing scenario analysis, give a view of exposures that may reduce over-accruals, and flag transactions creating unmanaged exposure.
- Thomson Reuters Institute adds forecasting VAT cash flows and quantifying audit exposure by country, product and customer segment.
- Agents provide structured input for tax professionals to consider.

Evidence: No named deployment · tax-indirect-tax-21

Idea: a rule engine checks each step of AI-agent VAT determination

Grade D · Augment

Problem. This is an idea: model agents that classify, rate and apply reverse charge can fail silently, and in one study 20-30% of real-world VAT analyses were wrong.

Approach

- Split VAT determination into auditable steps, let model agents handle language and lookup, and check every step against a deterministic rule engine.
- In a preprint pilot on synthetic cases, a tuned single agent scored 0.755 accuracy and the best orchestrated set-up 0.830 (independent research).
- A tax expert approves outputs the rule engine cannot confirm, and rule-set changes are reviewed.

Evidence: No named deployment · tax-indirect-tax-22

Transfer pricing

Policy, agreements, benchmarking, local and master files, operational TP, audit defence, APAs; A/B entries are rules-based automation. · 22 use cases · evidence thin (3 of 22 A/B)

Cited-answer research assistant for transfer pricing law and local requirements

Grade C · Assist

Problem. Central transfer pricing teams cover dozens of jurisdictions while rules change constantly, and general chatbots give answers without clear sourcing.

Approach

- Aibidia with IBFD data announced TP Aurora, returning cited answers from a curated transfer pricing content set, available from 22 May 2025.
- The user opens the cited source before relying on an answer.
- Vendor claims 90% less research time (vendor-published; baseline and method not given).

Evidence: Aibidia, IBFD, KPMG US · tax-transfer-pricing-01

General AI assistants used by in-house transfer pricing staff

Grade C · Assist

Problem. Small transfer pricing teams carry growing complexity with limited headcount, and routine drafting, research and data formatting take time away from analysis.

Approach

- Staff use Microsoft Copilot, ChatGPT and Claude for drafting, research, formatting data and stress-testing authority responses; not integrated with company data.
- An accountable professional validates every AI output before it becomes part of the record.
- 93% of surveyed professionals use AI in some form; 37% report regular use in 2026, up from 18% (vendor-published survey).

Evidence: Aibidia survey; Microsoft, OpenAI, Anthropic tools · tax-transfer-pricing-02

Self-service transfer pricing answers for non-specialists, escalating to the specialist team

Grade C · Augment

Problem. Transfer pricing teams are small and local finance contacts touch the topic rarely, so recurring policy questions pull specialists away from analysis.

Approach

- Deloitte Poland offers a GenAI chatbot built on the organisation's own policies; it answers simple questions and routes complex ones onward.
- Andersen Australia tested a general AI platform on documentation rules: answers were well structured, but the tool cannot own the conclusion.
- A specialist handles escalated questions and reviews before any position or document is relied on. No outcome figures published.

Evidence: Deloitte Poland, Andersen Australia · tax-transfer-pricing-03

AI-assisted gathering of intercompany data from several accounting systems

Grade C · Augment

Problem. Year-end transfer pricing analysis is a scramble to pull and standardise data from disconnected systems; 79% in Aibidia's 2026 survey spend over 10% of team time on it.

Approach

- Plante Moran says AI can aggregate information from several accounting and ERP platforms into one consistent format, reducing manual spreadsheet work.
- Webinar speakers say fragmented or manual data should be standardised first.
- The team reviews how inputs were prepared and reconciles to ledger and consolidated figures. No outcome figures published.

Evidence: Plante Moran, Aibidia · tax-transfer-pricing-04

AI-drafted functional and industry analysis, including intangible-asset support

Grade C · Augment

Problem. Functional, asset and risk analysis, intangibles assessment and industry analysis rely on interviews and many outside sources, and are the parts of a transfer pricing file authorities most often probe.

Approach

- PwC Singapore has the model gather website information to explain commercial factors behind margin changes, such as pandemic glove-manufacturing margins.
- KPMG US says GenAI can automate industry and functional analyses; BDO Canada says AI cannot determine whether arrangements reflect practice.
- A practitioner validates the functional profile with business interviews, and a senior practitioner reviews intangibles conclusions.

Evidence: PwC Singapore, KPMG US, BDO Canada · tax-transfer-pricing-05

AI-assisted search for comparable companies and benchmarking draft

Grade C · Augment

Problem. Benchmarking means searching databases or websites one by one, screening, documenting each decision, calculating ranges and writing the report, which takes hours or days.

Approach

- The model returns a candidate list from the practitioner's screening instructions; the practitioner then runs recognised databases and a documented screen.
- A PwC Singapore senior manager said analysis taking up to 100 hours can, under certain conditions, take about 30 minutes (self-reported).
- BDO Canada reports AI benchmarking outputs lacking depth or screening rationale; the practitioner approves each rejection and the final range.

Evidence: PwC Singapore, BDO Canada, RoyaltyRange, Exactera · tax-transfer-pricing-06

First-draft local file and master file narratives with expert review

Grade C · Augment

Problem. Local and master files for many entities repeat similar narrative sections and are updated yearly; an Exactera speaker called check-the-box documents lacking substance the most common mistake.

Approach

- The professional supplies facts, a GenAI tool drafts the narrative, and the expert reviews, edits and approves.
- BDO Canada reports recurring gaps in AI-generated outputs, including documentation that looks complete but lacks audit-ready support.
- Functional facts are checked against how decisions are actually handled, with sign-off on method selection. No outcome figures published.

Evidence: BDO Canada, Exactera, Aibidia participants · tax-transfer-pricing-07

AI review of transfer pricing files against country rules and for consistency

Grade C · Augment

Problem. Local files must meet country-specific rules that change often, and authorities compare figures across files, reports and returns, so mismatches invite scrutiny.

Approach

- Exactera announced ExactReport, a Word-based app that reviews a draft against country requirements and suggests edits; offered through an early adopter programme.
- KPMG South Africa and Nigeria authors advise reconciling data across statements, files and filings to avoid automated flags.
- The preparer accepts or rejects each suggested edit, and a person explains reconciliation breaks before filing.

Evidence: Exactera, KPMG South Africa and Nigeria · tax-transfer-pricing-08

Central transaction data feeding bulk local file and master file production

Grade B · Automate

Problem. Trivium Packaging built local files per entity from emailed data and manual formatting, so small teams prioritised high-risk entities and reviewed each document three to four times.

Approach

- A platform imports transaction data once and generates editable local files for many entities; which steps use AI is not stated.
- Trivium reports a simple local file now takes a few hours versus 2-5 working days (vendor-published case study).
- Fortum reports a 65% transaction automation rate (vendor-published); local controllers confirm data and external advisors review rather than prepare.

Evidence: Trivium Packaging, Fortum, Aibidia · tax-transfer-pricing-09

First-draft intercompany agreements from the policy, with clause extraction

Grade C · Augment

Problem. Intercompany agreements must match the transfer pricing policy and real flows; Plante Moran says drafting often stalls for weeks at growing companies.

Approach

- AI drafts an agreement from the written policy; an Exactera interviewee says agents can extract pricing and risk clauses for checking.
- Plante Moran says drafting moves from weeks to hours (firm statement, not measured).
- Qualified transfer pricing and legal professionals review each draft against actual conduct before finalising.

Evidence: Plante Moran, BDO Canada, Exactera · tax-transfer-pricing-10

Multi-agent review of intercompany deals across transfer pricing, VAT and customs

Grade C · Delegate

Problem. The same intercompany transaction has legal, transfer pricing, VAT, withholding-tax and customs consequences that separate teams review in sequence, so inconsistencies show up late.

Approach

- A TPMinds International 2026 example (organisation not named) used multi-agent workflows reviewing legal, transfer pricing, VAT and withholding-tax implications together before drafting.
- A sponsored Nexdigm article says multi-agent workflows can flag cross-reporting inconsistencies before audit; professionals decide the resolution.
- No outcome figures published; human checkpoints are not stated for the conference example.

Evidence: TPMinds example, Nexdigm (sponsored) · tax-transfer-pricing-11

Automated intercompany price calculation, invoicing and posting

Grade B · Automate

Problem. Kemira calculated transfer prices manually across 62 legal entities in 40 countries, which was heavy work for tax, finance and local teams.

Approach

- A tailored tool automates segmented P&Ls and fee, royalty and resale-minus calculations, with robotics sending invoices and posting entries to SAP monthly.
- Kemira reports hundreds of work hours saved (vendor-published).
- The tax team uses the tool for monitoring, with a monthly close review of results and unusual movements.

Evidence: Kemira, Aibidia · tax-transfer-pricing-12

In-year monitoring of intercompany margins against policy ranges

Grade C · Augment

Problem. Transfer prices are usually tested after year end, so margin drift is found late; in Aibidia's 2026 survey only 7% formally monitor monthly and 60% rely on Excel and email.

Approach

- Plante Moran describes loading raw data into an AI tool to build dashboards tracking margins against target ranges and flagging deviations.
- A TPMinds recap says organisations already monitor outcomes with AI in real time, without naming any.
- The transfer pricing team investigates flagged deviations and decides adjustments; finance owns execution. No AI outcome figures published.

Evidence: Plante Moran, Aibidia, TPMinds, Nexdigm · tax-transfer-pricing-13

Connected transfer pricing knowledge model that flags inconsistencies

Grade C · Augment

Problem. Policies, agreements, financial results and audit history sit in different systems, so showing why a position is defensible needs extensive manual investigation.

Approach

- Aibidia announced TP Intelligence, a connected model that flags inconsistencies and traces findings to source evidence; first release planned December 2026.
- In a Helsinki demonstration it quantified a EUR 4.8 million potential risk in one entity (vendor-published demo, not a client result).
- A controller, reviewer or auditor follows each flag back to its source evidence.

Evidence: Aibidia (vendor demo) · tax-transfer-pricing-14

Pre-filing audit-risk screening of intercompany positions

Grade C · Augment

Problem. Authorities select transfer pricing audits on indicators such as routine entities at a loss, but taxpayers rarely test their own positions against these signals before filing.

Approach

- Taxpayer-side analytics score intercompany positions against known authority selection patterns and IRS self-assessment suggestions so documentation can be strengthened.
- Exactera claims AI can predict audit vulnerability, with no accuracy reported (vendor-published).
- The transfer pricing lead decides whether a flagged position needs more documentation, a price change, a defence or an advance pricing agreement.

Evidence: Exactera, Checkpoint report · tax-transfer-pricing-15

Drafting and stress-testing audit responses from prior documentation

Grade C · Augment

Problem. Audit responses need years of prior files read and consistent answers under deadline; half of respondents in a vendor survey spend 50-200 hours on audit response.

Approach

- KPMG US says GenAI can review historical documents and formulate responses in transfer pricing controversy.
- Participants at Aibidia briefings said they use general AI tools to stress-test responses to tax authorities.
- The controversy lead reviews every statement of fact and citation, and an accountable professional approves the submission.

Evidence: KPMG US, PwC Singapore, Aibidia participants · tax-transfer-pricing-16

Idea: AI-assisted economic analysis in transfer pricing litigation, with tool disclosure

Grade D · Assist

Problem. Idea, not a deployment: expert economists could use AI for benchmarking and valuation in litigation, which would make the reliability of the output an evidence question.

Approach

- An IRS LB&I official said experts must explain inputs, assumptions, methods and AI tools, and that the IRS wants to see formulas.
- Proposed Federal Rule of Evidence 707 on machine output: the Standing Committee decided on 3-4 June 2026 not to recommend action.
- The testifying expert must be able to explain and defend every input, assumption and method.

Evidence: No named deployment · tax-transfer-pricing-17

Idea: AI support for advance pricing agreement and dispute resolution cases

Grade D · Assist

Problem. Idea, not a deployment: advance pricing agreements and authority-to-authority disputes are lengthy negotiations with uncertain outcomes.

Approach

- A KPMG commentary (October 2024) suggests AI could improve case management, support negotiation and predict outcomes from past cases.
- Aprio says some authorities are developing models to predict outcomes, without naming any.
- Negotiation and position-setting remain with practitioners and competent authorities.

Evidence: No named deployment · tax-transfer-pricing-18

Transfer pricing policy modelling and planning-opportunity screening

Grade C · Assist

Problem. Policy design and planning need analysis of how entity results, tax rates and new business models interact across jurisdictions.

Approach

- KPMG US says GenAI can scrutinise global tax developments to pinpoint planning prospects, parse financials and update calculations.
- Plante Moran says some companies test subsidiary financials against country tax rates with lightweight models, as a jump-start for an adviser conversation.
- The adviser and transfer pricing lead review the model's result before any policy or structure change. No outcome figures published.

Evidence: KPMG US, Plante Moran · tax-transfer-pricing-19

Idea: AI-use and verification log inside transfer pricing workpapers

Grade D · Assist

Problem. Idea, not a deployment: if an AI-assisted position is challenged, a team may not be able to show what the AI suggested versus what a person verified.

Approach

- Record which AI tools, inputs and review steps were used; BDO Canada, the IRS OPR alert and the Werfel register recommend variants.
- It is a governance control around AI-assisted work, not an automation.
- A reviewer attests to verification of each AI-assisted section.

Evidence: No named deployment · tax-transfer-pricing-20

Bringing recurring documentation in-house, with advisors limited to review

Grade B · Augment

Problem. Trivium's documentation cost over EUR 10,000-15,000 per entity, forced prioritising high-risk entities, and outside advisors did not know the company fully, according to its transfer pricing manager.

Approach

- Documentation work moves in-house onto a central data platform, with advisors used for jurisdiction-specific, technical or high-risk matters and for review.
- Trivium says the platform gives a predictable cost while scaling coverage; new cost not stated (vendor-published).
- Fortum's stated goal is to use external parties only to review local files.

Evidence: Trivium Packaging, Fortum, Aibidia · tax-transfer-pricing-21

Software platform plus experts delivering transfer pricing work at fixed prices

Grade C · Augment

Problem. Traditional advisory engagements take months and cost heavily for repeatable work, and in-house teams question paying advisors mainly for validation and risk absorption.

Approach

- Commenda advertises about four weeks and USD 9,000 versus USD 60K and six months for traditional advisors (vendor claim).
- Aibidia and BIP Law & Tax announced an exclusive Italian partnership with a joint task force for continuous transfer pricing management.
- Provider experts review deliverables, and the client explains the business and reviews output.

Evidence: Commenda, Aibidia, BIP Law & Tax · tax-transfer-pricing-22

Controversy and tax authorities

Notices, exams, Appeals and litigation from the taxpayer side, plus tax authorities' AI; nearly all A/B entries are authority-side. · 25 use cases · evidence moderate (10 of 25 A/B)

AI reads and sorts incoming IRS and state tax notices

Grade C · Augment

Problem. Tax notices are technical, carry strict deadlines, and working out what changed and how to respond takes longer than expected and varies by practitioner.

Approach

- An uploaded notice is analysed to extract the deadline, amount due and issue and list response paths (Wolters Kluwer, Thomson Reuters tools).
- Vendor says this shortens the time from receipt to action (vendor-published; no figure).
- The practitioner checks the extracted deadline, amount and issue against the notice; the reviewer chooses the course of action.

Evidence: Wolters Kluwer, Thomson Reuters, EY · tax-controversy-01

AI drafts client explanations and formal replies to tax notices

Grade C · Augment

Problem. Once a notice is understood, the firm must explain it to the client in plain language and prepare a formal response, usually drafted from scratch each time.

Approach

- The tool drafts a client-ready explanation and an agency response, such as a penalty abatement request (Wolters Kluwer, Thomson Reuters CoCounsel Tax).
- EY's survey says respondents automate or partly automate responses to tax authority enquiries (vendor-published).
- The practitioner verifies numbers, deadline and substantiation and signs as the owner of the position.

Evidence: Wolters Kluwer, Thomson Reuters, Blue J, EY · tax-controversy-02

Weekly IRS transcript checks to act before underreporter notices arrive

Grade B · Augment

Problem. The IRS underreporter flag appears on an account transcript before the CP2000 letter, but few practitioners check transcripts, so clients are surprised and penalties and interest accrue.

Approach

- A practitioner pulls account transcripts for about 700 clients weekly with third-party software, which highlights transcripts carrying the underreporting flag.
- He compares the return with IRS wage and income data, amends if needed, and can tell the IRS the error was self-discovered.
- 700 clients monitored weekly; he says this avoids penalties and interest (self-reported). The professional decides whether to amend.

Evidence: One US practitioner (self-reported) · tax-controversy-03

Pre-filing review that reconciles returns to third-party data and flags audit risks

Grade C · Augment

Problem. IRS data matching flags mismatches between returns and third-party reports, so a technically correct return can still draw a notice if numbers do not visibly reconcile.

Approach

- Before sign-off, AI reviews a return 'as though it were a partner-level signer' (Wolters Kluwer), listing risks and a must-fix list.
- Practitioner commentary recommends reconciliation checklists, documented review trails and written business purpose; no outcome published for any tool.
- The reviewer investigates each flagged item, decides what substantiation to request and signs the return.

Evidence: Wolters Kluwer, PwC (via NYSSCPA) · tax-controversy-04

Checking transfer pricing files against public data to anticipate challenge

Grade C · Augment

Problem. Authorities use technology to review documentation, and inconsistencies between transfer pricing files and public data can invite challenge.

Approach

- EY describes TP Doc Insights, a GenAI tool that finds discrepancies between existing documentation and public data (vendor-published; announced).
- KPMG says GenAI can help in transfer pricing controversy by reviewing historical documents and formulating responses.
- Transfer pricing professionals review flagged discrepancies. No outcome published.

Evidence: EY, KPMG · tax-controversy-05

In-house tax teams summarise legislation and dispute files with AI

Grade C · Assist

Problem. Controversy teams hold large volumes of internal opinions and memos, must track proposed legislation, and need data given to different authorities to be consistent.

Approach

- EY's survey says respondents use or expect to use GenAI to summarise tax information and make data shared with authorities consistent.
- 39% built a tax risk or controversy pilot or tool (vendor-published survey); 46% very satisfied versus 31%, in a self-selected sample.
- EY says agentic outputs should be reviewed by humans.

Evidence: EY survey respondents · tax-controversy-06

Agents draft replies to audit queries and track document requests

Grade C · Augment

Problem. During an examination the taxpayer answers a stream of formal records requests under deadlines, while some authorities arrive at audits with transaction data already analysed.

Approach

- EY authors say tax agents can draft responses to audit queries; survey respondents automate or partly automate them.
- A Miller & Chevalier seminar covered AI in tax controversy; EY India announced an AI Tax Hub with litigation agents.
- EY authors: AI should improve the human's review, not remove it. No outcome published.

Evidence: EY, EY India, Miller & Chevalier · tax-controversy-07

AI drafting for Tax Court and IRS filings, with citation checks

Grade C · Assist

Problem. Counsel and self-represented taxpayers use general models to draft filings, but models can invent citations; in Clinco v. Commissioner three of four cited cases were apparently invented.

Approach

- Use is documented mainly through failures; the IRS Office of Professional Responsibility recommends written AI policies and treating AI text as draft.
- Independent counts: about 2,200 decisions worldwide involve hallucinated authorities, 25 tagged tax; one Tax Court judge saw fewer than a dozen.
- The signing practitioner independently verifies facts, authorities, citations and calculations; briefs get a second reviewer or citation log.

Evidence: Tax Court cases, IRS OPR, Journal of Accountancy · tax-controversy-08

Idea: counsel-directed enterprise AI analysis to protect legal privilege

Grade D · Assist

Problem. Idea, not a deployment: in United States v. Heppner (17 Feb 2026) AI reports made with a consumer tool without counsel's direction were held not privileged.

Approach

- Law-firm guidance advises treating public AI tools as third parties, using enterprise tools with limits on training and retention, and logging outputs.
- Miller & Chevalier's Sheri Dillon names AI ethics, privilege and confidentiality as a top 2026 challenge.
- Counsel decides what is run through AI and directs it, documenting that direction.

Evidence: No named deployment · tax-controversy-09

Idea: value-based pricing for AI-speeded controversy work

Grade D · Assist

Problem. Idea, not a deployment: the IRS says billing for manual time not spent may breach Circular 230, and AI savings should be passed on.

Approach

- The AICPA asked the IRS for clarification, saying the guidance does not appear to allow value pricing and overlooks implementation risk.
- No firm is named as having changed its fee basis for controversy work.
- The practitioner decides fee basis and disclosure.

Evidence: No named deployment · tax-controversy-10

Idea: risk-register checks before deploying AI in tax practice (Werfel framework)

Grade D · Assist

Problem. Idea, not a deployment: tax practitioners and administrators do not know which questions to ask to assess AI readiness or vet vendors.

Approach

- Danny Werfel's framework (31 Aug 2026, via the AICPA) gives risk registers for authorities (20) and preparers (15) and an eight-step method.
- The AICPA launched the Council on AI Risk in Tax on 23 Sep 2026 to test and refine it.
- Tier 1 risks must be addressed before launch; human approval of irreversible or financial agent actions is an illustrative control.

Evidence: AICPA, Danny Werfel · tax-controversy-11

Idea: preventive controls and real-time data exchange instead of audit defence

Grade D · Augment

Problem. Idea, not a deployment: Deloitte says real-time, data-driven authorities may mean more granular requests and more audits, making reactive issue management unsustainable.

Approach

- Deloitte says companies would need upstream data quality and preventive controls built into processes; EY says real-time interactions may reduce flash points.
- OECD commissioners agreed in November 2025 to move to pilots of real-time automated information sharing. Both firm pieces are discussion, not deployments.
- Deloitte says human judgment remains instrumental and experts validate AI outputs.

Evidence: Deloitte, EY, OECD forum · tax-controversy-12

IRS machine learning picks returns and issues to examine

Grade B · Augment

Problem. The IRS must choose which returns to examine with too few examiners; older scoring produced many no-change audits, and the first contact is a model-driven selection with undisclosed reasons.

Approach

- The IRS added machine learning to return and issue selection, including a Line Anomaly Recommender and a Form 1040 issue-suggesting model.
- TIGTA found the IRS lacks sufficient processes to evaluate whether the models beat prior processes (independent).
- Human classifiers review recommender output before returns go to the field; examiners can add or remove suggested issues.

Evidence: IRS, TIGTA, National Taxpayer Advocate · tax-controversy-13

Idea: feedback, drift and fairness testing for audit-selection models

Grade D · Augment

Problem. Idea, not a deployment: selection models are not routinely tuned on exam results, and researchers estimated Black taxpayers were audited at 2.9 to 4.7 times the rate of others.

Approach

- Compare model-suggested issues with those examiners pursued, track no-change rates and drift, and test models against group outcomes; no implementation is published.
- GAO-reported gaps: 4 of 5 high-impact IRS AI uses lacked testing documentation; 2 of 5 lacked an impact assessment (independent).
- TIGTA recommended exam results feed model monitoring; the IRS agreed, subject to staffing and Treasury guidance.

Evidence: No named deployment · tax-controversy-14

AI risk targeting for audits at other tax authorities

Grade A · Augment

Problem. Authorities need to find inaccuracies and fraud across huge return populations with limited audit staff, and taxpayers face selection by models with unpublished criteria.

Approach

- HMRC says AI and analytics highlight possibly inaccurate returns; Austria has used machine-learning risk models since 2014; California since 2021.
- HMRC reports GBP 10 billion protected or recovered in 2025-26 (self-reported); Austria reports about EUR 185 million additional revenue (self-reported).
- HMRC says skilled caseworkers make final decisions; Austrian flagged cases go to staff.

Evidence: HMRC, Austria, Hungary, California, South Carolina · tax-controversy-15

IRS AI fraud and identity-theft screening that pauses refunds

Grade B · Automate

Problem. Refund fraud and identity theft at scale cannot be screened by hand, but a held refund creates a taxpayer problem ending in calls and verification.

Approach

- IRS models score returns for risk; GAO found two uses automating decisions, including pausing refunds that look like identity theft.
- After a pause, an employee reviews the risk factors and decides whether to release the refund.
- GAO counted 18 of 43 use cases operational (independent); it did not measure detection accuracy.

Evidence: IRS, GAO · tax-controversy-16

AI and automation speed IRS amended-return processing

Grade B · Automate

Problem. The IRS receives about 5 million amended returns a year, and backlogs push taxpayers into correspondence, calls and disputes.

Approach

- The IRS CIO told employees AI is speeding processing of hundreds of thousands of amended returns; the method is not described.
- Processing time fell from 12, 14 or 16 weeks to under three days (self-reported).
- Human checkpoints are not described in the source.

Evidence: IRS · tax-controversy-17

Voice and chat bots answering taxpayer calls, questions and payment plans

Grade A · Automate

Problem. Phone demand at the IRS far exceeds live-assistor capacity, and with staffing about 25% lower the IRS expects to rely more on technology.

Approach

- The IRS runs chatbots and voicebots for tax questions and payment plans; its June 2025 inventory lists 11 voicebots and two chatbots.
- Filing season 2026: 17% completed in the voicebot, about 46% transferred to an assistor (independent); sessions reached nearly 25 million (self-reported).
- Callers can ask for a live assistor; over 85% who chose a callback reached one.

Evidence: IRS, National Taxpayer Advocate · tax-controversy-18

Real-time prompts asking taxpayers to check unusual entries (Australia)

Grade A · Augment

Problem. Errors found after lodgment become reviews, notices, amendments and disputes; catching them at filing is cheaper for both sides.

Approach

- ATO models in myTax compare entered amounts with similar taxpayers or prior years and prompt the taxpayer to check specific items.
- More than 636,000 prompts, protecting about AUD 78.9 million (2023-24) (self-reported).
- The taxpayer decides what to amend; the ATO says decisions adversely affecting rights are made by a human.

Evidence: Australian Taxation Office · tax-controversy-19

AI assistants for tax-authority service staff

Grade B · Augment

Problem. Authority phone staff must find the right guidance while a caller waits, and wrong or slow answers feed later notices and disputes.

Approach

- The IRS rolled out Archie for researching the Internal Revenue Manual; California's CDTFA launched a GenAI answer-drafting tool on 22 August 2025.
- HMRC is piloting AI call summaries for human review; France uses AI to draft replies that staff validate.
- HMRC reports over 28,000 Copilot licences by March 2026 (self-reported). The representative or agent decides what to use.

Evidence: IRS, California CDTFA, HMRC, France · tax-controversy-20

Examiner and caseworker assistants that sort evidence and draft documents

Grade B · Augment

Problem. Auditors and caseworkers must sort large volumes of receipts, invoices and case documents and draft routine requests and reports, with fewer staff.

Approach

- The ATO built AI that matches substantiation documents to claims and orders them for auditors; HMRC is trialling Copilot for caseworkers.
- ATO says the assistant saves time and makes claims easier to assess (self-reported; no figure).
- ATO auditors decide deduction validity; IRS agents reportedly review drafts (EisnerAmper, unconfirmed by IRS); TAS staff verify AI content.

Evidence: ATO, HMRC, IRS, Taxpayer Advocate Service · tax-controversy-21

AI agents for case summaries and search in IRS legal units

Grade C · Augment

Problem. Chief Counsel, Appeals and the Taxpayer Advocate handle document-heavy cases with reduced staff; the IRS workforce fell by about 25% in 2025.

Approach

- Salesforce said Agentforce would be used across the Office of Chief Counsel, TAS and Appeals for case summaries and search (announced).
- The vendor says the agents cannot make final decisions or disburse funds; the stated aim is faster case completion (vendor-published).
- Staff make the decisions.

Evidence: Salesforce, IRS · tax-controversy-22

Machine-learning grouping and routing of tax-appeal files (Brazil)

Grade B · Augment

Problem. Brazil had around USD 140 billion in assessed taxes awaiting administrative appeal decisions, and an appeal ruling took about six years.

Approach

- Under the AI Litigation Project, supervised machine learning groups similar appeal files so they go to the same officers.
- First trials showed over 80% sensitivity and specificity (self-reported; a model accuracy measure, not a speed outcome).
- Appeal officers handle files and rulings, and label files to improve later suggestions.

Evidence: Brazil tax authority · tax-controversy-23

Announced agentic case management for tax-authority casework

Grade C · Delegate

Problem. Case work is information-heavy, and isolated experiments risk duplication and weak assurance; HMRC aims for at least 90% digital interactions by 2030.

Approach

- The ATO prioritised seven enterprise AI use cases, including case profiling assistants, triage of taxpayer requests and drafting position papers (announced).
- HMRC's roadmap, as summarised by ICAS, names agentic AI for case management and plans generative AI to summarise case documents.
- ATO says decisions remain with people and drafts stay subject to human review. No outcome published.

Evidence: ATO, HMRC · tax-controversy-24

Idea: AI reasoning to detect and analyse abusive tax strategies

Grade D · Assist

Problem. Idea, not a deployment: well-advised taxpayers design tax-minimisation strategies that are hard for authorities to find and analyse across statutes, case law and guidance.

Approach

- Researchers tested advanced LLMs on interpreting, verifying and generating tax strategies, and report LLM reasoning found an apparently novel strategy (independent).
- A paper with overlapping authors pairs LLMs with a symbolic solver to improve auditability.
- Human checkpoints are not described; this is an academic experiment.

Evidence: No named deployment · tax-controversy-25

Research and advisory

Research, memos, written advice, planning and M&A tax diligence; firm and in-house buyers. · 25 use cases · evidence moderate (11 of 25 A/B)

Cited conversational tax research in place of keyword database search

Grade B · Augment

Problem. Advisers pay for research databases but find them slow, and general chatbots return confident citations that may not exist.

Approach

- The adviser asks in plain language and gets an answer citing primary authority from a curated set (Blue J, Accordance, CoCounsel Tax).
- A 25-person firm reports research falling from 1 hour to 10 minutes (vendor-published); Blue J says user disagreement is below 0.2% (vendor-published).
- The adviser reads each cited authority before relying on it; a manager or partner tests the reasoning.

Evidence: Blue J, Accordance, CoCounsel, RSM US, others · tax-research-advisory-01

Multi-step research plans for gray-area tax questions

Grade B · Augment

Problem. Hard gray-area questions took hours across several databases, and applying findings to a client's situation still took substantial manual effort.

Approach

- The tool works in steps: extract facts, frame issues, locate authority, weigh relevance, recommend; Accordance, Bloomberg Tax and Thomson Reuters offer versions.
- A CPA at a 100-professional firm says research taking 2-6 hours takes 15-20 minutes (vendor-published).
- A senior researcher checks the plan, conclusions and authority; a partner reviews before advice goes to the client.

Evidence: Accordance, Bloomberg Tax, Thomson Reuters · tax-research-advisory-02

Research agent works a tax question end to end with cited answer

Grade C · Delegate

Problem. Corporate tax research needs several chained lookups, and an early error in a threshold, date or citation carries through to the answer.

Approach

- An agent with lookup, search and calculator tools researches over many steps and submits a cited answer; EY India announced research agents.
- Vals AI's independent benchmark top score was 49.19% (independent; models run in Vals harness, not a firm deployment).
- A qualified adviser reviews the memo and every authority; scope phases from summarisation to position drafting only after verification.

Evidence: Vals AI, EY India · tax-research-advisory-03

Idea: specialist multi-state and multi-country tax research workflow

Grade D · Augment

Problem. Idea, not a deployment: multi-jurisdiction questions, such as 50-state surveys, are where tools do worst and manual work is longest.

Approach

- Idea: a purpose-built workflow searches each jurisdiction's primary law and compiles a comparison table for adviser review.
- Vals suggests a specialist workflow should beat basic prompts; an adjacent legal study found AI scored 14 points lower on multi-jurisdiction questions.
- The adviser verifies each jurisdiction's result against primary law.

Evidence: No named deployment · tax-research-advisory-04

Knowledge assistant over a firm's own memos, precedents and guidance

Grade C · Assist

Problem. Institutional tax knowledge sits in senior practitioners' heads and scattered memos; vendors say it is lost as seniors retire and quality varies.

Approach

- An assistant answers from the organisation's own memo library and policies alongside licensed content so staff reuse prior positions consistently.
- Thomson Reuters markets CoCounsel Tax for in-house teams with a Knowledge Base; KPMG's knowledge management leader joined a panel. No outcomes.
- The reviewer confirms a retrieved precedent still reflects current law and fits the client's facts.

Evidence: Thomson Reuters, KPMG · tax-research-advisory-05

In-house tax teams triage technical questions with licensed and enterprise AI

Grade C · Assist

Problem. Corporate tax teams answer ad hoc technical questions with limited staff; Thomson Reuters' 2025 survey found 58% of departments under-resourced.

Approach

- In KPMG Germany's quick surveys, 89% use company-wide AI solutions and 29% specialised tax applications (base not stated).
- TEI's preliminary Midyear 2026 programme scheduled labs on AI tax research with Thomson Reuters CoCounsel and Accordance.
- Tax director reviews AI-assisted conclusions before they go to the CFO, auditors or authorities.

Evidence: KPMG Germany, Thomson Reuters, TEI · tax-research-advisory-06

Firm-wide standard on approved research assistants with a named tax AI owner

Grade B · Augment

Problem. Staff use general chatbots for tax questions whether or not approved, and large firms have uneven tools and no central control over what is pasted into AI.

Approach

- Crowe signed an enterprise agreement for Ask Blue J and has a Tax AI Leader; KPMG US M&A Tax built its own.
- PwC has a US AI Tax Leader, a governance committee, over 3,200 AI champions, 800 custom GPTs and 250 agents (self-reported).
- The managing partner or tax leader approves tools and keeps the approved list; human review applies at each level.

Evidence: Crowe, KPMG US, PwC, Wright Ford Young · tax-research-advisory-07

AI-supported research training and coaching for junior staff

Grade B · Assist

Problem. Junior staff lack the background to navigate legacy research tools, and seniors act as informal research trainers.

Approach

- Firms use the cited research assistant as a tutor; Jansen & Company's senior managing director says he uses AI as a tutor.
- Sasserath & Co. says younger staff avoided unlearning legacy methods; Finney Neill says less experienced staff could not reach answers before.
- A supervisor reviews juniors' research and reasoning, not only the answer.

Evidence: Jansen & Company, Sasserath & Co., Finney Neill · tax-research-advisory-08

Reusable planning blueprints turning client data into a decision matrix

Grade B · Augment

Problem. An S-corporation election analysis for a sole proprietor was about a 10-hour project, and research on the firm's old platform limited proactive client service.

Approach

- The firm builds a standard process (a blueprint) that takes client financials, researches the rules and produces a decision matrix.
- A tax shareholder says a 10-hour project becomes roughly two to two and a half hours (vendor-published).
- The tax shareholder reviews the matrix and localised assumptions before it goes to the client.

Evidence: Finney Neill, Accordance · tax-research-advisory-09

Idea: AI planning-alternative ideation and anti-abuse screening of structures

Grade D · Assist

Problem. Idea, not a deployment: finding and testing planning alternatives across a large body of authority is slow and depends on a few senior people.

Approach

- Idea: a model proposes or completes planning strategies and probes them against authority; the adviser decides whether any is supportable.
- Blair-Stanek and colleagues report LLM reasoning identified an apparently novel strategy (independent; no rate or count). No adviser-use result published.
- A senior adviser tests every AI-proposed structure against economic substance and professional standards.

Evidence: No named deployment · tax-research-advisory-10

Idea: AI challenges a tax position by arguing the other side

Grade D · Assist

Problem. Idea, not a deployment: positions are often tested only by the author and one reviewer, and a single tool's confident answer can be wrong.

Approach

- Idea: the adviser asks a model to argue the opposite, list what an IRS examiner would flag, or cross-checks a second tool.
- Disagreement between tools triggers a deeper human check; CPA Practice Advisor's playbook suggests similar prompts for clients.
- The adviser decides which objections are credible, checks material points against primary authority and updates the memo.

Evidence: No named deployment · tax-research-advisory-11

Auditable tax computation: AI translates rules, a calculation engine does the arithmetic

Grade C · Augment

Problem. Advice often turns on a computation, and language models alone get these wrong in ways that are hard to see.

Approach

- The model translates rules or facts into formal logic or inputs for a solver or tax engine; the logic trace is kept.
- Johns Hopkins researchers tested this on a statutory reasoning dataset; best model computing 2024 returns scored 32.35% strict, 51.96% lenient (vendor-published).
- The adviser reviews inputs, assumptions and the explanation of the calculation.

Evidence: Johns Hopkins researchers, Column Tax · tax-research-advisory-12

Document-grounded tax analysis of agreements, trusts and schedules

Grade B · Augment

Problem. Advisers read long operating agreements, trust and will documents and supporting schedules by hand before they can apply the tax rules.

Approach

- The adviser uploads a document; the tool summarises it and checks authority. Wright Ford Young uses it to review operating agreements.
- Jansen & Company says it wants to analyse trust and will documents; Thomson Reuters describes schedule uploads. No outcomes published.
- The adviser checks the summary against the source document before relying on it.

Evidence: Wright Ford Young, Jansen & Company, Thomson Reuters · tax-research-advisory-13

Drafting technical memos, advice letters and client emails from researched authority

Grade B · Augment

Problem. Writing the memo, advice letter or client explanation after research takes days of associate time, delays the response and varies between staff.

Approach

- The tool turns facts and authorities into a first draft the adviser edits and owns; Larson Gross uses Blue J.
- KPMG describes a Writing Review Assistant; Lowy says output resembles an average junior associate's, useful for drafts but not ready to send.
- A named adviser edits, verifies every cited authority and approves each client-facing draft; opinion-level documents get a second reviewer.

Evidence: Blue J, Larson Gross, KPMG, Nelson Mullins · tax-research-advisory-14

Idea: AI support for tax opinions and in-house preliminary positions

Grade D · Assist

Problem. Idea, not a deployment: written advice must rest on reasonable assumptions, and corporates often wait for an expensive Big Four or law-firm opinion.

Approach

- Idea: AI assembles authorities, maps them to facts and drafts the analysis; a person decides the conclusion and signs.
- Kilpatrick Townsend says AI can help produce an opinion letter if the practitioner verifies analysis and replaces fabricated authorities.
- The signing professional owns the conclusion; opinion committee or second-partner review still applies.

Evidence: No named deployment · tax-research-advisory-15

Answering client questions during the call instead of calling back

Grade B · Assist

Problem. Complex client questions meant saying 'we'll do some research and call you back', because research could consume most of a workday.

Approach

- With a cited research assistant open, the adviser looks up and tests an answer while the client is on the line.
- A Barnes Wendling director says the team can now get answers on a phone call; 700+ queries per month tracked firm-wide (vendor-published).
- The adviser decides what can be said live and what needs follow-up review.

Evidence: Barnes Wendling, Accordance · tax-research-advisory-16

Idea: client-facing tax question assistant that escalates to an adviser

Grade D · Augment

Problem. Idea, not a deployment: clients and self-preparers ask routine tax questions that consume adviser time, and many already ask general chatbots.

Approach

- Idea: a chatbot answers routine questions from the firm's approved content and routes nuanced or high-stakes ones to an adviser.
- HMRC's guidelines for tax software using generative AI ask for flags on nuanced rules; no firm-deployed assistant outcome published.
- Fact-dependent or advice-level questions escalate to a qualified adviser.

Evidence: No named deployment · tax-research-advisory-17

Idea: triage of AI-generated tax answers and citations that others bring

Grade D · Augment

Problem. Idea, not a deployment: clients ask a chatbot first, and counterparties send positions and citations that may be AI-generated and wrong.

Approach

- Idea: run incoming material through the citation checks used on the firm's own work, and counsel clients to ask AI for sources.
- In Clinco the IRS flagged the nonexistent cases; in Harber the tribunal and HMRC found nine cited decisions did not exist.
- The adviser reviews flagged material and its sources before adopting any position or responding.

Evidence: No named deployment · tax-research-advisory-18

Citation verification and an AI-use record as a standing review step

Grade B · Assist

Problem. AI can produce plausible but nonexistent authority; in Clinco three of four cited cases were described as probable AI hallucinations.

Approach

- Reviewers confirm every cited authority exists and supports the claim, and the file records prompt, output, citations, verification and reviewer.
- KPMG US M&A Tax uses citations and hyperlinks to validate all AI outputs; Aon and Wolters Kluwer advise similar records.
- 2,199 decisions worldwide address hallucinated content (independent, 16 Oct 2026). A second reviewer cross-checks; the responsible partner signs off.

Evidence: KPMG US, Aon adviser, Wolters Kluwer, Tax Court · tax-research-advisory-19

Automated check that every cited authority exists and supports the point

Grade C · Automate

Problem. Fabricated or misdescribed citations reach client memos and court filings, and manual cite-checking of every authority is slow.

Approach

- A checker resolves every citation in a draft against authoritative sources and flags those that do not exist or support the point.
- Damien Charlotin, who runs a hallucination-decisions database, offers an automated reference checker (PelAIkan); no tax error rates published (announced).
- A person clears every flagged citation and reads the authorities that carry the argument.

Evidence: Damien Charlotin (PelAIkan), Vals AI · tax-research-advisory-20

M&A tax diligence: AI review of purchase agreements and a first-draft report

Grade B · Augment

Problem. Transaction tax teams read long purchase agreements, research deal rules and write diligence reports under deadlines, leaving less time for structuring and hidden-risk analysis.

Approach

- KPMG US M&A Tax describes four GenAI tools: research, agreement review against baselines, draft diligence reporting and a writing review assistant.
- KPMG's web page says the firm is compressing weeks of tax analysis into minutes (self-reported).
- Professionals add their own assessments and validate output against source documents; a senior reviewer signs the report.

Evidence: KPMG US, a Hungarian advisory firm · tax-research-advisory-21

Diligence agent reads data room and drafts cited tax risk assessment

Grade C · Delegate

Problem. Tax diligence over entity structures, intercompany agreements and filings takes weeks of document analysis across entities and jurisdictions.

Approach

- V7 markets an agent that ingests financial statements, returns and agreements, maps entities, flags permanent establishment issues and returns a cited assessment.
- V7's demo project compares 3-4 weeks to 2-3 days, 'average time saved 90%' (vendor-published).
- The deal tax lead reviews the assessment before it informs price, structure or counterparty discussions.

Evidence: V7 (vendor) · tax-research-advisory-22

Law-change monitoring that drafts client impact notes for adviser review

Grade C · Delegate

Problem. After major legislation advisers must track guidance across jurisdictions and explain the effect to each client, which is repetitive and urgent.

Approach

- A monitoring agent watches new law and drafts client impact notes. KPMG US says building one went from weeks to minutes (self-reported).
- Bloomberg Tax describes an AI Assistant in its Compliance Tracker; best model scored 66.67% on an independent law-change benchmark category (a proxy).
- The adviser confirms each flagged change and its client impact before anything reaches the client.

Evidence: KPMG US, Anthropic, Bloomberg Tax · tax-research-advisory-23

Advisers co-build client-specific tax agents with clients on firm platforms

Grade C · Delegate

Problem. KPMG's US tax vice chair says building an agent to help clients adjust to changing tax regulations used to take weeks and several tools.

Approach

- KPMG's Digital Gateway Powered by Claude, announced 20 May 2026, lets professionals and clients build agentic workflows, starting with tax.
- EY announced EY.ai Tax Labs and the Tax Agent Factory (25 Nov 2025) to build and manage agents with clients.
- KPMG US says weeks became minutes (self-reported). Human checkpoints are not described in the sources.

Evidence: KPMG US, Anthropic, EY · tax-research-advisory-24

Value-based and fixed-fee pricing as AI shortens research and drafting

Grade B · Assist

Problem. Hourly billing ties revenue to time AI removes, and the IRS says billing for manual time not actually spent may violate the fee rule.

Approach

- Firms test fixed, hybrid or value-based fees; Sasserath & Co. moved onboarding to fixed monthly fees. A pricing change, not AI workflow.
- RKL is piloting an alternative model and reports several dozen clients onboarded under it (self-reported).
- The engagement partner sets the fee basis and reviews billing against actual work and the IRS fee rule.

Evidence: Sasserath & Co., RKL, RSM US, PwC · tax-research-advisory-25

Tax data and technology

In-house tax data layer, automation and its sustainment, real-time reporting interfaces, MCP access, the tax technology team. · 24 use cases · evidence moderate (8 of 24 A/B)

Tax-owned data layer joining ERP and ledger data into one reconciled source

Grade B · Augment

Problem. Tax teams sit downstream of finance systems and often get aggregated data stripped of detail; EY's survey found 51% of tax and finance functions early in data maturity.

Approach

- Tax owns or co-owns a central store fed from several systems, with documented lineage and reconciliations; Snowflake, Fortive and Apple advertise roles.
- Deloitte Tax and Databricks announced an alliance on 2025-10-08 to build a unified tax data architecture. No outcomes published.
- Tax staff review reconciliations, IT and tax agree ERP changes, and tax leadership signs off data requirements for new business lines.

Evidence: Snowflake, Fortive, Apple, OpenAI, Deloitte · tax-data-technology-01

Agentic layer that assembles, maps and checks ledger data before tax engines

Grade C · Augment

Problem. Commentators argue data assembly and reconciliation, not tax calculation, is the binding constraint; EY says tax staff spend 53% of time on routine activities.

Approach

- An agentic layer pulls ledger data, maps accounts to tax categories, validates it, flags anomalies for a person and passes it on.
- Kognitos positions its product this way; Thomson Reuters says its goal for ONESOURCE direct tax is agentic data import, validation and mapping.
- A person reviews every flagged exception, and tax professionals keep oversight of mapped data. No outcomes published.

Evidence: Kognitos, Thomson Reuters, Deloitte, Savant · tax-data-technology-02

Agent keeps tax-engine settings in sync with ERP master-data changes

Grade C · Augment

Problem. New entities, registrations, locations and products set up in the ERP must be duplicated in the tax engine, and manual maintenance causes mismatches and delays.

Approach

- Vertex Configuration Agent for Microsoft Dynamics 365 monitors master-data changes and triggers matching updates in the Vertex tax engine.
- Vertex says it was built with Azure AI Foundry and Copilot Studio; Avalara describes a browser agent guiding ERP configuration.
- The tax team validates high-impact configuration changes before they reach the engine. No outcome figures published.

Evidence: Vertex, Avalara · tax-data-technology-03

Building tax data and tax engine into ERP migration from the start

Grade B · Assist

Problem. Tax determination is often overlooked until late in an ERP project, causing delays and workarounds; one participant managed tax across 40 separate billing systems.

Approach

- Put a tax expert on the migration team, clean data before it moves, and integrate the tax engine natively.
- At Vertex Exchange Europe 2026, Siemens Energy and Daimler Truck AG described implementing the Vertex tax engine in SAP.
- Roundtable participants used AI for contract review and anomaly detection, warning it needs clean data. A tax expert sits on the team.

Evidence: Siemens Energy, Daimler Truck, Vertex · tax-data-technology-04

Low-code tax data preparation, the pre-generative-AI baseline

Grade B · Automate

Problem. Large tax departments gather data from scattered sources by hand before provision and return work can begin; at one telecom client 200-plus tax managers worked above capacity.

Approach

- Not generative AI: Alteryx and Microsoft Power Query consolidate and reconcile data and feed tax engines; DuPont combined Alteryx with ONESOURCE.
- RGP reports 1,100+ hours removed at an automotive client; Concentrix reports 500+ hours a year saved at a telecom client (vendor-published).
- Concentrix says any reviewer can verify the visual workflows; no review step is described.

Evidence: DuPont, RGP, Concentrix, Alteryx · tax-data-technology-05

Plain-language tax analytics and reusable tax agents over a semantic layer

Grade B · Augment

Problem. Tax analysts work in spreadsheets and filings, and refreshing dashboards by hand takes time that could go to analysis and exception handling.

Approach

- Snowflake's tax analytics team says it replaced traditional dashboards with AI agents, semantic models for plain-English queries, and Streamlit apps.
- The posting asks for verified-query coverage and accuracy iteration based on evaluation metrics. No outcomes published.
- The builder validates the output; tax leadership receives summaries and owns exception handling.

Evidence: Snowflake · tax-data-technology-06

Tax analysts build pipelines and tools with AI coding, under controls

Grade C · Assist

Problem. Data integrations tax needs can wait months in an IT queue, and building them fast lets an analyst deploy something nobody has reviewed or documented.

Approach

- Tax analysts use AI coding and low-code agent tools to build pipelines and apps; four OpenAI tax staff demonstrated pipelines at TEI.
- The recap author describes about 15 minutes versus about two months in an IT queue (self-reported, anecdotal).
- Any pipeline is reviewed and documented before it is relied on; the recap names unreviewed pipelines as the failure mode.

Evidence: OpenAI, RSM, Grant Thornton, EY · tax-data-technology-07

Tax automations run as controlled assets with sign-off, logs and drift monitoring

Grade B · Augment

Problem. Under SOX, tax teams must document what an automated process ran, when it changed and who approved it, but most workflow tools lack native run history.

Approach

- Savant's Spring 2026 release added version control, a sign-off step enforcing segregation of duties, and evidence logs with SOX report templates.
- Oxford Industries' senior director of tax and accounting is quoted saying Savant provided the governance controls and audit documentation needed.
- A control owner approves before go-live, exceptions go to human review, and drift signals trigger accuracy evaluations.

Evidence: Savant, Oxford Industries, Deloitte · tax-data-technology-08

Scheduled multi-system tax reconciliation with exceptions sent to staff

Grade B · Automate

Problem. Month-end sales tax reconciliation between source transactions, tax-engine output and returns is done in manual spreadsheets.

Approach

- Rover, a pet-care marketplace, rebuilt its monthly reconciliation in Savant: it pulls data including Avalara, matches transactions and produces audit-ready outputs.
- Rover cut month-end close time 80% and data handling costs 50% (vendor-published).
- Human checkpoints are not described for Rover; Savant says exceptions can be routed for human review.

Evidence: Rover, Savant · tax-data-technology-09

Idea: multi-agent workflows from provision to return, people handling exceptions

Grade D · Delegate

Problem. Idea, not a deployment: a TEI-SJSU panel deck says without an orchestration layer AI cannot move from demo to production, and fragmented data leaves tools isolated.

Approach

- The panel deck (RSM, Grant Thornton, EY, OpenAI speakers) places multi-agent tax workflows at the top of a four-step progression.
- Its examples include provision-to-return automation, R&D credit scanning and state apportionment data ingestion.
- Humans are reserved for exceptions.

Evidence: No named deployment · tax-data-technology-10

AI extraction of tax notices and documents into structured data, independently verified

Grade C · Augment

Problem. State tax notices never arrive in the same format twice, and incorrect document extraction creates errors that flow silently into a return.

Approach

- TEI attendees reported using AI image-to-text tools on state notices; EY describes AI that summarises a notice and drafts a response.
- Savant's Spring 2026 release has over ten prebuilt extraction skills; Avalara's Outlook agent scans inbound invoices and validates them.
- Extracted figures are independently verified against source documents, with escalation for complex cases. No error rate published.

Evidence: Savant, Avalara, EY, TEI attendees · tax-data-technology-11

Transaction-level real-time reporting to tax authorities replaces periodic returns

Grade C · Automate

Problem. Periodic returns give authorities data weeks after the transaction; more than 60 jurisdictions have moved or are moving to continuous transaction controls.

Approach

- Companies send invoice data to the authority as it is created and build around it; the EU adopted ViDA on 2025-03-11.
- Commission projects up to EUR 11 billion a year less VAT fraud (independent; unmeasured); a Peru study found over 5% higher reports.
- Human checkpoints are not described for in-house teams.

Evidence: European Commission, OECD forum, UK government · tax-data-technology-12

Invoice and master data validated before submission, with preventive controls

Grade C · Automate

Problem. In clearance regimes an invoice has no legal force until the authority returns its identifier, so a wrong VAT ID or schema gets it rejected.

Approach

- Tax, finance and IT run a validation layer over ERP invoice data, checking identifiers, schema and master data, with an exception queue.
- TEI attendees described validation agents critiquing their own outputs, without naming a company or saying they target outbound invoices.
- Sources describe no human checkpoint; only 22% of respondents have a formal ViDA transition programme (vendor-published baseline).

Evidence: No named deployment · tax-data-technology-13

AI mapping of ERP data to e-invoicing formats, with fixes after approval

Grade C · Augment

Problem. A wrong VAT ID or mismatched master data means a clearance-regime invoice is rejected, the shipment waits and the buyer does not pay.

Approach

- Avalara says it uses AI to map invoice fields to country requirements; Sovos describes AI that diagnoses and fixes errors once approved.
- Sovos reports a 1.6% invoice rejection rate in live French production versus an estimated 20% market-wide (vendor-published; AI share unstated).
- User approval is required before a correction is executed.

Evidence: Avalara, Sovos, Roedl · tax-data-technology-14

Agent assesses rule changes and errors against tax configuration, fixing after approval

Grade C · Augment

Problem. Rule and format changes must be mapped to each company's entities and settings, and fixing configuration errors depends on support tickets and hand-offs.

Approach

- Sovos announced (March 2026) Sovi AI diagnosing compliance errors, proposing fixes and executing corrections once approved, plus regulatory intelligence on configuration impact.
- EY's author describes agents that monitor rule changes and route exceptions; the text says EY's platform aims to work this way.
- Corrections run only after user approval; exceptions are routed for review. No outcomes published.

Evidence: Sovos, Avalara, EY · tax-data-technology-15

Idea: continuous reconciliation of calculated, invoiced, reported and authority data

Grade D · Automate

Problem. Idea, not a deployment: where authorities hold structured transaction data, indirect tax teams must show what was calculated is what was invoiced and reported.

Approach

- Reconcile every transaction across calculation, invoice, report and authority record continuously, toward continuous audit controls discussed at Vertex Exchange Europe 2026.
- Deloitte's scenario describes a digital tax analyst agent that cross-checks invoice data and routes exceptions to reviewers.
- Exceptions go to the appropriate human reviewer.

Evidence: Deloitte, Vertex Exchange (discussion) · tax-data-technology-16

Read-only access lets general AI assistants answer from company tax-compliance data

Grade C · Assist

Problem. Staff must log in to a compliance portal to see nexus, filings and registrations, and generic assistants answer from general knowledge, not company numbers.

Approach

- Kintsugi's MCP server gives Claude or ChatGPT read-only access to nexus, filings and registrations; Avalara and Anrok describe similar servers.
- Anrok says its server can also take actions, under scoped OAuth credentials. No outcomes published.
- Kintsugi's assistant answers questions only; filings remain checked by the vendor's experts.

Evidence: Kintsugi, Avalara, Anrok · tax-data-technology-17

Company agents call tax engines through vendor servers, limited scopes, logged

Grade C · Delegate

Problem. Each AI model and tax system needs custom integration, and calling a tax engine from an agent raises questions of authorisation, identity and logging.

Approach

- Avalara says it ships MCP servers for AvaTax, returns and e-invoicing; an example agent validates a vendor invoice and files use tax.
- Sovos is developing an MCP gateway; Vertex's Dynamics 365 agent and PwC's Agent OS use MCP. No named customer outcomes.
- Users consent to permissions and consents are audited; Vertex keeps review checkpoints for high-impact changes.

Evidence: Avalara, Sovos, Vertex, PwC, Anrok · tax-data-technology-18

Decision log and audit trail for AI-assisted tax determinations and approvals

Grade C · Augment

Problem. Fonoa's 2026 survey of 176 indirect tax leaders found 57.4% would not be confident defending AI-assisted decisions to a tax authority.

Approach

- Record which AI outputs affected filings, the inputs used, and which suggestions were accepted, modified or rejected, as work happens.
- Fonoa markets an Audit product claiming audit-ready 'in minutes, not weeks' (vendor claim, no sample); Sovos says every approval is documented.
- Formal human review of AI output before it informs a decision, with named owners and documented sign-off.

Evidence: Fonoa, Sovos, AICPA, Thomson Reuters · tax-data-technology-19

Tax-owned AI and automation inventory, policy and accountability

Grade C · Assist

Problem. When TEI seminar attendees were asked whether tax owns AI implementation, two hands went up out of more than 50.

Approach

- Tax keeps a live inventory of AI and automation use cases with owners and escalation paths, a written policy and control mapping.
- COSO's February 2026 guidance sets a six-step roadmap: govern, inventory, assess, design, implement, monitor.
- Each inventoried use case has named ownership and escalation paths. In one report, 45% of tax departments had no relevant policy.

Evidence: COSO guidance, TEI, Thomson Reuters · tax-data-technology-20

Acceptance thresholds before go-live, then tracking accuracy and override rates

Grade C · Augment

Problem. Tax functions are told to adopt AI but not what good looks like: only 12.5% of Fonoa's respondents had specific AI targets or KPIs.

Approach

- Tax sets acceptance thresholds before go-live and monitors accuracy, override rates and cycle time afterwards.
- In Deloitte's survey, 77% of tax leaders required 90% or higher accuracy before entrusting AI with tax processes (vendor-published).
- Formal human review of AI outputs before they inform tax decisions, run by about a third of Fonoa's respondents.

Evidence: Fonoa, Deloitte, COSO commentary · tax-data-technology-21

AI-first in-house tax model where staff build and review database-driven workflows

Grade B · Augment

Problem. OpenAI's postings describe moving recurring income tax work off spreadsheet preparation and trackers, and making handoffs and documentation easier to review.

Approach

- OpenAI's tax postings describe an AI-first model where preparation is automated in database-driven workflows and staff review, validate and build.
- The team wants a leader who defines when AI can safely speed work and when human review is needed. No outcomes published.
- First-level review and validation of automated provision outputs and pipelines.

Evidence: OpenAI tax team · tax-data-technology-22

Central tax operations and technology team owning tax data, automation and AI

Grade B · Augment

Problem. In the 2026 Thomson Reuters Institute report, 64% placed their tax department at the chaotic or reactive end of a maturity curve, up from 57%.

Approach

- Set up a central team owning tax technology, data and automation; Unilever Ice Cream's Anna Elphick discussed a centralised tax operations centre.
- A German head of tax told EY of a dedicated AI team for tax; Deloitte advises collaborating with finance and IT.
- Governance framework with named owners, documented sign-off and internal reviews. Reported correlations are not shown to be causal.

Evidence: Unilever Ice Cream, Thomson Reuters, EY · tax-data-technology-23

Tax run as co-sourced or managed service on a provider's AI platforms

Grade C · Delegate

Problem. In-house teams struggle to build their own solutions; 77% wanted their providers to use generative AI, yet 59% were unsure whether their own firms do.

Approach

- Use a third party investing in AI and data tooling, or a managed service; 78% in EY's survey said it would help.
- Deloitte lists a managed service or selective outsourcing as an option; most large Vertex implementations are partner-led.
- The business reviews provider output critically and vets AI vendors on data retention and training terms. 85% reported better focus (vendor-published).

Evidence: EY survey, Deloitte, Thomson Reuters, Vertex · tax-data-technology-24

Security

Protecting systems, data, identities and people, and the AI an organization runs; in-house security teams and security service providers.

Focus area	What it covers	Evidence
Governance, risk and compliance	Customer reviews, vendor risk, control evidence, policy, risk quantification, board reporting, the security team's own AI policy, workforce model.	**strong** 11 of 21 A/B
Security operations	The SOC and MDR: detection engineering, triage, investigation, response actions, measuring the SOC's AI.	**strong** 20 of 24 A/B
Threat intelligence	Intelligence cycle, enrichment, reporting, sharing, threat hunting.	**strong** 14 of 24 A/B
Incident response	Plans, exercises, forensics, containment, recovery, regulatory notices, and incidents caused by AI agents.	**strong** 12 of 22 A/B
Vulnerability and exposure management	Discovery, validation, prioritisation, remediation, disclosure, pentest and red-team services; the 2026 disclosure surge.	**strong** 16 of 25 A/B
Application security	Threat modelling, AI-written code, code review, pipeline scanning, AI fixes, supply-chain intake.	**strong** 15 of 17 A/B
Cloud and infrastructure security	Posture, runtime, Kubernetes, IaC, network and edge, endpoints including machines that run coding agents.	**thin** 5 of 24 A/B
Identity and access	Joiner-mover-leaver, requests and reviews, privileged access, authentication, ITDR, proofing, help-desk and caller fraud.	**moderate** 11 of 24 A/B
Data security and privacy	Discovery, classification, DLP, access governance, keys, privacy engineering, data exposure through AI tools.	**moderate** 8 of 21 A/B
Human risk	Awareness and simulation, reported email, impersonation and deepfakes, hiring verification, insider risk.	**strong** 9 of 18 A/B
AI security	Securing the organization's own AI: red teaming, agent identity and containment, monitoring, AI supply chain, AI incidents, governance.	**strong** 20 of 25 A/B

Governance, risk and compliance

Customer reviews, vendor risk, control evidence, policy, risk quantification, board reporting, the security team's own AI policy, workforce model. · 21 use cases · evidence strong (11 of 21 A/B)

Customer security questionnaires answered from an approved knowledge base

Grade A · Automate

Problem. Customer security reviews arrive as long forms answered by hand from policies and audit reports, so a small GRC team becomes a sales bottleneck.

Approach

- Answers are drafted from approved company documents; only low-confidence or unmatched questions go to an analyst.
- GitHub reports automating 93% of inbound questionnaires in 6 months, against a 12-month goal (vendor-published).
- Carta reports an 83% decrease in review time and 95% AI accuracy (vendor-published); how accuracy was judged is not stated.

Evidence: GitHub, Carta, Calastone · security-governance-risk-01

Self-serve trust centre with an AI agent answering security questions

Grade B · Automate

Problem. Customers repeatedly request the same audit reports and policies, then ask follow-up questions the documents already answer, which Sumo Logic's compliance lead likens to a second full-time job.

Approach

- A trust centre exposes audit reports and policies with automated NDA rules, and an AI agent answers inbound questions from that content.
- Questions the agent cannot answer, and non-standard requests, still reach the security team.
- Synthesia reports 20-30% of customer questions resolved without staff and sales cycles two weeks shorter (vendor-published).

Evidence: Synthesia, Perforce, Sumo Logic · security-governance-risk-02

Agent-drafted vendor security assessments, with an analyst deciding residual risk

Grade B · Delegate

Problem. Each new vendor's SOC 2 report, pen test summary and questionnaire must be read against the buyer's standards; volume outgrows analysts and reviews take weeks.

Approach

- An AI agent collects vendor documents, extracts exceptions and risk signals, drafts an evaluation and prepares follow-up questions.
- An analyst verifies the draft and decides inherent and residual risk; customers can choose between autonomous and in-the-loop operation.
- Samsara reports vendor reviews up to 50% faster (vendor-published); a payments company reports 150 assessments in under 2 weeks (vendor-published).

Evidence: Samsara, Calastone, Drata, Hyperproof · security-governance-risk-03

Continuous vendor monitoring with reassessment when something changes

Grade C · Augment

Problem. Vendor approvals are point-in-time, so new reports, subprocessors, incidents or AI features added after approval can change risk without anyone reopening the review.

Approach

- The programme defines triggers such as a new SOC 2 report, subprocessor or vendor incident, on which an analyst reopens the assessment.
- Vendors including Safe and Vanta sell agents that monitor breaches, contracts and vendor changes; no outcome figures are published.
- Idea: extend the inventory to vendor-embedded agents, with a named human reviewer for AI-generated findings that trigger action.

Evidence: Safe Security, Vanta, Anthropic · security-governance-risk-04

Mapping and rationalising controls and evidence across frameworks with an agent

Grade A · Augment

Problem. Organisations holding many frameworks keep duplicate controls and map evidence by hand; Synthesia's case study puts matching 500+ HITRUST controls at 1.5 months of manual work.

Approach

- An agent proposes a common control framework and maps controls and evidence to each framework; a GRC owner approves the mapping.
- Samsara reports consolidating 820 controls to 260 (68% reduction) across 10 frameworks (vendor-published).
- Synthesia reports HITRUST implementation compressed from 18 months to about 3 months (vendor-published).

Evidence: Samsara, Synthesia, Vanta · security-governance-risk-05

Agent-run evidence collection and continuous control monitoring

Grade B · Automate

Problem. Control evidence is gathered by hand before each audit, so failures surface late; manual compliance work took up to 60% of Perforce's team time.

Approach

- Connectors pull evidence from source systems; agents check it against control descriptions, flag drift and send issues to control owners.
- Control owners drive findings to closure, and humans own thresholds and policy; external audit cycles continue.
- Perforce reports compliance work falling from 60% to 15% of team time; Synthesia reports 60% of evidence collection automated (vendor-published).

Evidence: Perforce, Synthesia, Vanta · security-governance-risk-06

Agents test controls end to end and assemble audit workpapers for review

Grade C · Delegate

Problem. Control testing is done by sampling and manual fieldwork, then written up as workpapers for internal and external auditors.

Approach

- Agents ingest unstructured evidence, run attribute tests on the full set of uploaded evidence and record each step.
- They assemble Excel workpapers linked to source evidence; auditors review the workpapers and exceptions.
- Optro announced this capability; no outcome figures are published.

Evidence: Optro (formerly AuditBoard) · security-governance-risk-07

Drafting and keeping security policies current with AI

Grade B · Augment

Problem. Policy sets must be written and updated for each new framework, and generic chatbot requests for a security policy produce generic output.

Approach

- AI drafts tailored policy documents and keeps a policy database current across frameworks.
- Prompt templates supply audience, tech stack, certifications and current state; the policy owner reviews and approves drafts.
- Synthesia reports its policy database kept current across six frameworks (vendor-published); an independent test of policy-to-code translation reports 50.3% vs 15.3% (independent).

Evidence: Synthesia, Vanta, GitLab · security-governance-risk-08

Gap analysis of security policies against a standard and actual practice

Grade B · Augment

Problem. Security policies are often incomplete against standards and drift from what teams do; finding gaps takes extensive manual effort and scarce experienced reviewers.

Approach

- AI compares policies with programme data or customer-facing reports and surfaces inconsistencies for policy owners to fix.
- In a lab benchmark, small open-weight models judged ISO 27002 controls as met or not met, as an assistant to the auditor.
- Best model's mean agreement with the human expert was 80.65% (independent); four of eight models reached 52.4-59.9% balanced accuracy.

Evidence: Calastone, Vanta, academic researchers · security-governance-risk-09

Mapping AI and security regulations into policy and controls

Grade C · Assist

Problem. A Gartner analyst describes the AI regulatory landscape as fragmented and volatile, and teams must keep policy-to-regulation mappings current.

Approach

- Governance engineers use AI-assisted workflows to monitor regulations, assess impact with Legal and update policy mappings.
- Gartner advises building a baseline on shared principles rather than law-by-law compliance, with cross-functional review of which mandates apply.
- No outcome figures are published.

Evidence: GitLab, Okta, Gartner · security-governance-risk-10

Risk register upkeep, intake triage and first-draft risk analyses with AI

Grade C · Augment

Problem. Risk intake, register upkeep, first-draft analyses and reporting are manual work; Anthropic and Plaid job postings seek AI-based automation of it.

Approach

- Anthropic plans Claude-based tooling to classify and triage incoming risks; Plaid seeks automations for first-draft analyses and reports.
- Analysts own calibration and quality review of AI outputs.
- An independent comparison of five LLMs with 50 human experts found LLM risk scores consistently lower.

Evidence: Anthropic, Plaid, Vanta · security-governance-risk-11

Cyber risk quantification with AI: data gathering and expert elicitation

Grade C · Augment

Problem. Structured expert elicitation produces calibrated estimates but takes months of coordination, while boards ask for decision-ready, data-driven numbers.

Approach

- Anthropic plans Claude-based tooling to sense changes in the risk landscape; researchers use LLM personas to replace or supplement expert panels.
- Analysts own estimate calibration; 89% of survey respondents have board-approved risk thresholds.
- A lab study reports Pearson r = 0.91-0.98 against ground truth (independent); T-Mobile reports a 75% reduction in reporting time (vendor-published).

Evidence: Anthropic, T-Mobile, FAIR Institute · security-governance-risk-12

Risk analysis extended to the organisation's own AI agents and model providers

Grade C · Assist

Problem. Analysts must assess software agents that hold privileges and can bind the company, but the FAIR threat taxonomy defines AI agents only as malicious tools.

Approach

- The FAIR Institute's standards director proposes treating agents as privileged insiders and model providers as third parties.
- Analysts collect three numbers on agent activity: share reviewed, delay, and how often review catches something.
- Human approval is required for agent actions above a defined threshold; no outcome figures are published.

Evidence: FAIR Institute, PwC, UC Berkeley CLTC · security-governance-risk-13

Board and executive risk reports drafted from programme data

Grade C · Augment

Problem. Gartner analysts say many board reports are built around cybersecurity rather than the business, and CISOs may get only five to ten minutes with the board.

Approach

- Idea: programme data feeds a board pack that AI drafts and the CISO edits; no source describes this in use.
- Perforce plans to use its GRC platform for regular risk reviews and board-level reporting.
- The CISO owns the narrative and the requests to the board; no outcome figures are published.

Evidence: Perforce, Gartner, CSA · security-governance-risk-14

Audit response drafting and consolidating several audits around one evidence set

Grade B · Augment

Problem. Each external audit asks subject experts for the same walkthroughs and evidence, and several audits run in parallel.

Approach

- AI drafts responses to auditor requests from existing evidence, and one evidence set is mapped to several frameworks.
- No source describes who reviews AI-drafted audit responses; under NIS2 a named executive owns what is filed.
- Synthesia reports five framework audit cycles in one month; Samsara reports expert time per cycle falling from 70 to 40 hours (vendor-published).

Evidence: Synthesia, Samsara, Vanta · security-governance-risk-15

Verifying automated compliance evidence and auditor independence

Grade C · Assist

Problem. After a whistleblower alleged the platform Delve generated fabricated SOC 2 and ISO 27001 evidence (the company denies this), practitioners worry that customers relying on the certificates carry the liability.

Approach

- IANS faculty advise buyers to re-read their SOC 2 report and ask the platform vendor what the auditor can access.
- Buyers get written confirmation that the auditor designed its own tests and spot-check 5 to 10 controls at random.
- No outcome figures are published.

Evidence: IANS Research · security-governance-risk-16

Security team writes AI policy and approval gates for tools and agents

Grade B · Assist

Problem. Staff adopt AI tools and agents faster than policy; security teams must decide what data agents may touch and which actions need human approval.

Approach

- GRC writes agent governance policies, sets approval criteria and sits as reviewer in engineering approval workflows.
- Cengage reports assessing 67 AI vendors in 15 months (self-reported), aiming not to be 'the Department of No'.
- Sendbird's CISO describes tiered AI tools, blocks on some models and contract review so vendors do not train on customer data.

Evidence: Cengage, Sendbird, Cloudflare, Anthropic · security-governance-risk-17

The security team's own AI-use policy: approved tools, logging and autonomy limits

Grade B · Assist

Problem. AI is in security work faster than control over it: SANS reports 79% of SOCs use AI or ML tools but only 36% have built them into a defined workflow.

Approach

- The policy sets approved tools and data classes, an owner for each use, and logging of prompts, outputs and model versions.
- Agents get no broad access; deterministic gates and a kill switch outside the agent's control sit before high-risk actions.
- Trail of Bits wrote an AI handbook listing approved and unapproved tools; Centene describes hash-verified records of each AI-assisted step.

Evidence: Trail of Bits, Centene, FINRA, SANS · security-governance-risk-18

GRC engineering team builds compliance automation and agent workflows

Grade B · Augment

Problem. Compliance headcount scales with frameworks, vendors and customer requests, yet GRC still runs on spreadsheets and skills are uneven.

Approach

- GRC teams hire automation engineers, define controls as machine-readable code and expect analysts to build their own AI automations.
- The GRC practitioner decides whether a configuration is in fact their control; Anthropic's postings state a human-in-the-loop design.
- Anthropic, Figma, Plaid and Cloudflare are hiring for these roles; no outcome figures are published.

Evidence: Anthropic, Figma, Plaid, Cloudflare · security-governance-risk-19

Security roles redesigned around AI oversight, with role-based AI training

Grade C · Delegate

Problem. Teams report skills rather than headcount as the binding constraint, and only 20% provide comprehensive AI training for all staff.

Approach

- Work is reassigned between people and AI; new roles such as AI security engineer and AI governance analyst appear.
- Staff get role-based training in AI tools, LLM SecOps (running and securing LLM systems) and AI regulation.
- Surveys report 34% creating AI/ML specialist roles and 41% naming AI the most pressing skills need (independent).

Evidence: RSA Conference/SANS-GIAC, ISC2, ISACA · security-governance-risk-20

Deliberate apprenticeship for junior risk staff when AI absorbs entry-level work

Grade D · Assist

Problem. Idea, not a deployment: juniors learned what normal looks like from routine work that AI now automates, so Venables argues the talent pipeline fractures within a few years.

Approach

- Idea: put juniors on control-failure post-mortems instead of evidence gathering, with AI as a coach.
- Venables also proposes pod or master-and-apprentice structures and hiring tests that spot errors in AI output.
- Juniors review machine-generated work against a standard; no results are published.

Evidence: No named deployment · security-governance-risk-21

Security operations

The SOC and MDR: detection engineering, triage, investigation, response actions, measuring the SOC's AI. · 24 use cases · evidence strong (20 of 24 A/B)

Agentic alert triage: simple checks first, case built before analyst opens it

Grade A · Automate

Problem. Manual investigation of each alert took about half an hour; Elastic's first AI summaries were wrong about 40% of the time, so analysts stopped reading them.

Approach

- Rule-based queries close obvious false positives; narrow agents investigate the rest and build a case with a verdict.
- Only high-confidence false positives close without an analyst; analysts confirm or override and record when the AI was wrong.
- Elastic reports AI verdict correctness rising from 60% to 92% after changing the context given to agents, not the models (self-reported).
- Elastic reports a 30-minute investigation now finishing in under 3 minutes (self-reported).

Evidence: Elastic, Figma · security-operations-01

Precedent retrieval showing analysts how similar alerts were closed before

Grade A · Augment

Problem. Many alerts resemble cases already investigated, but proving that meant digging through closed tickets, raw logs and colleagues' Slack comments.

Approach

- Figma indexes alerts with on-call comments, retrieves similar recent alerts, posts a summary and downgrades severity when similar alerts were benign.
- Expel's precedent engine shows a suggested read and nearest past cases; weak matches default to escalation and the analyst always decides.
- Figma reports a 20% drop in on-call pages (self-reported); Expel publishes targets, not measured results.

Evidence: Figma, Expel · security-operations-02

SIEM triage agent proposes a verdict and next steps; analyst decides

Grade B · Augment

Problem. Analysts pivot manually across data to gather context for every queued finding before deciding whether to close, escalate or investigate it.

Approach

- Google, Splunk, Microsoft and Cisco embed triage agents in the security monitoring platform (SIEM); the agent proposes a disposition and rationale.
- Analysts decide whether a finding is closed, escalated or acted on; high-impact actions stay with people.
- Google says a typical 30-minute analysis falls to about 60 seconds (vendor-published); Cisco's event figures are observations, not benchmarks.

Evidence: Google, Splunk, Cisco, Microsoft · security-operations-03

Agent triages user-reported phishing emails and resolves false alarms

Grade B · Automate

Problem. User-reported suspicious emails arrive continuously; reviewing each one slows response and risks genuine threats being missed.

Approach

- An agent detonates files and URLs, checks threat intelligence, classifies the email and explains its verdict in plain language.
- False positives are resolved; true positives stay open for an analyst, who can give feedback on the classification.
- Valvoline's CISO says analysts reclaimed hours and containment became automatic on Torq's platform (vendor-published); no figures.

Evidence: Microsoft, Valvoline, Torq · security-operations-04

AI SOC analyst investigates every first-line alert and closes the benign majority

Grade B · Automate

Problem. Alert volume grew faster than analyst headcount and most alerts were benign; at Zapier a very small team faced 50-100+ daily investigations.

Approach

- Alerts flow from detection tools into an AI analyst that investigates each one and writes outcomes into the case system.
- Analysts work only what is not closed and see every query and piece of evidence; CyberProof adds QA sampling of closed cases.
- ECS reports 70% of first-line alerts closed automatically (vendor-published); Zapier reports triage falling from 10-15 minutes to under 2 (vendor-published).

Evidence: ECS, Zapier, CyberProof, Dropzone AI · security-operations-05

Calibrated models score alerts; confident benign ones close, others go to analysts

Grade C · Automate

Problem. Noise and low-severity alerts consume analyst time, and prose-generating AI triage is costly, variable and hard to audit.

Approach

- Practitioners argue to start where error cost is lowest: close only alerts judged benign at a stated confidence, keeping recall fixed.
- Decision models return a score with a probability: high closes, low escalates, the middle band goes to analysts, each verdict logged.
- CrowdStrike reports false-positive recall rising from 21.8% to 64.8% with reasoning before the verdict (vendor-published).

Evidence: CrowdStrike, Swimlane, academic researchers · security-operations-06

Evidence-gated dismissal: an independent challenge must find counter-evidence before dismissal

Grade B · Augment

Problem. Triage agents tend to dismiss attack alerts when searches return nothing, and self-review in the same context does not correct errors.

Approach

- Grow Therapy's model must argue against each finding and produce counter-evidence before dismissing it; Slack uses a separate Critic agent.
- Surviving findings go to analysts, who mark false positive or escalate.
- Grow Therapy reports about 40% of findings were noise without the phase (self-reported); a benchmark design cut false negatives to 3.1% (independent).

Evidence: Grow Therapy, Slack, academic researchers · security-operations-07

'SOCless' model: AI investigates all alerts, engineers paged only for serious events

Grade B · Automate

Problem. A small, all-senior engineering team targeted by state-sponsored attackers was swamped by thousands of monthly alerts, mostly false positives.

Approach

- All alert types go to an AI SOC analyst; results return to the SIEM and on-call engineers are paged for serious events.
- Mysten has no dedicated security analysts.
- Monthly alerts needing human review fell from thousands to under 20; time per alert from 30-60 minutes to roughly 1 (vendor-published).

Evidence: Mysten Labs, Dropzone AI · security-operations-08

Agent investigates alerts end to end; on-call staff supervise and correct

Grade A · Delegate

Problem. Gathering context was the main burden for on-call engineers, and a single-prompt prototype at Slack was highly variable and sometimes jumped to spurious conclusions.

Approach

- Figma's agent works in the Slack alert thread with scoped tools; Slack splits investigation across Director, Expert and Critic model calls.
- The on-call engineer reviews what the agent found, confirms or corrects it, and handles cases needing judgment.
- Figma reports a 71% reduction in alert time to resolution (self-reported).

Evidence: Figma, Slack · security-operations-09

Agent prepares the investigation and the analyst decides, tested in controlled studies

Grade B · Augment

Problem. Manual investigations are slow, vary by analyst and degrade with fatigue, and vendors claim AI helps with little controlled evidence.

Approach

- Analysts receive an agent's evidence gathering and draft conclusion, review it and remain author of the verdict.
- A Cloud Security Alliance study with Dropzone AI randomly assigned 148 participants; assisted analysts were 45% and 61% faster (vendor-published).
- A university security team reports about 40% less ticket completion time (independent).

Evidence: CSA, Dropzone AI, a university SOC · security-operations-10

Agent-written investigation narratives help new analysts work above their experience

Grade B · Augment

Problem. New analysts spend their first hours learning where every tool lives and assembling context manually, and juniors take months to ramp up.

Approach

- Analysts start from an agent-prepared incident narrative, evidence and recommended next steps, then validate and decide.
- At one customer, junior analysts learned from the agent's visible investigation reasoning.
- Cabinetworks says junior ramp-up fell from months to weeks (vendor-published); Cisco Live reports a dozen-plus new analysts operating at Tier 2 level.

Evidence: Cisco Live, Cabinetworks, Splunk · security-operations-11

Analyst copilot and chat assistants for queries, log analysis and incident summaries

Grade A · Assist

Problem. Analysts take time to gather and read incident information from many sources, and most use AI individually without organisational structure or validation.

Approach

- A copilot in the XDR portal aggregates incident information and answers natural-language queries; the analyst remains decision-maker and author.
- Microsoft authors associate copilot adoption with a 30.13% lower mean time to resolution after three months (vendor-published).
- SANS reports 79% of SOCs use AI or ML tools but only 36% have built them into a defined workflow (independent).

Evidence: Microsoft, SANS Institute · security-operations-12

Agent drafts the investigation report for analyst sign-off

Grade B · Augment

Problem. Analysts write structured reports for technical and non-technical readers after gathering evidence across tools, and report detail can decline with fatigue.

Approach

- Pan-American Life's agent produces structured reports with MITRE ATT&CK mapping, technical for analysts and plain-language for others.
- Expel's Ruxie writes plain-language incident reports that people review and sign off before they are final.
- CrowdStrike says Pan-American Life's reporting that once took hours now arrives automatically (vendor-published); no figures.

Evidence: Pan-American Life, Expel, CrowdStrike, Elastic · security-operations-13

AI triage of anomaly signals surfaces an intrusion no single rule flagged

Grade B · Augment

Problem. Separating real signals from daily noise is hard, and rules miss activity that no single alert flags, so false negatives go unseen.

Approach

- Hugging Face says its anomaly-detection pipeline uses AI triage over security telemetry, and correlating those signals flagged an intrusion.
- Responders handled containment and assessment; alerting was changed so a high-severity signal pages a responder within minutes.
- The disclosure credits AI-assisted detection with surfacing the compromise (self-reported); no figures.

Evidence: Hugging Face · security-operations-14

AI drafts, translates and scores detection rules, with judge model and review

Grade A · Augment

Problem. Turning each new high-severity vulnerability or threat report into a validated detection rule took research, tuning and peer review, so coverage had to be prioritised.

Approach

- Amazon's RuleForge scores exploit code, runs parallel rule-generation agents and uses a separate judge model to score each rule.
- A security engineer reviews the best rule; human judgment is the final gate before production.
- Amazon reports rules produced 336% faster and 67% fewer false positives from the judge model (self-reported).

Evidence: Amazon, Kroll, Google · security-operations-15

Coding agents validate detections end to end in a lab, then retry

Grade B · Delegate

Problem. Rules pass code review but nobody checks that telemetry arrives and the detection fires, and driving labs by hand is slow.

Approach

- DNB's Cyber Defense Center repurposed coding agents to write attack simulations, detonate them in a lab, query Splunk and rewrite on failure.
- A person reviewed every generated simulation.
- DNB reports most simulations were fit for purpose and the loop surfaced mechanical pipeline issues (self-reported; numbers redacted); piloting.

Evidence: DNB Cyber Defense Center · security-operations-16

Agent drafts allowlist and rule-change proposals after analyst confirms a false positive

Grade B · Augment

Problem. Alerts keep firing for known-benign patterns until someone writes the suppression.

Approach

- When an on-call engineer confirms a false positive, Figma's agent opens a draft pull request with an allowlist entry or rule tune.
- Pull requests open as drafts for human review, and the agent responds to reviewer comments.
- Figma says the step from understanding an alert to a fixing pull request 'surprised us most' in time saved (self-reported); no figures.

Evidence: Figma, Elastic · security-operations-17

SOC teams build their own agents from playbooks in a no-code workspace

Grade B · Delegate

Problem. Each SOC has its own playbooks and escalation paths; that knowledge is lost to turnover, and generic automation does not capture it.

Approach

- Analysts encode playbooks and SOPs into agents in plain language on CrowdStrike's Charlotte AI AgentWorks.
- For each workflow, teams set what is fully automated and what requires approval.
- One analyst reports building the same agent in four minutes versus six to eight hours in Microsoft Copilot (vendor-published).

Evidence: CrowdStrike, Pan-American Life, Kroll · security-operations-18

Agents propose containment actions that run only as validated, templated commands

Grade C · Augment

Problem. Blocking, killing a process or isolating a host can cause harm if the agent is wrong or manipulated, including by a single adversarial alert.

Approach

- Google previews agentic containment pairing agents with fixed playbooks that keep high-impact actions under analyst control.
- A research design confines model output to templated commands behind an argument validator, with human approval or a delay window.
- A stock guardrail proxy raised injection recall from 25.0% to 94.5% at 0.1% false positives (independent).

Evidence: Google, Valvoline, academic researchers · security-operations-19

Per-action authority for SOC agents, with activity observable and stoppable

Grade C · Automate

Problem. AI shortened investigation but not the distance to a safe, verified response, and teams lack a shared way to decide which actions an agent may take alone.

Approach

- Grant authority one action at a time: the UK NCSC proposes scoring each automation on potency, scope, criticality, rollout confidence and recoverability.
- The accountable owner approves each autonomy level and can widen or withdraw it; agent activity is logged, attributable and stoppable.
- A vendor-run survey found 57% require a human to review every AI decision before an alert is closed (vendor-published).

Evidence: UK NCSC, SACR, Cisco/Splunk · security-operations-20

Measuring the SOC's AI: score verdicts, sample closures, replay benchmarks

Grade A · Assist

Problem. Vendors give clean accuracy figures on curated alerts, but teams need evidence on their own alerts, especially false negatives.

Approach

- Record the AI verdict and the analyst's closure reason on every case, and sample AI-closed cases for quality review.
- Before go-live and after each change, test on real alerts or replay benchmarks, and decide autonomy on the results.
- Elastic reports AI-analyst agreement rising from 60% to 92% (self-reported); an independent benchmark found every approach missed at least 40.4% of attacks.

Evidence: Elastic, CyberProof, UnderDefense, academic researchers · security-operations-21

Managed detection services move to agent-led, human-accountable models

Grade B · Delegate

Problem. Alerts are investigated in tiers while attackers move, buyers face a wave of 'AI MDR' products, and regulated buyers must show control over suppliers.

Approach

- Providers describe specialist and judge agents with a route to human experts when confidence is low; Gartner defines MDR as 'AI-augmented, human-led'.
- Buyers can use the NCSC's list of AI risks as a supplier questionnaire and sign off third-party risk before onboarding.
- Expel reports 14 minutes mean time to remediate on fully automated high and critical incidents (self-reported).

Evidence: Arctic Wolf, Expel, eSentire, Sophos · security-operations-22

SOC staffed to build and supervise automation with coding agents

Grade B · Augment

Problem. Detection and response need custom automation while teams are small, and manual-triage roles are the smallest, lowest-paid and least automated family in SOC hiring.

Approach

- Job postings ask detection and response engineers to use AI coding tools and some ask for experience building agentic SOC workflows.
- The analyst tier validates AI output.
- D3 Security's sample of US SOC postings found 247 build-family versus 68 SOC analyst postings (vendor-published).

Evidence: Expel, Databricks, Robinhood, Cloudflare · security-operations-23

Idea: defender agents that contain an active attack without a human

Grade D · Delegate

Problem. Idea, not a deployment: the field is in awe of models that find vulnerabilities while patching and detection lag, and Hugging Face's attacker was bound by no usage policy.

Approach

- Idea: guardrailed agents stop an active attack without human intervention; no production deployment was found.
- A DARPA-derived programme planned to deploy red and blue team agents on digital twins of water systems.
- No human checkpoint is defined; no results are published.

Evidence: No named deployment · security-operations-24

Threat intelligence

Intelligence cycle, enrichment, reporting, sharing, threat hunting. · 24 use cases · evidence strong (14 of 24 A/B)

Idea: agents that watch intelligence-requirement coverage and keep briefings current

Grade D · Augment

Problem. Idea, not a deployment: intelligence requirements are expanding while capacity is constrained, and most formal CTI teams have fewer than four full-time staff.

Approach

- Flashpoint's interview study says practitioners see coverage monitoring against priority intelligence requirements, and standing briefings, as workflows where agents could extend coverage.
- Tasks with reviewable outputs, reversible actions and clear success criteria are the practical starting point; analysts stay in the process.
- No deployment was found.

Evidence: No named deployment · security-threat-intelligence-01

AI-supported monitoring and collection of open sources for threat-landscape reporting

Grade B · Augment

Problem. Threat-landscape reporting depends on collecting and curating thousands of open-source incident reports, which have gaps in granularity and timing.

Approach

- ENISA states AI was used in a limited capacity to support collection and processing for its Threat Landscape 2026.
- All AI outputs were reviewed and validated by subject-matter experts; ENISA published no measure of AI's effect.
- Apura presented an approach using retrieval-augmented generation and agentic workflows at FIRST 2026; a research benchmark reports 89.33% strict F1 (independent).

Evidence: ENISA, Apura Cyber Intelligence · security-threat-intelligence-02

Dark-web and stolen-credential log collection triaged by language-model pipelines

Grade C · Augment

Problem. Forum posts, messaging channels and millions of stealer logs are too many and varied for analysts to read; Flare says over 50 million logs were posted in 2025.

Approach

- Mandiant (2023) described dozens of AI models over botnet, forum and messaging data, with entity extraction, topic classification and translation.
- Flare introduced StealerLens at FIRST 2026, an LLM-powered tool to speed infostealer log investigations.
- Google's relevance system filters dark-web findings against an organization profile. Human checkpoints are not stated; no outcome figures are published.

Evidence: Flare, Mandiant, Google · security-threat-intelligence-03

Multi-agent system that elicits intelligence in underground forums (research prototype)

Grade C · Delegate

Problem. Passive monitoring yields less as forum users grow aware of data collection and valuable intelligence moves to private spaces.

Approach

- DarkBot, a university and industry prototype, splits interaction across eleven agents, with built-in engagement gating for relevance and safety.
- Operator review of individual conversations is not described.
- It recovered 72.8% of validated techniques from the first post alone; live threads gathered 3.85 more CTI entities than controls (independent).

Evidence: Politecnico di Milano, BV TECH · security-threat-intelligence-04

Reports turned into indicators and tags, source attached, checked before storage

Grade B · Automate

Problem. Analysts read vendor blogs and advisories, then retype indicators of compromise into their tools, and indicators get separated from the reason they matter.

Approach

- Cloudflare's Threat Signals polls chosen feeds, extracts indicators and stores each as an event linked to its source report.
- Analysts see which tags were automatic and trace each indicator to its report; reviewed variants add approval before writing to live tools.
- Independent studies found LLMs recovered only 25-31% of labeled indicators, though with fewer false indicators than rule baselines.

Evidence: Cloudflare, Adobe, Anthropic, Feedly · security-threat-intelligence-05

Mapping report text to attacker techniques and enriching hunts with actor context

Grade B · Augment

Problem. MITRE describes mapping the tactics and techniques in threat reports to ATT&CK as difficult, error-prone and time-consuming.

Approach

- Intel 471's hunt analysts use AI to tag hunts with actors, map techniques to ATT&CK and add industry and severity context.
- Mappings should be reviewed by analysts; Feedly lists attribution and risk ratings as outputs a model tends to assert with unwarranted confidence.
- On sandbox reports three LLMs reached technique F1 of 0.71 to 0.72; on complex reports the best open model scored 0.22 (independent).

Evidence: Intel 471, MITRE, EclecticIQ, Feedly · security-threat-intelligence-06

Idea: merging report collections into knowledge graphs to measure vendor bias

Grade D · Augment

Problem. Idea, not a deployment: the same threat gets unrelated names across vendors, and annual vendor reports contradict each other on top intrusion vectors.

Approach

- Research designs extract each report into a graph, verify entities against evidence and ATT&CK definitions, and merge graphs across sources.
- One team structured 16,096 public reports to measure what each source adds; no team was found using this to manage subscriptions.
- In research, BEACON beat baselines by at least 23% on extraction (independent); human checkpoints are not described.

Evidence: No named deployment · security-threat-intelligence-07

Global intelligence ranked against an organization profile so only relevant items surface

Grade C · Augment

Problem. External monitoring floods CTI teams with keyword hits; Google says the problem is lack of relevance, not data, and alert noise was the top challenge for 65% in Flashpoint's interviews.

Approach

- Google's relevance system (Beta) builds an organization profile, scores intelligence and dark-web findings against it and groups them into alerts.
- Analysts change alert status and give feedback; Forrester asks vendors for testing and validation mechanisms.
- Google reports 98% internal accuracy, with no test design described; Mandiant (2023) reports 96% fewer false positives in alert generation (vendor-published).

Evidence: Google, Microsoft, Recorded Future, Mandiant · security-threat-intelligence-08

Malware-analysis agent triages samples, explains behaviour and extracts indicators

Grade C · Augment

Problem. Malware samples from partners need manual reverse engineering to find indications of compromise and adversary command-and-control.

Approach

- Google's Malware Analyst agent triages files, reverse engineers binaries and scripts, and explains behaviour in natural language with reasoning shown.
- CISA's inventory lists a deep-learning malware reverse-engineering use case at the initiation stage, assisting analysts within a larger toolbox.
- No outcome figures are published.

Evidence: Google, CISA · security-threat-intelligence-09

Threat research agent triages articles, verifies indicators and drafts cited reports

Grade B · Augment

Problem. Analysts triage articles, gather evidence and write the report; analysts at the authors' organization said analyzing one incident from an article typically takes several hours.

Approach

- Microsoft authors describe an agent in their CTI workflow that researches a seed article, retrieves supplementary content and drafts a cited report.
- A team of experts reviews outputs and their corrections are fed back into the prompts.
- Indicator precision rose by 0.02 to 0.05 at several times the run time; technique recall was flat or lower (self-reported).

Evidence: Microsoft Research · security-threat-intelligence-10

Natural-language questions answered from a curated intelligence corpus

Grade B · Assist

Problem. Analysts pivot by hand across feeds and query languages, and colleagues outside the security team wait days for answers about the threat landscape.

Approach

- Platforms from Google, Recorded Future, Microsoft, Cloudflare and CrowdStrike put a chat or agent interface on their own intelligence data.
- Analysts read the cited sources and tool-call trace before relying on an answer and still run in-depth investigations themselves.
- Cowbell says stakeholder questions now get answers in minutes instead of two to three days (vendor-published).

Evidence: Cowbell, Superhuman, Google, Recorded Future · security-threat-intelligence-11

Drafting and tailoring threat briefings for different audiences, scheduled or on demand

Grade B · Augment

Problem. Producers write the same finding several times for different readers; 91% of CISOs value CTI but only 26% say it significantly influences their decisions.

Approach

- Microsoft's briefing agent combines actor activity with customer vulnerability data; Google 'Flows' schedule prompts such as a daily sector digest.
- At CISA, authorized personnel review and edit drafts before publication; an analyst approves final analytic content.
- SANS reports 45% of surveyed organizations use AI in CTI, mainly for summarization and report writing (independent).

Evidence: Microsoft, Google, CISA, Recorded Future · security-threat-intelligence-12

Preparing intelligence for sharing: personal-data screening, redaction and packaging

Grade B · Augment

Problem. Sharing threat intelligence risks exposing sensitive information; 17 of 18 surveyed practitioners named it a recurring difficulty, and SANS reports 55% lack legally reviewed sharing processes.

Approach

- CISA's Automated Indicator Sharing uses language processing to flag potential personal data; analysts confirm or reject each flag and redact before dissemination.
- Researchers pilot LLMs for redaction and STIX packaging; expert review is advised at each step.
- In the pilot, every model asserted relationships the findings did not support, for example 38 of 73 links correct (independent).

Evidence: CISA, GAO, UC Santa Barbara · security-threat-intelligence-13

Threat reports turned into tested detection rules (Sigma, YARA, KQL)

Grade C · Augment

Problem. Moving from a threat report to a detection that fires takes days or weeks of handoff between intelligence analysts and detection engineers.

Approach

- Microsoft Security Copilot promptbooks extract indicators and generate hunting queries; Anthropic's posting describes using Claude to generate hunting queries.
- A secondary report says Rapid7's team built a pipeline emitting detection rules; the detection engineer reviews and tests rules before deployment.
- Microsoft's benchmark found the best of 16 frontier models reached a 0.637 reward out of 1 (vendor-published).

Evidence: Microsoft, Anthropic, Rapid7 (secondary report) · security-threat-intelligence-14

Automated alert enrichment and tool connections letting agents pull threat intelligence

Grade B · Augment

Problem. Alerts need threat scores, actor profiles and indicator context before anyone can decide, and manual lookups across tools slow triage.

Approach

- Superhuman wired Recorded Future into its SOAR platform and built an internal MCP server so its agents can request and summarize intelligence.
- Google and SOCRadar describe similar connections; Anthropic's posting lists VirusTotal, Censys and Urlscan integrations.
- Superhuman analysts keep doing in-depth investigations; the company says times are lower but gives no numbers (vendor-published).

Evidence: Superhuman, Recorded Future, Google, SOCRadar · security-threat-intelligence-15

New indicators matched against enterprise logs by an LLM-fed hunting pipeline

Grade B · Automate

Problem. When a critical advisory appears, teams spend days reading it, extracting indicators and hunting across tools while attackers exploit the gap.

Approach

- Adobe's platform monitors sources, uses LLMs to extract indicators and launches parallel hunts across endpoint, email, cloud and authentication logs.
- Analysts receive compiled detections and investigate; whether any step needs approval before a hunt runs is not stated.
- Adobe says each hunting job completes within minutes, with no before-and-after comparison (self-reported).

Evidence: Adobe · security-threat-intelligence-16

Chained agentic workflow from inbound report to scoping, tickets and draft detections

Grade C · Delegate

Problem. Following one vendor report through extraction, mapping, asset checks, ticketing and leadership notice can consume a morning; about 40% say integration into workflows is mostly manual.

Approach

- Feedly's guide chains five prompts in low-code tools: extract indicators, map to ATT&CK, scope to assets, then draft detections and tickets.
- Analysts review scoping and approve before any write to live tooling.
- Flashpoint's interviews found 25% of organizations in production with agentic AI and 20% piloting (vendor-published).

Evidence: Feedly, Flashpoint, Cyware · security-threat-intelligence-17

Bounded agents that package evidence for takedown of phishing and brand-abuse sites

Grade C · Automate

Problem. Phishing and impersonation sites often live only hours, and Memcyco says manual enrichment and case preparation consume the window for takedown.

Approach

- Memcyco describes bounded agents that continuously collect, enrich, score and package external threat evidence.
- Analysts keep enforcement decisions; Recorded Future announced AI-driven alert triage in a brand-protection hub with automatic takedowns.
- No outcome figures are published.

Evidence: Memcyco, Recorded Future · security-threat-intelligence-18

AI assistants inside human-led threat hunts and frontline intelligence work

Grade B · Assist

Problem. Hunters can fixate on one indicator, need to understand unfamiliar techniques and query languages, and must document findings for several audiences.

Approach

- Intel 471's hunters use AI to stress-test hypotheses, suggest related actors and draft documentation; Microsoft's assistant turns questions into queries.
- The hunter forms and owns the hypothesis and reviews generated queries and results.
- A research prototype lifted mean hunt-lead F1 from 0.44 to 0.85 (independent); Intel 471 publishes no figures.

Evidence: Intel 471, Microsoft, Google Threat Intelligence Group · security-threat-intelligence-19

Managed-service agents turn new campaigns into hunt hypotheses and detection rules

Grade C · Delegate

Problem. Hypothesis-driven hunting is limited by scarce senior hunters, so teams cannot test for emerging campaigns that have not yet triggered an alert.

Approach

- CyberProof runs four agents for a logistics client: match campaigns, generate 30 to 40 hypotheses, write queries, create standing rules.
- CyberProof says human oversight remains central but does not say which steps need approval.
- CyberProof reports 150 to 200 hunts a month and a 20% increase in active detection coverage (vendor-published).

Evidence: CyberProof · security-threat-intelligence-20

Scheduled AI hunt agents that must argue against their own findings

Grade A · Delegate

Problem. Grow Therapy needed proactive coverage across systems touching sensitive data, but rules only cover patterns someone knows how to write.

Approach

- About 20 daily Claude-based hunts run in five phases; the last requires the model to argue against its findings with counter-evidence.
- Analysts mark false positives in Slack, and a weekly report decides which hunts need tuning.
- Grow Therapy reports $320 to $510 a month, and estimates about 40% of findings were noise without the final phase (self-reported).

Evidence: Grow Therapy · security-threat-intelligence-21

Always-on investigation agent finds missed malicious activity and writes explainable detections

Grade A · Delegate

Problem. Defenders must keep translating new attacker tradecraft into detection logic, which leaves them reactive, and attack stories with gaps go unflagged.

Approach

- Microsoft's agent runs continuously across Defender, builds a unified timeline, tests attack hypotheses and issues alerts with severity and plain-language description.
- Customer feedback on each alert is the evaluation signal; whether a person reviews before an alert is raised is not stated.
- Customers rated alerts correct 80.1% of the time over 120 days, with novel alerts on about 15% of incidents (vendor-published).

Evidence: Microsoft · security-threat-intelligence-22

Machine-learning anomaly surfacing focuses government threat hunters on network data

Grade B · Augment

Problem. CISA threat hunters and SOC analysts process terabytes of daily network log data and need a way to narrow what they review.

Approach

- CISA's AI inventory lists an anomaly detection tool in operation that uses unsupervised machine learning on Einstein network data.
- Analysts review anomalies alongside rule-based heuristics and prioritize alerts for investigation.
- A critical-infrastructure equivalent is at the initiation stage; no outcome figures are published.

Evidence: CISA · security-threat-intelligence-23

Model providers' threat intelligence teams use their own models to disrupt misuse

Grade B · Augment

Problem. Model providers must detect and disrupt misuse of their own products over very large volumes of conversation and telemetry data.

Approach

- Anthropic states its Threat Intelligence team used Claude extensively to analyse data in its investigation of a campaign reported in November 2025.
- OpenAI's teams build systems using its models for lead generation, triage and synthesis; investigators conduct the investigations.
- No measurement of time saved, accuracy or error rate is published.

Evidence: Anthropic, OpenAI · security-threat-intelligence-24

Incident response

Plans, exercises, forensics, containment, recovery, regulatory notices, and incidents caused by AI agents. · 22 use cases · evidence strong (12 of 22 A/B)

AI review of response plans for completeness and fit with NIST guidance

Grade C · Augment

Problem. Incident response plans are essential but time-consuming to maintain and are updated reactively; ISACA reports 48% do not know whether AI incident playbooks exist or say they do not.

Approach

- At FIRST 2026 a Fortinet consultant presented a proof of concept: AI checks a plan against NIST 800-61 and flags outdated procedures.
- Tested on a real plan; who validates is not stated, and the plan owner decides which suggestions to adopt.
- No outcome figures are published.

Evidence: Fortinet, FIRST · security-incident-response-01

AI scenario builder creates tabletop exercises from the organisation's own playbooks

Grade C · Augment

Problem. Scenarios written once a year drift out of date, and building custom exercises by hand takes focus time.

Approach

- Immersive's AI Crisis simulation builder, released 1 October 2026, builds a branching scenario from a description or an uploaded playbook.
- The exercise owner reviews, edits and publishes each scenario; nothing reaches participants until a person publishes it.
- A solo-player pilot with 4 participants found greater intention to use the AI version than the card deck (independent).

Evidence: Immersive, Center for Internet Security · security-incident-response-02

Keep a vetted self-hosted model ready before an incident

Grade B · Assist

Problem. Hosted frontier models may refuse requests involving real exploit payloads or attack commands, which forensic analysis needs; Hugging Face says safety filters cannot tell responder from attacker.

Approach

- Hugging Face moved its AI forensic pipeline to an open-weight model on its own infrastructure after hosted APIs blocked the work.
- It advises defenders to have a self-run model vetted before an incident; one newsletter says the decision should go to the CSO.
- Hugging Face reports analysis could proceed after hosted models refused it (self-reported); no measured effect.

Evidence: Hugging Face, OpenAI · security-incident-response-03

Reconstruct attack timelines from logs and forensic artifacts with AI agents

Grade B · Augment

Problem. Timeline analysis can take investigators weeks, sifting hundreds of millions of log records; Hugging Face had to interpret about 17,600 attacker actions in July 2026.

Approach

- Hugging Face ran LLM agents over the attacker action log; Google's agent analyses Timesketch timelines and surfaces findings in an AI panel.
- Centene's six-layer pipeline versions and hash-verifies every transformation and validates before export; decision authority stays with the analyst.
- Hugging Face says the AI-assisted approach did in hours what usually takes days (self-reported).

Evidence: Hugging Face, Google, Centene, Mandiant · security-incident-response-04

Agent runs deterministic forensic tools for host triage, tying findings to artifacts

Grade B · Delegate

Problem. A full compromised-host investigation traditionally consumes an analyst's day, and organisations lack benchmarks to judge whether an LLM can be trusted with forensics.

Approach

- SANS's Protocol SIFT puts an AI agent in front of forensic tools; the AI sequences steps and ties findings to artifacts.
- Validation, interpretation and reporting are done by the investigator; challenge finalists were re-run on unseen evidence and traced to raw artifacts.
- A live demonstration investigated a compromised host in 14 minutes (self-reported); the best model fully solved 8 of 25 benchmark scenarios (independent).

Evidence: SANS Institute · security-incident-response-05

Plain-language questions over collected evidence in a forensic platform

Grade C · Assist

Problem. After remote collection from an affected host, establishing what happened and when can take days of manual review before leadership can be briefed.

Approach

- Investigators ask plain-language questions in Magnet Review, which returns a summary of flagged IPs and next lines of inquiry citing artifacts.
- The vendor says outputs are leads, not conclusions; the investigator validates every finding against source artifacts before it informs decisions.
- A Magnet Forensics survey reports 68% of DFIR professionals use AI in investigations (vendor-published).

Evidence: Magnet Forensics · security-incident-response-06

LLM agent traces alerts to root cause, with daily human audit

Grade C · Delegate

Problem. Tracing the chain of system events behind an alert breaks down in practice, and a legacy LLM investigation tool produced plausible but wrong reports.

Approach

- SherAgent iteratively queries a provenance graph, uses an LLM to read context and threat intelligence, and widens queries when events are missing.
- Built with the SOC of an unnamed large internet company; analysts spot-check 10 sampled investigations daily and review the graph before acting.
- Authors report human-verified success above 96% versus 64.7% for the legacy baseline (self-reported).

Evidence: Unnamed internet company SOC, academic authors · security-incident-response-07

Rank likely root-cause code changes for operational incidents

Grade B · Augment

Problem. Responders must build context and find which of thousands of code changes caused an incident before they can mitigate.

Approach

- Meta narrows thousands of changes to a few hundred with heuristics, then a fine-tuned Llama 2 7B ranker picks a top five.
- Responders independently reproduce and validate the results; Grafana reports an assistant investigating in parallel with on-call engineers.
- Meta reports 42% root-cause identification in backtesting (self-reported); Grafana reports one incident solved 3.5x faster (self-reported).

Evidence: Meta, Grafana Labs · security-incident-response-08

Verify AI investigation findings and harden tools against attacker-controlled logs

Grade C · Augment

Problem. AI can state plausible but false facts about artifacts, and the logs and emails an investigation tool reads are often attacker-controlled and can steer its conclusions.

Approach

- Practitioners combine deterministic checks that cited items exist in the original data, independent judging models and effort set by case stakes.
- Raw log content is treated as adversarial input: filtering, constrained outputs, least privilege and human verification.
- Cyber Triage suggests a criminal case needs a human to verify every item; layered defences cut injection success by 90.4% (independent).

Evidence: Cyber Triage, USENIX researchers · security-incident-response-09

Recommended triage, containment and remediation actions inside the incident console

Grade C · Assist

Problem. Responders must quickly decide how to classify an incident and what to contain, based on past cases and the organisation's own response rules.

Approach

- Microsoft documents guided responses in Copilot for Defender: recommended triage, containment, investigation and remediation actions, each with a reason.
- Administrators can upload organisation-specific response guidelines; the documentation does not describe automatic execution.
- No outcome figures are published.

Evidence: Microsoft · security-incident-response-10

Guardrailed automated containment playbooks with pre-authorised human override

Grade C · Automate

Problem. Containment such as isolating a host or revoking credentials is time-critical; Mandiant reports a median 22 seconds from initial access to hand-off in 2025.

Approach

- Unit 42 recommends playbooks that revoke credentials, end OAuth sessions, freeze pipelines and isolate cloud accounts at once.
- NIST, NSA and CISA call for automatic shutdown of agents on a control failure; pre-authorised responders can revoke an agent's credentials.
- SANS reports 39% adoption of automated incident response; 57% require human review of every AI decision (vendor-published).

Evidence: Unit 42, Mandiant, NIST, SANS · security-incident-response-11

Idea: LLM agent plans response and recovery, validated in a digital twin

Grade D · Delegate

Problem. Idea, not a deployment: network incident response is slow and labour-intensive, and LLM agents may hallucinate attacks and responses.

Approach

- Research prototypes infer attack progression, validate it against an emulated network, plan recovery and check commands in the twin first.
- Authors recommend human-in-the-loop or delayed execution.
- On a testbed, recovery success was 18-31% higher than frontier-LLM baselines (independent).

Evidence: No named deployment · security-incident-response-12

AI in cyber recovery: finding the last clean restore point, drafting runbooks

Grade C · Augment

Problem. During an incident the SOC flags a compromised host but does not know what is safe to recover, and ransomware crews now target backups.

Approach

- Rubrik markets an assistant that runs recovery on approval; a SOC agent can ask it for a host's last clean recovery point.
- The operator approves the recovery sequence; N2WS advises human review of recovery from corruption.
- Rubrik says its AI assistant reaches one-third of global customers (vendor-published); the agent link is in private preview.

Evidence: Rubrik, N2WS, Block · security-incident-response-13

Draft incident summaries and executive updates, edited by the incident commander

Grade A · Augment

Problem. Google estimates a thorough incident summary can take nearly an hour to write, and complex communications multiple hours.

Approach

- A Generate Summary control in Google's incident tool pre-fills a draft from structured case fields; the responder accepts, edits or discards it.
- Google reports 51% less time per summary, and LLM summaries rated 10% higher in a blind comparison (self-reported).
- A follow-on experiment drafted executive communications, cutting writing time 53% (self-reported).

Evidence: Google, Microsoft · security-incident-response-14

Draft regulator notifications from case evidence, with people approving every filing

Grade C · Augment

Problem. Regulatory reporting clocks start before forensic work is complete and run in parallel across DORA, NIS2, the Cyber Resilience Act, SEC rules and CERT-In.

Approach

- D3 Security markets an AI product that classifies incidents and populates DORA and NIS2 report templates for review and approval.
- Analyst or incident commander approves classification; legal and the accountable executive approve every external submission.
- D3's illustrative walkthrough ends in filing about 40 minutes after the alert (vendor scenario, not a customer result).

Evidence: D3 Security, ISMS Copilot, Microsoft · security-incident-response-15

AI review of post-incident reports against a written standard

Grade B · Augment

Problem. Incident reports can be incomplete: Cloudflare's reviewer has found missing follow-up actions, incomplete timelines and omitted detection signals.

Approach

- Cloudflare's reviewer agent checks each incident report against a dedicated engineering standard for completeness, contributing factors, resolution and follow-up.
- It is mandatory for high-severity incidents, and reports are not complete until all findings are addressed; domain owners approve the standards.
- Cloudflare reports more than 200 incident reports assessed since May 2026 (self-reported); no accuracy figure.

Evidence: Cloudflare · security-incident-response-16

Prepare for AI-agent incidents as a new class: identities, drills, halt authority

Grade B · Assist

Problem. Agents have taken significant uninstructed actions that breached the operator's controls and sometimes reached third parties; CERT-In reports none of the affected Indian organisations detected the access.

Approach

- On 2026-10-16 NIST, NSA and CISA published ten voluntary practices for agent incidents; CERT-In advises short-lived least-privilege agent identities.
- Leadership approves before runs start or resume; affected organisations and CERT-In are told promptly if an agent reaches a real system.
- ISACA reports 8% run AI-specific exercises regularly, 64% none; 56% do not know how fast they could halt an AI system (independent).

Evidence: NIST, NSA, CISA, CERT-In, ISACA · security-incident-response-17

Reconstruct what an AI agent did from tamper-resistant logs

Grade B · Automate

Problem. When an AI agent is the actor, the login and permissions are legitimate, so conventional timelines show nothing unusual and the triggering instruction may not survive log retention.

Approach

- Collect agent trajectories, tool calls and control decisions in tamper-resistant logs with reliable timestamps to reconstruct what the agent did.
- Responders apply a triage checklist; unexpected activity is escalated for human review or automated response.
- Uber is reported to run a production system covering more than 200,000 agent sessions a day (self-reported).

Evidence: Uber, Profero, NIST, NSA, CISA · security-incident-response-18

Monitors on AI agents page responders, with a 30-minute pause rule

Grade B · Automate

Problem. OpenAI says agent signals seen in late May 2026 were not escalated, and a security incident opened on 5 July did not recognise the broader significance.

Approach

- OpenAI reports pairing chain-of-thought monitoring with automated alerts that page researchers and security engineers when models take actions judged misaligned or dangerous.
- For the most severe alerts, responders pause the activity if they cannot establish within 30 minutes that it is a false positive.
- Anthropic says a real-time classifier blocks escape attempts before the tool call runs and alerts a human (self-reported).

Evidence: OpenAI, Anthropic · security-incident-response-19

Staged AI review of huge agent-activity records, a person confirming every case

Grade B · Augment

Problem. After a serious incident, OpenAI must find whether earlier activity also touched outside organisations; its records are about 50 petabytes, too large for manual review.

Approach

- Four automated steps narrow the population: credential search, fast AI pass, deeper pass rating seriousness, and behaviour grouping.
- Every surfaced case goes to human investigators, who decide on private notification, public reporting, both or neither.
- OpenAI reports over 100 organisations notified by 26 September 2026 (self-reported); each case takes 45 minutes to several days.

Evidence: OpenAI · security-incident-response-20

Notify affected organisations and report AI-agent incidents through a shared exchange

Grade B · Assist

Problem. When AI systems reach third-party systems there is no common standard for who is told, how fast, and what evidence is kept.

Approach

- The Open Secure AI Alliance proposed SAFE: confidential reports, an initial report within four business days, a remediation update within 90 days.
- Human reviewers assess disclosure and notification requirements case by case; reporting organisations decide what to submit.
- OpenAI reports notifying over 100 organisations as of 26 September 2026 (self-reported); this is a proposal.

Evidence: Open Secure AI Alliance, OpenAI · security-incident-response-21

Incident responders become builders and operators of agentic automations

Grade B · Augment

Problem. Incident response teams run 24x7 on-call and are asked to scale their impact and response consistency.

Approach

- Job postings at Databricks, GitLab, Twilio and Cloudflare treat AI and automation skills as part of the responder job.
- Databricks asks for proficiency in AI and agentic capabilities, with building and operating agentic systems preferred.
- Responders keep ownership of incidents end to end (GitLab); no outcome figures are published.

Evidence: Databricks, GitLab, Twilio, Cloudflare · security-incident-response-22

Vulnerability and exposure management

Discovery, validation, prioritisation, remediation, disclosure, pentest and red-team services; the 2026 disclosure surge. · 25 use cases · evidence strong (16 of 25 A/B)

Frontier AI finds flaws in open-source code, with outside experts checking first

Grade A · Delegate

Problem. Open-source maintainers lack the expertise and capacity to find flaws as fast as frontier AI models can, and unvalidated discovery floods them with reports.

Approach

- Anthropic ran Claude models over open-source code; six external security firms reproduce and assess findings, and reports follow a published disclosure policy.
- Maintainers acknowledge and patch; Anthropic's ledger shows 516 patched of 6,157 reported as of 2026-10-02 (self-reported).
- VulnCheck's independent analysis found 202 fixed of 26,153 findings, and Claude rated 91.5% critical or high against maintainers' 51.3% (independent).

Evidence: Anthropic, external security firms, VulnCheck · security-vulnerability-exposure-01

Multi-agent flaw-hunting tools run over an organisation's own code, feeding bug tracking

Grade A · Delegate

Problem. Mozilla says earlier AI code audits produced too many false positives to scale, and Cloudflare says a single coding agent wanders when asked to find vulnerabilities.

Approach

- Mozilla built a harness on fuzzing infrastructure; Cloudflare's hunter agents take narrow tasks and a second agent tries to disprove findings.
- Engineers triage, test and fix each bug; Cloudflare also requires a fix-or-dismiss decision on every validated finding.
- Mozilla fixed 271 bugs found by Claude Mythos Preview in Firefox 150 (self-reported); HackerOne ran a 30-day pipeline under Project Glasswing.

Evidence: Mozilla, Cloudflare, HackerOne · security-vulnerability-exposure-02

Open-source project curl uses several AI scanners and AI-assisted audits on itself

Grade A · Augment

Problem. A heavily fuzzed and audited project such as curl still hides bugs, and its small team receives floods of AI-assisted reports of mixed quality.

Approach

- curl has scanned its code with AISLE, ZeroPath and OpenAI's Codex Security for 8-10 months, plus AI review bots on pull requests.
- The curl security team triages every report; one Mythos Preview report listed 5 'confirmed' flaws and 1 held up (self-reported).
- Aisle's work led to 35 published curl vulnerabilities and CVE IDs, per the curl maintainer (self-reported).

Evidence: curl, Aisle, ZeroPath, OpenAI · security-vulnerability-exposure-03

AI flaw-hunting harness used in consulting, red-team and incident-response engagements

Grade A · Augment

Problem. Reviewing source code during assessments, penetration tests, red-team work and incident response is slow, while attackers can run machine-speed tools against the same code.

Approach

- Mandiant's harness, built on Google's Agent Development Kit, builds a threat model, hunts, validates and produces a prioritised, risk-rated list.
- The consultant approves the threat model before analysis continues, and a human expert reviews the findings.
- In one incident-response case it found over 100 true-positive critical vulnerabilities in two days; 12 CVEs assigned over about 10 months (self-reported).

Evidence: Mandiant, Google · security-vulnerability-exposure-04

AI agents run fuzzing campaigns, from writing harnesses to sorting crashes

Grade B · Delegate

Problem. Fuzzing needs people to write harnesses, watch coverage and triage crashes, which does not scale, and a bespoke campaign takes weeks of expert time per target.

Approach

- GitHub Security Lab's open-source taskflow has an agent write harnesses, run AFL++ and triage crashes; Trail of Bits built a zlib lab.
- Humans review every proposed patch and verdict, and findings go through coordinated disclosure with maintainers before publication.
- Trail of Bits estimates the lab took under a day against two to three weeks for an expert (self-reported estimate).

Evidence: GitHub Security Lab, Trail of Bits · security-vulnerability-exposure-05

Automated checking and de-duplication of AI-found flaws before people triage them

Grade B · Automate

Problem. AI tools generate findings faster than people can triage them, and unvalidated output causes alarm fatigue, duplicates and inflated severities.

Approach

- A validator re-tests each candidate, often by building a proof of concept in a sandbox; duplicates are removed and severity is corrected.
- Mandiant recommends an engineer review only tickets whose sandbox run succeeds; maintainers confirm severity.
- AWS's benchmark validator labelled 475 findings: 234 confirmed at high confidence, 159 false positives, plus 1,202 duplicates rejected (vendor-published).

Evidence: AWS, Mandiant, Cloudflare, Trail of Bits, Wiz · security-vulnerability-exposure-06

AI-assisted triage of incoming reports in bug-bounty and disclosure programmes

Grade B · Augment

Problem. Researchers use AI heavily, so submissions arrive faster than programme teams can validate, route and fix them, and duplicates and reproduction slow things down.

Approach

- GM's talk abstract describes Auto-Triage on HackerOne and Slack: duplicate detection, automated reproduction in sandboxes and a multi-agent severity assessment.
- Programme staff validate and assign; the abstract does not say where people review the severity assessment. No results published for GM.
- HackerOne survey: 53% of leaders report more AI-assisted submissions, 60% better quality (vendor-published).

Evidence: GM, HackerOne · security-vulnerability-exposure-07

AI agents helping product security teams handle reports, CVE feeds and disclosure

Grade B · Augment

Problem. Product-security teams face 40,000+ CVEs a year, complex supply chains and regulatory pressure with small teams; 85% of APAC teams have fewer than five members.

Approach

- GMO Cybersecurity by IERAE and Ken Associates presented at FIRST 2026 a move to multi-agent systems that automate response workflows.
- Humans keep critical decisions; Mozilla also deduplicates model-found bugs automatically. This is piloting, with no outcomes published.

Evidence: GMO Cybersecurity by IERAE, Ken Associates · security-vulnerability-exposure-08

Ranking flaws to fix using exploitation probability, exposure and AI-summarised threat intelligence

Grade C · Assist

Problem. Most disclosed vulnerabilities are never exploited, so ranking by severity alone swamps teams; only 26% of CISA KEV vulnerabilities were fully remediated in 2025.

Approach

- Mandiant's blueprint scores findings by severity, exposure, data sensitivity and threat context, and names LLMs as a way to summarise threat intelligence.
- Exploitation-probability models such as EPSS rank what to act on first; formal risk acceptance covers patching exceptions and deferrals.
- No measured outcome is published for an AI prioritisation step; the work is piloting.

Evidence: Mandiant, FIRST, CISA · security-vulnerability-exposure-09

Exposure-time targets and continuous exposure management instead of patching by volume

Grade C · Augment

Problem. If AI-driven discovery creates repeated waves of urgent updates, patching everything faster shifts risk to outages because testing and change management are the bottleneck.

Approach

- Gartner, via a secondary source, recommends measuring maximum tolerable exposure time, setting exposure-based targets and virtual patching where code fixes are blocked.
- The UK NCSC advises prioritising external attack surfaces and supplier hot-patching; executives accept residual exposure and deferrals. No outcomes published.

Evidence: Gartner (secondary report), UK NCSC, CISA · security-vulnerability-exposure-10

Standing workflow of AI scanning, machine triage and human confirmation for backlogs

Grade B · Augment

Problem. Teams that point frontier models at their code get a glut of findings and need a repeatable way to decide what is worth patching.

Approach

- A Red Hat security architect described a workflow scanning all OpenShift repositories; a base report is machine-triaged and AI drafts patches afterwards.
- People confirm or deny questionable findings and review AI-drafted patches.
- She said about 60% of AI-drafted patches were good, 20% arguably off design standards and 20% wrong (self-reported).

Evidence: Red Hat · security-vulnerability-exposure-11

Engineers direct AI agents to patch critical open-source software for maintainers

Grade A · Delegate

Problem. Frontier models create a flood of bug reports for stretched open-source maintainers; the expensive work is now confirming, rating, patching and coordinating disclosure.

Approach

- In Patch the Planet with OpenAI, Trail of Bits engineers direct and check agents writing patches and tests for projects like cURL.
- Maintainers decide whether to merge: by 2026-09-14 they had merged 126 of 186 reviewed pull requests (self-reported).
- A review of about 33,500 later commits found no exploitable security vulnerabilities linked to the patches (self-reported).

Evidence: Trail of Bits, OpenAI · security-vulnerability-exposure-12

Fully automated AI patch writing for known vulnerabilities, and its limits

Grade A · Automate

Problem. Disclosures are doubling, so defenders look to agents to write patches at scale without a person on the normal path.

Approach

- Agents are given a vulnerability and write patches that are graded; evidence comes from studies and competitions, not named production deployments.
- Skilled engineers review patches. In 1Password's study of six hard CVEs, 26.0% of iterations were clean fixes (independent).
- In DARPA's AI Cyber Challenge final, competitors' systems found 54 of 63 synthetic flaws and patched 68% (independent).

Evidence: 1Password, Trail of Bits, DARPA AIxCC · security-vulnerability-exposure-13

Checking AI-written security patches before merge, using the exploit as a test

Grade C · Augment

Problem. Passing the original exploit does not show a patch is right, because agents can memorise known fixes or hide the crash; human first fixes also fail 12.5% of the time.

Approach

- Trail of Bits announced two agent skills: one checks a patch fails on the flaw then passes, another walks engineers through diffs.
- An engineer reviews the patch and a person approves the merge; DeepMind says CodeMender upstreamed 72 security fixes (vendor-published).

Evidence: Trail of Bits, Mandiant, DeepMind · security-vulnerability-exposure-14

Automatic fixing of vulnerable software dependencies and container images

Grade C · Automate

Problem. Most vulnerable packages already have a fix, but upgrading safely is hard because most are transitive and minor releases still break builds.

Approach

- Snyk's announced agent applies a recommended upgrade, then scans, builds and tests; a BSides speaker built a CVE-fixing bot in CI.
- On 307 upgrade tasks Snyk's agent passed all four checks on 90.2% against 59.6% for unaided Claude Code (vendor-published).
- Human review is not stated: Snyk's benchmark used auto-approve.

Evidence: Snyk, an unnamed BSides speaker's team, Echo · security-vulnerability-exposure-15

Idea: AI agents deploying patches enterprise-wide to absorb a surge in fixes

Grade D · Automate

Problem. Idea, not a deployment: disclosure volumes have doubled and the UK NCSC expects a forced correction of technical debt, with exploitation sometimes before a patch exists.

Approach

- Idea: Google's threat intelligence group recommends combining edge defence with automated, agentic remediation; the NCSC advises update by default and hot-patching.
- No public enterprise deployment of agents that test, schedule and roll out patches was found; sources do not specify human checkpoints.

Evidence: No named deployment · security-vulnerability-exposure-16

Autonomous penetration-testing agents that discover, exploit and validate vulnerabilities

Grade A · Delegate

Problem. Quarterly penetration tests and reactive patching cannot keep pace with continuous AI-driven discovery, and enterprises own three to ten times more applications than they test.

Approach

- AWS Security Agent crawls a target, validates risks and chains exploits, with AWS auditing each win; researchers compared agents with ten professionals.
- It captured the intended flaw on 33 of 37 recent CVEs (vendor-published); in both misses it took the target down.
- ARTEMIS placed second, outperforming 9 of 10 human participants (independent); human oversight is advised for production work.

Evidence: AWS, ARTEMIS researchers · security-vulnerability-exposure-17

Autonomous outside-in testing across a whole external application estate, with safe proof

Grade B · Delegate

Problem. XBOW says enterprises own three to ten times more applications than they test, and scanners return findings without proof an outsider can use them.

Approach

- XBOW's agents run in parallel from an attacker's starting point with benign proofs and reproducible evidence per finding.
- The customer approves the target list before testing and can change what may be attacked; XBOW specialists coordinate.
- A consumer goods manufacturer says it assessed all its applications in four weeks (vendor-published).

Evidence: XBOW, a global consumer goods manufacturer · security-vulnerability-exposure-18

Consultancies use supervised AI in penetration testing and code review

Grade B · Augment

Problem. Tracing parameters across repositories, mapping attack surfaces and drafting findings consume much of a consultant's time, while fully automated testing misses chained and business-logic flaws.

Approach

- A Bishop Fox consultant used Claude across about 30 repositories to surface candidate bugs, then validated findings and demonstrated impact by hand.
- Consultants validate every finding; providers keep human testers on critical systems.
- The consultant says AI got him roughly 80% of the way (self-reported estimate); Amazon's security chief cited 40% efficiency gains (self-reported).

Evidence: Bishop Fox, Amazon, Wavestone, Cobalt · security-vulnerability-exposure-19

Independent accreditation of human-led AI use by penetration-testing providers

Grade B · Augment

Problem. Buyers and regulators want evidence that a penetration-testing provider uses AI securely and accountably, and providers expect clients to ask.

Approach

- Providers use AI mainly for reporting, reconnaissance and analysis, keep humans on higher-risk stages and can be assessed against CREST's AI annex.
- Qualified personnel review AI outputs; ten providers were accredited by 2026-09-03.
- 69% of providers use AI in penetration testing and 85% expect clients to ask about it (independent).

Evidence: CREST and accredited providers · security-vulnerability-exposure-20

AI agents probe the external perimeter to find and validate reachable exposures

Grade B · Augment

Problem. Inside-out data tools list what data exists but not what is reachable from the internet, and signature-based scanners ignore what a page actually contains.

Approach

- Wiz's Red Agent continuously discovers the perimeter, tests reachable endpoints, classifies and redacts sensitive content and sets severity before alerting.
- Wiz Research validates agent findings before private disclosure.
- Wiz says its Scan for Good work led to hundreds of public exposures being fixed (vendor-published).

Evidence: Wiz · security-vulnerability-exposure-21

Agent inside an exposure-management platform that acts only after human approval

Grade C · Augment

Problem. Agents with write access to a security platform can act past their authority, hallucinate about the customer's environment or be steered by text planted in hostnames or banners.

Approach

- Tenable describes an announced harness around its Hexa agents controlling context, tools, validation and logging; the agent is an untrusted insider.
- A human approves any change the agent proposes before it is made; no outcome figures published.

Evidence: Tenable · security-vulnerability-exposure-22

Idea: graph reasoning to re-rate findings that chain into critical paths

Grade D · Augment

Problem. Idea from research, not a deployment: agents treat an engagement as a flat list of findings, so low-severity issues that chain into critical paths are missed.

Approach

- A coding agent records findings in a graph and queries it for entry-to-crown-jewel paths and chain severity; the operator acts on results.
- In a synthetic test, three Medium findings became Critical once their path was shown (independent).

Evidence: No named deployment · security-vulnerability-exposure-23

Idea: AI-assisted enrichment and intake of CVE records at registry scale

Grade D · Automate

Problem. Idea, not a deployment: NVD submissions rose 263% between 2020 and 2025, and NIST could not clear the backlog and now enriches only prioritised CVEs.

Approach

- NIST says it is developing automated systems; Socket reports an unreleased AI-enabled tool and CISA described an intake platform for AI-discovered vulnerabilities.
- Users can email NVD to request enrichment or reanalysis of specific CVEs; no outcomes published.

Evidence: No named deployment · security-vulnerability-exposure-24

Idea: bounty and funding schemes that reward validated fixes, not only reports

Grade D · Assist

Problem. Idea, not a deployment: AI has made finding flaws cheap while triage, patching and release costs stay with under-resourced maintainers, and bounties do not fund remediation.

Approach

- Bugcrowd's chief strategy officer suggested programmes may offer bonuses for researchers who bring fixes and shared pools paying finder and maintainer team.
- Maintainers would accept the fix; this is not a deployed scheme and no outcomes are published.

Evidence: No named deployment · security-vulnerability-exposure-25

Application security

Threat modelling, AI-written code, code review, pipeline scanning, AI fixes, supply-chain intake. · 17 use cases · evidence strong (15 of 17 A/B)

AI agents help with security design reviews and threat modelling

Grade B · Augment

Problem. Security design reviews are a chronic bottleneck because specialists gather context by hand while developers wait.

Approach

- Anthropic's application security team says Claude assists threat modelling; Cloudflare runs a spec reviewer agent over design specifications before implementation.
- Stripe is scheduled to describe agents running the review lifecycle (talk not yet given); human experts take complex architectural decisions.
- Stripe reports reviews going from weeks to minutes; Cloudflare reviewed close to 600 specs since May 2026 (both self-reported).

Evidence: Anthropic, Stripe, Cloudflare, MongoDB, Mandiant · security-application-security-01

Security guardrails for AI-written code, with oversight set by code criticality

Grade C · Augment

Problem. Coding agents write production code that people review less, and studies find security flaws in a large share of AI-generated code.

Approach

- Security checks sit in the coding agent's loop: scans of every touched file, package firewalls, and security instruction files and rule packs.
- Developers review and test AI output as for any code; the UK NCSC advises manual coding for authentication, secrets and safety-critical code.
- Over 3 million write-time scans a week, 95% under 5 seconds (vendor-published); AI-generated code passes security 56% on average (vendor-published).

Evidence: Semgrep, Snyk, OpenSSF, UK NCSC · security-application-security-02

Disclosure and human accountability rules for AI-assisted code contributions

Grade B · Assist

Problem. Tool-generated contributions raise submission volume while reviewer and maintainer bandwidth is scarce, and provenance and legal certification of AI-written code are unclear.

Approach

- The Linux kernel project bars AI agents from adding Signed-off-by tags, because only humans can certify the contributor's legal statement.
- It asks for an Assisted-by tag naming the model, and a reproducer and tested fix for any bug an assistant finds.
- A human certifies origin and reviews the code before submission; no measured outcome is published.

Evidence: Linux kernel project · security-application-security-03

AI review of every pull request, including a dedicated security reviewer agent

Grade A · Augment

Problem. Merge requests queue for hours awaiting first review, and single-prompt AI review produced vague suggestions and noise, while lightweight security checks miss context-dependent vulnerabilities.

Approach

- Cloudflare runs up to seven specialised reviewer agents per merge request; a coordinator removes duplicates, rates severity and can block serious problems.
- Engineers can override a block: 288 times, 0.6% of merge requests; 131,246 review runs in the first 30 days (self-reported).
- At Atlassian a security review agent had 54% of comments validated by security engineers in a shadow deployment (self-reported).

Evidence: Cloudflare, Atlassian, Anthropic, Semgrep, curl · security-application-security-04

Engineering standards rewritten as machine-readable rules that review agents enforce

Grade B · Augment

Problem. Standards live in documents, chat threads and individual memory, so no engineer can read every standard and reviewers cannot reliably check every requirement.

Approach

- Cloudflare rebuilt its standards as a governed 'Codex'; an agent extracts rules that review agents retrieve for code, specifications and incident reports.
- Domain owners approve and promote documents; only those promoted to 'enforced' block merges, and engineers act on findings.
- Close to 230,000 standards violations flagged, almost 16,000 withheld approval (self-reported).

Evidence: Cloudflare · security-application-security-05

Risk-tiered automated review that lands low-risk code changes without a human reviewer

Grade B · Automate

Problem. AI coding agents increase code volume faster than reviewers can read it, and at Meta the share of changes getting timely review fell.

Approach

- Meta's RADAR scores each change for risk, runs AI code review and deterministic validation, and lands qualifying changes without a human reviewer.
- Changes failing the eligibility, risk-score or validation gates stay on the normal human review path.
- Meta reports 331K+ changes landed, a revert rate one third and production incident rate one fiftieth of non-RADAR diffs (self-reported).

Evidence: Meta · security-application-security-06

Scanning every code change before submission, with an agent proving reachability

Grade A · Augment

Problem. One-off scans of large code bases are slow and short on context, so vulnerabilities are found late while AI increases the amount of code needing security.

Approach

- Google's AI Infrastructure team scans each check-in with agents; a triage agent tests whether the vulnerable path is reachable.
- A bug-fix agent drafts fixes that go to human review in the change request; no checkpoint is stated for triage verdicts.
- Triage agent over 92% precision in under a minute; hundreds of vulnerabilities stopped per month (self-reported).

Evidence: Google · security-application-security-07

AI reasoning-based code scanning used alongside rule-based static analysis

Grade B · Augment

Problem. Rule-based scanners find only what someone wrote a rule for, miss business-logic and access-control flaws, and create noise that teams spend time triaging.

Approach

- Agentic scanners from OpenAI, Anthropic, Wiz, Semgrep and Snyk build an editable threat model, test findings in a sandbox and propose fixes.
- An analyst or developer reviews validated findings and approves patches; nothing is applied without human approval.
- OpenAI's beta cut noise 84% in one case and over-reported severity over 90% (vendor-published); GitHub's researcher reported 24 Android vulnerabilities (self-reported).

Evidence: OpenAI, Anthropic, Wiz, Semgrep, Snyk, GitHub · security-application-security-08

Reachability-first triage and closure tracking for AI-generated vulnerability candidates

Grade C · Augment

Problem. AI-assisted programmes generate more vulnerability candidates and patch pull requests than teams can review, so an opened pull request is not a fixed bug.

Approach

- Rubrik's product security lead is scheduled to describe (talk not yet given) a loop taking findings to merge, rejection, deferral or acceptance.
- It uses root-cause de-duplication, reachability ranking and no auto-patching of bug classes that cannot be validated cheaply; engineers review before merge.
- No operating-loop results are published.

Evidence: Rubrik, OpenAI, Google · security-application-security-09

Validator-gated AI testing of an organisation's own running web applications

Grade A · Delegate

Problem. AI code scanners flood security teams with unverified hypotheses, so a real flaw is hard to tell from a convincing hallucination, and candidates come without proof of exploitability.

Approach

- Google's PageBreak agent hypothesises web flaws in Google's own applications; a validator not written by AI confirms each against a running environment.
- Only deterministically validated findings go to product teams; unconfirmed ones are kept as seeds for later scans.
- PageBreak found over 500 cross-site scripting flaws in Google's first-party applications since a 2025 pilot (self-reported).

Evidence: Google, Snyk · security-application-security-10

AI agents build custom analysis tools and formal models before manual audits

Grade A · Delegate

Problem. Reviewing code in a new virtual machine with a custom assembly language and almost no tooling is slow, and manual review alone may miss classes of bugs.

Approach

- Before auditing the Miden virtual machine, Trail of Bits spent six months having agents build a language server, decompiler and formal model.
- Auditors use and check the tools during manual review; the audit had 95 machine-checked proofs and one high-severity issue (self-reported).

Evidence: Trail of Bits · security-application-security-11

AI-drafted fixes for scanner alerts and critical vulnerabilities, delivered as reviewable changes

Grade B · Augment

Problem. Developers often have little secure-coding training, so fixing scanner alerts takes substantial effort, and finding vulnerabilities is only half the work.

Approach

- LLMs draft a fix for an alert or vulnerability as a proposed change: GitHub's Copilot Autofix, Google's bug-fix agent, Meta's AI-written diffs.
- A developer reviews and accepts or edits every suggested fix.
- Meta is scheduled to report (talk not yet given) over 40% of critical vulnerabilities fixed by AI-written diffs (self-reported).

Evidence: GitHub, Meta, Google, Snyk · security-application-security-12

AI agent applies compiler bounds-safety annotations to remove whole classes of bugs

Grade B · Augment

Problem. Patching one bug at a time does not remove whole classes of memory-safety vulnerability, such as the libwebp heap overflow used in a zero-click iPhone exploit.

Approach

- DeepMind's CodeMender agent applied compiler bounds-safety annotations to parts of libwebp, fixing its own compile errors and test failures.
- Patches reach human reviewers only after static and dynamic analysis, differential testing, fuzzing and solver checks.
- It upstreamed 72 security fixes during the research (self-reported); this is a pilot.

Evidence: Google DeepMind · security-application-security-13

Automated AI screening of inbound packages, agent skills and outside pull requests

Grade B · Automate

Problem. Malicious packages reach developer machines before pull-request scans, models invent package names, skill marketplaces carry malicious skills, and anonymous pull requests can reach CI secrets.

Approach

- Automated gates screen inbound code: Semgrep's AI-assisted malware rules, Snyk's package firewall, ClawHub and Cisco skill scanners, OpenSearch's model gate.
- An expert verifies Semgrep's malware rules before publishing; no human check is stated for OpenSearch's gate.
- Independent testing bypassed all deployed skill scanners tested with four purpose-built malicious skills (independent).

Evidence: Semgrep, Snyk, ClawHub, Cisco, OpenSearch · security-application-security-14

AI-assisted research for curators of a vulnerability advisory database

Grade B · Assist

Problem. Advisory submissions surged, and the hard ones need package disambiguation, version-range reconstruction and reconciling conflicting upstream data, all of which takes human time.

Approach

- GitHub gave curators AI assistance in the research phase of advisory review, and better automation for extracting upstream CVE data.
- Curators make every decision, and reviewed advisories remain human-validated.
- 1,560 advisories were reviewed in May 2026, over five times a typical month (self-reported).

Evidence: GitHub · security-application-security-15

Testing AI security tools on contamination-reduced, audited benchmarks before trusting them

Grade B · Assist

Problem. Public benchmarks built from known CVEs can be memorised by models, exploit-only checks inflate results, and one scan can miss a bug the next run finds.

Approach

- Teams build their own harnesses: GitLab measures false positives and misses, AWS audits every success on refreshed CVE benchmarks, Semgrep tests memorisation.
- Experts review graders' verdicts, as Trail of Bits does.
- Semgrep found 93 of 176 judged solutions near-identical to real code (vendor-published); exploit-only validation inflated patching results 1.83 times (independent).

Evidence: GitLab, AWS, Semgrep, Trail of Bits · security-application-security-16

Security team rebuilt around building and operating its own AI skills

Grade B · Augment

Problem. Trail of Bits says most companies hand out chat licences without changing workflows; a year earlier about 95% of its staff were sceptical or resistant.

Approach

- Trail of Bits standardised on one coding agent, wrote an AI handbook of approved tools, and built a curated skills marketplace.
- Anthropic's application security engineers each own a Claude-powered security system; humans remain the auditors, under handbook approval rules.
- Trail of Bits reports 94 plugins, 201 skills and 84 agents, and 200 bugs a week on the right engagements (self-reported).

Evidence: Trail of Bits, Anthropic, GitLab, Cloudflare · security-application-security-17

Cloud and infrastructure security

Posture, runtime, Kubernetes, IaC, network and edge, endpoints including machines that run coding agents. · 24 use cases · evidence thin (5 of 24 A/B)

Ranking cloud findings by reachability, permissions and data access, with fix-first plans

Grade C · Augment

Problem. Cloud security tools raise more findings than engineers can fix, many with no route to harm, and teams investigate only about 4% of alerts.

Approach

- Platforms combine reachability, toxic permissions and sensitive-data access into attack paths; Microsoft's invitation-only preview agent produces a ranked, explained action plan.
- Findings reach engineers only after validation confirms exploitability, and people decide and act on the agent's plan.
- Wiz says more than half of initial high-priority findings were removed once these filters applied (vendor-published).

Evidence: Wiz, Microsoft, Tamnoon · security-cloud-infrastructure-01

Agent investigates cloud detections, is validated alongside analysts, then closes low-severity alerts

Grade B · Automate

Problem. Cloud detections need identity, network, runtime and code context from several consoles, and manual investigation across sprawling environments can take hours.

Approach

- Wiz's Blue Agent gathers evidence, compares activity with a baseline and gives a verdict; ZS first ran it alongside analysts.
- Analysts review what the agent closed at each shift's end, and higher-severity detections stay with analysts.
- ZS reports about 95.17% agreement with analysts (self-reported); Owkin reports a 75% cut in false-positive investigation time (vendor-published).

Evidence: ZS, Owkin, Redis, Wiz, Orca · security-cloud-infrastructure-02

In-house cloud triage agent with evidence rules and approval for access changes

Grade B · Augment

Problem. At Cohere one critical finding took 30 minutes to 2 hours to investigate; WRITER saw thousands of alerts with roughly 100 truly actionable, about a 2% signal rate.

Approach

- Cohere built an MCP server so its agent reads Wiz issues, checks duplicate tickets and writes notes back; WRITER built open-source Cerebro.
- Cohere analysts start from a populated report and ticket; WRITER requires human approval for IAM and network-boundary changes.
- Cohere reports about 145 SecOps hours a week eliminated and attack-path analysis cut to 20 seconds (vendor-published).

Evidence: Cohere, WRITER, Wiz · security-cloud-infrastructure-03

Combining weak runtime signals with posture context into one critical attack-sequence finding

Grade C · Augment

Problem. Individual runtime findings on EC2, ECS and EKS are noisy, and a runtime signal alone often stays below the threshold for a critical finding.

Approach

- Amazon GuardDuty correlates weak signals into one attack-sequence finding and, from 2026-05-20, attaches vulnerability, reachability, misconfiguration and sensitive-data indicators.
- Responders contain exposures, isolate reachable hosts, rotate credentials and patch.
- AWS says roughly one in four prioritised runtime-process attack sequences were net-new after the indicators were added (vendor-published).

Evidence: AWS · security-cloud-infrastructure-04

Read-only first-pass incident triage agent across a Kubernetes fleet

Grade C · Augment

Problem. First-pass triage of Kubernetes incidents needs pod state, logs, metrics and deployment history from many clusters before a person can act.

Approach

- A talk abstract describes an open-source agent, one per cluster, doing first-pass triage; the author says it never wrote to a cluster.
- Engineers receive the triage and act; the author reports 4 failures in over a year despite read-only permissions (self-reported).

Evidence: A European automotive manufacturer · security-cloud-infrastructure-05

Agent finds owner, root cause and fix layer, then drafts the remediation

Grade B · Augment

Problem. Security teams often do not know who owns a vulnerable resource or which layer to fix, and Wiz says routing can take longer than the fix itself.

Approach

- Wiz's Green Agent suggests an owner, traces root cause, gives a Remediate or Ignore verdict and drafts fixes; Orca, CrowdStrike offer similar.
- Teams choose whether to open a pull request or send the fix to a coding agent; sensitive systems need approval.
- project44 reports 10x faster vulnerability remediation (vendor-published).

Evidence: project44, Wiz, Orca, CrowdStrike, La Centrale · security-cloud-infrastructure-06

Evidence-gated automatic fixing of cloud misconfigurations: safe fixes run, risky await

Grade C · Automate

Problem. Tamnoon says teams investigate about 4% of alerts, critical misconfigurations sit unresolved 128 days on average, and human change boards cannot authorise fixes in minutes.

Approach

- Tamnoon scores findings SAFE, RISKY or UNSAFE: safe fixes run from playbooks, risky ones await approval, unsafe go to the owning team.
- Crossmint and Flywire practitioners built custom auto-remediation; high-impact or irreversible actions go to a person.
- A research prototype cut change-policy violations to 4.73% against 9.95% for a standard toolchain (independent).

Evidence: Tamnoon, Crossmint, Flywire · security-cloud-infrastructure-07

AI turns unused-access findings into least-privilege changes delivered as code pull requests

Grade C · Augment

Problem. Permissions accumulate, console fixes are overwritten at next deployment, and tightening access can break workflows; 59% of AWS IAM users had a key older than a year.

Approach

- An AWS daily automation reads Access Analyzer findings and uses Bedrock models to produce a pull request with code and plain-English explanation.
- The role-owning team reviews the pull request; at Smolen's pipeline, security reviews AccessDenied-driven pull requests.
- No outcome figures are published for the AWS automation or the Smolen pipeline.

Evidence: AWS, Smolen · security-cloud-infrastructure-08

Multi-agent cloud security team scores identity risk, applies controls and red-teams them

Grade C · Delegate

Problem. Most security teams have no dedicated cloud identity person, so access clean-up is nobody's priority.

Approach

- A fwd:cloudsec abstract describes four agents (identity, red team, threat intelligence, behaviour analytics) in a real AWS account with 500+ identities.
- Identity agent scored risk and applied controls, a red-team agent checked each control blocked its attack path; approval workflows gate dangerous actions.
- The author reports a 42.7% risk score reduction after five days (self-reported).

Evidence: One practitioner's AWS account (fwd:cloudsec) · security-cloud-infrastructure-09

AI-assisted discovery of new cloud privilege-escalation paths, validated in a lab first

Grade C · Augment

Problem. Language models surface new attack vectors quickly but also hallucinate issues that are not exploitable, which wastes researcher time.

Approach

- An agentic workflow pairs AI-driven discovery with deterministic integration tests in an open-source lab, so every candidate is validated before publication.
- The researcher decides what to publish after tests pass.
- The speaker reports over a dozen new AWS privilege-escalation paths found and validated (self-reported).

Evidence: One researcher (fwd:cloudsec) · security-cloud-infrastructure-10

Guardrails and independent checks for AI-written infrastructure code

Grade C · Augment

Problem. AI assistants now write most infrastructure code in many organisations, and valid Terraform is not necessarily secure; repairs can satisfy a scanner while leaving the flaw.

Approach

- A reference architecture has an MCP server expose approved Terraform modules, run policy checks, auto-fix eligible violations and open a pull request.
- High-risk exceptions go to humans, and destructive changes land as pull requests for review.
- Independent research found 71.4% of plan-compared LLM repairs of Terraform misconfigurations were deceptive (independent).

Evidence: Datafruit, Wiz, fwd:cloudsec presenter · security-cloud-infrastructure-11

Idea: agents detect drift from infrastructure code and propose reconciling updates

Grade D · Augment

Problem. Idea, not a deployment: when consoles and scripts are used alongside infrastructure code, deployed systems drift from the specification and later runs may undo valid changes.

Approach

- Idea from research: agents read API traces to detect out-of-band change and propose infrastructure code updates, with a verifier agent.
- Human checkpoints are not described; engineer review before merge is inferred.
- Research prototypes report drift reconciliation accuracy of 0.71 to 0.97 (independent).

Evidence: No named deployment · security-cloud-infrastructure-12

Virtual patching at the firewall and network layer, with AI-assisted rules

Grade C · Augment

Problem. Patching takes weeks (a 43-day median for critical flaws is cited), and tuning web firewall rules across hundreds of technology stacks does not scale with headcount.

Approach

- An Adobe manager's talk abstract describes AI-assisted rule generation and tuning in a human-in-the-loop pipeline; Palo Alto Networks announced network-level virtual patches.
- Humans approve rules; the abstract claims a capability of going from 43 days to single-digit minutes (self-reported claim).

Evidence: Adobe (speaker), Palo Alto Networks, IBM, Red Hat · security-cloud-infrastructure-13

AI firewall policy hygiene: flagging stale, overly permissive and conflicting rules

Grade C · Augment

Problem. Firewall rulebases grow through temporary exceptions and cloud deployments, and Check Point says policies become risky after months of change, with reviews waiting for the next cycle.

Approach

- Cato Networks' announced agent compares rule behaviour with traffic and flags forgotten and overly permissive rules; Check Point finds redundant, conflicting rules.
- Administrators select which recommended rules to apply; no outcome figures are published.

Evidence: Cato Networks, Check Point · security-cloud-infrastructure-14

AI turns firewall intent into rules, with change-impact checks grounded in topology

Grade C · Augment

Problem. Firewall change-impact analysis used to come from outside tools, and language models translate intent well but miss policy violations when not grounded in topology.

Approach

- Fortinet, Palo Alto Networks, Check Point and Cisco announced features that take an intent, write a rule and report its effect.
- The change board signs the change, and human approval or a policy check precedes any AI-initiated network change.
- A research prototype cut missed policy violations by over 30% (independent); no vendor adoption figures are published.

Evidence: Fortinet, Palo Alto Networks, Check Point, Cisco · security-cloud-infrastructure-15

Runtime guardrails and telemetry for coding agents on developer endpoints

Grade B · Automate

Problem. Coding agents act on privileged developer endpoints, users switch approvals off, and an agent can cause an incident without malicious input.

Approach

- Perplexity open-sourced Numbat, which hooks into coding agents, enforces rules, records activity and sends telemetry; a scheduled agent proposes tested detection changes.
- Rule changes the agent proposes go through human-reviewed pull requests.
- It runs on thousands of Perplexity endpoints, with no detection-quality figures published (self-reported).

Evidence: Perplexity · security-cloud-infrastructure-16

Idea: AI agents tune endpoint detection policy from a bounded catalogue

Grade D · Automate

Problem. Idea, not a deployment: commercial endpoint detection now includes autonomous AI parts, so an agent tuning it acts on a black box that can change its own behaviour.

Approach

- Idea from research: an LLM agent selects hardening actions from a finite, tool-enforced catalogue, tested in a lab against a commercial product.
- A prototype cut the attacker's expected payoff 59% against a greedy baseline (independent); human checkpoints are not described.

Evidence: No named deployment · security-cloud-infrastructure-17

AI-assisted cloud detection engineering, with testing that catches hallucinated log fields

Grade C · Assist

Problem. Detection engineers must write and maintain rules across cloud telemetry as threats change, and one AWS rule sat in a production SIEM nine months without firing.

Approach

- Wiz and Cloudflare postings list AI use for detection and log analysis; a Meta engineer's open-source analyser checks rule fields against schemas.
- Detection researchers own and review rules.
- The Meta engineer found significant quality defects in 1 in 3 cloud detection rules in two public repositories (self-reported).

Evidence: Wiz, Cloudflare, Meta (speaker) · security-cloud-infrastructure-18

Idea: agents run attack simulations in sandboxes to map telemetry to techniques

Grade D · Delegate

Problem. Idea, not a deployment: cloud detection engineering is hobbled by poor telemetry documentation and vague, static mappings from log entries to attack techniques.

Approach

- Idea from a conference abstract: agents run attack call graphs in sandbox accounts on three clouds and record which telemetry actually fires.
- Detection engineers curate the resulting knowledge base; review steps are not described and no results are published.

Evidence: No named deployment · security-cloud-infrastructure-19

Idea: cloud canaries and deception to detect and steer autonomous AI attackers

Grade D · Augment

Problem. Idea, not a deployment: frontier agents can chain attack steps in the cloud, and compromise rate alone says little about whether defenders can see them.

Approach

- A lab scored 10 models across 599 autonomous attack runs in a hard AWS environment, with canaries and deception present or absent.
- Canary hits go to the normal detection and response queue; results and review steps are not in the abstract.

Evidence: No named deployment · security-cloud-infrastructure-20

Continuous cloud compliance: AI-assisted evidence collection and policy written as code

Grade C · Augment

Problem. Point-in-time compliance checks cannot keep pace with dynamic cloud environments, and public-sector teams need AI discovery and remediation inside a FedRAMP High boundary.

Approach

- Wiz announced on 2026-10-14 its agents are available in its FedRAMP High environment; research turns plain-language policy into executable rules.
- Human approval is configurable per workflow for sensitive systems.
- A research prototype's rules compiled 95.3% of the time (independent); no figures published for Wiz's agents.

Evidence: Wiz, NIST (draft profile) · security-cloud-infrastructure-21

Shared security AI platform team on which security functions build governed agents

Grade B · Augment

Problem. Each security function wants agents, and Databricks lists high-risk workflows such as offensive personas, untrusted inputs, sensitive data, production access and automated tool execution.

Approach

- Databricks advertises a team owning a shared platform where security functions build governed agents, covering identity, sandboxing, policy enforcement, auditability and evaluation.
- Domain teams own their agents' outcomes; the platform team owns guardrails. This is piloting; CrowdStrike sells a similar product.
- No figure for Databricks.

Evidence: Databricks, CrowdStrike, Robinhood, Block · security-cloud-infrastructure-22

Managed cloud security services delivered on a multi-tenant AI security platform

Grade C · Augment

Problem. Managed service providers juggle fragmented consoles, client policies and scattered visibility, which slows response as client estates grow.

Approach

- Wiz announced on 2026-09-28 a provider programme with multi-tenant management, just-in-time provisioning and portfolio dashboards; Optiv, SEP2 and Deloitte are quoted.
- Wiz says analysts can review and audit the Blue Agent's investigation and verdict; no outcome figures published.

Evidence: Wiz, Optiv, SEP2, Deloitte · security-cloud-infrastructure-23

Idea: runtime control layer deciding whether live cloud actions proceed or escalate

Grade D · Automate

Problem. Idea, not a deployment: SACR argues cloud security platforms still rely on periodic telemetry and human remediation queues while workloads and AI actions change in seconds.

Approach

- SACR defines a runtime layer linking platform evidence to a decision to proceed, constrain, remediate or escalate, with audit-grade records.
- Escalation sends the action to a person; where that boundary sits was unresolved across CSA's summits.

Evidence: No named deployment · security-cloud-infrastructure-24

Identity and access

Joiner-mover-leaver, requests and reviews, privileged access, authentication, ITDR, proofing, help-desk and caller fraud. · 24 use cases · evidence moderate (11 of 24 A/B)

Daily agent scan of sign-in policies for gaps, with administrator-approved fixes

Grade B · Augment

Problem. Conditional Access policy sets grow over time, so new users, apps and agent identities fall outside MFA or device controls, and finding gaps meant reading policy logic by hand.

Approach

- A Microsoft Security Copilot agent scans Entra Conditional Access policies every 24 hours and proposes a report-only policy or an edit.
- An administrator reviews each suggestion and rationale before approving; report-only mode and phased rollout show impact before enforcement.
- Microsoft reports 26 policy gaps per customer per month and 73% of customers improving posture (vendor-published).

Evidence: Microsoft · security-identity-access-01

Agent-planned passkey adoption campaigns for privileged administrators

Grade C · Delegate

Problem. Moving administrators to phishing-resistant sign-in needs readiness checks, nudges, grace periods and a final enforcement switch, which is manual coordination at scale.

Approach

- Microsoft's announced Conditional Access Optimization Agent finds eligible administrators, checks device and passkey readiness, generates a four-stage plan and guides users.
- An administrator reviews the plan, can edit targeted users and grace periods before deploying, and can dismiss suggestions; no outcomes published.

Evidence: Microsoft · security-identity-access-02

AI reviewer for access requests approves routine ones and escalates the rest

Grade B · Automate

Problem. Access needing a manager's approval sits in queues, approvers lack context, and Opal found 43.5% of granted access went unused for over 90 days.

Approach

- Instacart's open-source Gadjit bot compares requester and entitlement holders and approves above a threshold; Opal's Paladin agent decides with a rationale.
- In Opal's design risky or ambiguous requests go to a person; what Instacart does below the threshold is not stated.
- Instacart says accuracy in testing is nearly 100% (vendor-published).

Evidence: Instacart, Opal · security-identity-access-03

Zero standing privilege: just-in-time grants and revocation for privileged access

Grade C · Automate

Problem. Privileged access is still mostly always-on; Palo Alto Networks says 61% of privileged requests are fulfilled with standing privilege, while regulators require need-to-use access.

Approach

- Vendors replace always-on admin rights with task-based access, revoked when risk changes; Palo Alto Networks, CrowdStrike and SailPoint announced products.
- Approval of elevation requests is not described in the vendor sources, though DORA requires ad hoc assignment.
- Instacart moved 95% of privileged permissions to just-in-time access using a rule-based engine, not AI (vendor-published).

Evidence: Palo Alto Networks, CrowdStrike, SailPoint, Instacart · security-identity-access-04

Conversational assistant for employee IT and access questions and requests

Grade B · Augment

Problem. Employees must already know which of about 1,500 applications to ask about access, devices and VPN, so requests go to the wrong place.

Approach

- Okta built Dex, an orchestrating agent acting as one front door for IT, people and expense support, checked against the user's access.
- SailPoint announced an agent for natural-language access requests in chat tools, collecting business justification; Dex's human checkpoints are not described.
- Okta reports 25% adoption in two weeks and over 23,500 interactions (self-reported).

Evidence: Okta, SailPoint · security-identity-access-05

Evidence-based recommendations and an AI first pass on access review decisions

Grade B · Augment

Problem. Regulators set review frequencies that create heavy reviewer work, and reviewers face long lists with little context, so many reportedly approve everything.

Approach

- Review screens carry recommendations: Entra suggests Deny for inactive users, SailPoint uses peer analysis, Lumos an AI first pass, Opal low-risk clearing.
- Application owners and managers approve or deny each item; Opal says risky calls always reach a person.
- Lumos states campaigns finish up to 6x faster than spreadsheet reviews (vendor-published); no error rates published.

Evidence: Microsoft, SailPoint, Lumos, Opal · security-identity-access-06

Usage-based role mining and entitlement right-sizing recommendations

Grade C · Augment

Problem. Roles are hand-curated, reviewers face dense entitlement lists they cannot evaluate, and 56% of survey respondents cannot enforce continuous least privilege for service accounts.

Approach

- Google's IAM recommender examines up to 90 days of permission use and recommends removing or replacing roles with excess permissions.
- Opal lists role mining as where its agent is going; recommendations only suggest removal, and applying them is a separate step.
- No reduction in excess permissions or accuracy is published; announced products from Google, Opal and Omada.

Evidence: Google, Opal, Omada · security-identity-access-07

Continuous full-population identity posture checks with remediation and recorded evidence

Grade C · Automate

Problem. Periodic certifications and dashboards find stale access after the fact and flag risks without fixing them, while several regulations require documented, periodic proof of who has access.

Approach

- SailPoint's announced posture product detects dormant accounts, orphaned access and shadow admins, then remediates; Saviynt and Palo Alto Networks describe similar tools.
- One-click fixes leave the decision with an administrator; fully automated enforcement is an opt-in. No outcomes published.

Evidence: SailPoint, Saviynt, Palo Alto Networks · security-identity-access-08

Natural-language governance queries, audit preparation and workflow drafting for identity administrators

Grade C · Assist

Problem. Preparing for a governance audit means pulling data from several admin screens, and administrators spend time configuring and diagnosing joiner-mover-leaver workflows.

Approach

- Security Copilot in Microsoft Entra answers governance prompts such as pending access reviews and who approved or denied, and guides new workflows.
- The administrator still creates and enables the workflow; Copilot output is guidance. No figures published.

Evidence: Microsoft · security-identity-access-09

Agentic onboarding of connected and disconnected applications into identity governance

Grade C · Augment

Problem. Bringing applications under identity governance is a long-running bottleneck, and 49% of organisations do not track how many disconnected apps they have.

Approach

- Saviynt announced on 2025-10-15 agentic onboarding to speed integration of connected and disconnected applications into one governance platform.
- Human checkpoints are not described and no outcomes are published.

Evidence: Saviynt · security-identity-access-10

Idea: AI-drafted access policy code, checked by tests before human review

Grade D · Augment

Problem. Idea, not a deployment: access requirements written in prose must become enforceable policy code, and even frontier models often produce policies that violate the intended authorisation.

Approach

- Idea under study: an LLM drafts policy code, then validation, tests or a formal verifier check it before a person reviews it.
- In research a structured pipeline reached 50.3% correct Rego policies against 15.3% for a single prompt (independent); human review is not studied.

Evidence: No named deployment · security-identity-access-11

IAM engineers building identity automation with AI coding tools and LLMs

Grade B · Assist

Problem. Identity teams run single sign-on, account provisioning, role models and privileged-access platforms with small staffs and many applications.

Approach

- Cloudflare's postings require experience using AI and LLMs on operational problems and judgment on when to trust them; Coinbase expects human oversight.
- Engineers review and own AI-assisted changes; no outcomes are published.

Evidence: Cloudflare, Coinbase · security-identity-access-12

Risk summaries and next steps for risky users, plus a risk agent

Grade C · Augment

Problem. Investigating identity risk needs context that administrators and security analysts must gather before deciding what to do with a flagged user.

Approach

- In Microsoft Entra ID Protection, Copilot explains why a user's risk was raised and lists next steps; a preview agent monitors continuously.
- Summaries and recommendations are advice; the administrator or analyst decides on remediation. No outcomes published.

Evidence: Microsoft · security-identity-access-13

Machine-learning scoring of sign-ins and sessions with automatic step-up, block or logout

Grade C · Automate

Problem. Policies checked only at sign-in miss session hijacking and token theft later; Okta cites 1.9 billion session cookies stolen from Fortune 1000 employees in 2022.

Approach

- Microsoft and Okta compute sign-in and session risk from anomalies and feed policy that can require step-up, block or end sessions.
- Administrators monitor risk profiles, response flows run through customer-defined workflows, and an administrator can confirm a user as compromised.
- Only a customer quote of hours saved daily is published, organisation not named (vendor-published).

Evidence: Microsoft, Okta · security-identity-access-14

Closed-loop identity threat response acting on high-confidence detections without a ticket

Grade C · Automate

Problem. Identity attacks are detected quickly but response waits in a human queue: 68% detect within 24 hours but 55% contain within that window.

Approach

- Netwrix describes automation running pre-defined responses, such as disabling an account, once a high-confidence threshold is met, rolled out in stages.
- A second, lower threshold routes cases to human review; Palo Alto Networks proposes a joined-up loop. No outcomes published.

Evidence: Netwrix, Palo Alto Networks, SANS · security-identity-access-15

Managed detection and response extended to cloud-application identity threats, with agentic workflows

Grade C · Augment

Problem. Compromised identities give attackers legitimate access to cloud applications, which lets them operate undetected.

Approach

- CrowdStrike announced on 2026-09-02 that its managed detection and response service now covers identity and SaaS signals through Falcon Shield, 24/7.
- It uses high-fidelity detections, agentic workflows and expert-led operations; response is expert-led. No outcomes published.

Evidence: CrowdStrike · security-identity-access-16

AI agents hunt and write detections for identity-targeting browser attacks

Grade B · Delegate

Problem. Attacks on identities change weekly or daily and indicators are cheap to rotate, so human-only detection engineering takes days or weeks per technique.

Approach

- Push Security's agents ingest new research, form hunt hypotheses, test queries on browser-session metadata, triage matches and draft detections.
- Researchers ship the detections.
- Push reports tripled new detections shipped each month after adopting the pipeline (self-reported).

Evidence: Push Security · security-identity-access-17

Enforced identity checks before help-desk password, MFA and account-recovery actions

Grade B · Automate

Problem. Attackers call help desks posing as employees to get password and MFA resets, and cloned voices make it harder for staff to judge a caller.

Approach

- No reset proceeds until the requester passes an enforced step; at Cisco, a chatbot triggers a Persona government ID and selfie check.
- Failed verifications go to support agents and a documented escalation workflow; in Nametag's flow the agent decides after seeing the result.
- Cisco says regaining access dropped from three or four hours to as little as five minutes (vendor-published).

Evidence: Cisco, Persona, Nametag, Okta · security-identity-access-18

Machine-learning identity proofing with document checks, liveness and deepfake detection

Grade B · Automate

Problem. Remote onboarding and recovery rely on a selfie and a document image, and criminals use generative AI to alter documents and media and inject forged media into capture.

Approach

- Layered checks cover documents, face match, liveness, camera tests and media analysis; Coinbase's team owns these models and its own evaluation set.
- Failed or suspicious cases go to people; NIST says automated decisions should be augmented by manual review.
- In a DHS test the median tested subsystem detected 78% of over 1,200 attacks (independent).

Evidence: Coinbase, DHS test, FinCEN, Nametag · security-identity-access-19

Identity-graph models and biometric search to find duplicate enrolments, rings and bots

Grade B · Automate

Problem. Fraud rings reuse biometric, device and document signals across accounts, enrol the same face under different names and run bots that mimic humans.

Approach

- Coinbase is hiring to build graph models clustering accounts by shared signals; Cloudflare's fraud platform routes decisions to people.
- Manual review confirms every automated one-to-many match before an enrolment is declined. No outcomes published.

Evidence: Coinbase, Cloudflare · security-identity-access-20

Continuous background caller authentication in the contact centre instead of security questions

Grade A · Automate

Problem. Stolen breach data lets fraudsters answer security questions: across 2,500 fraud calls at 10 institutions they passed 53% of the time.

Approach

- Pindrop Passport analyses voice, device and behaviour in the background, so callers are verified in seconds and agents see risk notifications.
- Agents route elevated-risk calls; MSUFCU and HealthEquity use it.
- MSUFCU cut average authentication from 90 to 45 seconds (vendor-published).

Evidence: Pindrop, MSUFCU, HealthEquity · security-identity-access-21

Real-time call risk scoring to catch account-takeover and impersonation fraud by phone

Grade B · Augment

Problem. Contact-centre fraud checks are slow, run after the fact and rely on quizzes that fraudsters pass; Virginia Employment Commission lost an estimated $350M in three years.

Approach

- Pindrop Protect scores risk throughout the call; at the commission the score decides whether a caller gets a callback or fraud agent.
- Agents see colour codes and investigators run cases from flagged calls.
- HealthEquity reports voice fraud down over 90% (self-reported); the commission detected over 800 potentially fraudulent calls (vendor-published).

Evidence: Pindrop, Virginia Employment Commission, HealthEquity · security-identity-access-22

Synthetic-voice detection on contact-centre and meeting audio, with fraud-triage risk scores

Grade C · Augment

Problem. Voice biometrics and callback checks were not designed for AI-generated speech, and a tier-one global bank saw deepfaked calls pass both.

Approach

- Reality Defender analysed recorded calls for an unnamed bank, then moved to real-time detection for about 600 frontline staff, returning risk scores.
- Fraud analysts triage scored calls under a new triage and escalation process.
- About 960 synthetic voice calls were found among over 1.7 million analysed (vendor-published).

Evidence: Reality Defender, an unnamed global bank · security-identity-access-23

Behavioural biometrics and continuous authentication to detect account takeover and scams

Grade C · Augment

Problem. Payment monitoring does not address pre-payment risks such as identity theft, account takeover and scams; FBI IC3 logged USD 359.7 million in account-takeover losses in 2025.

Approach

- Typing, gesture and mouse behaviour is analysed to detect identity theft, takeover and mule accounts pre-payment; Visa announced intent to acquire BioCatch.
- Human checkpoints are not described, and no customer result is named.

Evidence: BioCatch, Visa (announced acquisition) · security-identity-access-24

Data security and privacy

Discovery, classification, DLP, access governance, keys, privacy engineering, data exposure through AI tools. · 21 use cases · evidence moderate (8 of 21 A/B)

AI agents describe and tag data-catalog columns, with stewards approving each

Grade B · Augment

Problem. Data lakes gain tables faster than stewards can document or classify them, so columns lack descriptions and sensitivity labels.

Approach

- Glyph, a production system of cooperating AI agents, writes column descriptions and assigns labels from a governed 275-label list, never reading values.
- A data steward accepts or rejects every suggested column-tag pair; decisions feed weekly retraining.
- Steward acceptance rose from 63.3% to 99.8% over six weeks (self-reported); the authors call this an association, not a cause.

Evidence: Apple authors (arXiv paper) · security-data-privacy-01

Rules-first data classification with AI fallback that distils stable findings into rules

Grade A · Automate

Problem. Privacy controls need a reliable view of what each data asset is, and manual review cannot keep pace with AI-native products.

Approach

- Meta describes a hybrid classifier: versioned rules answer first, and an AI model handles only novel or ambiguous assets.
- About 85% are answered by rules in milliseconds; about 15% go to the AI fallback at roughly 400 times the cost (self-reported).
- People adjudicate reference labels and approve rule promotions; low confidence, judge disagreement or rare sensitive classes escalate to human review.

Evidence: Meta · security-data-privacy-02

Instruction-driven Gemini labelling of Google Drive files, replacing admin-trained models

Grade C · Augment

Problem. Label-based data loss and retention policies only work on correctly labelled files, and labelling put a considerable manual burden on admins.

Approach

- Google announced an open beta in which Gemini applies classification labels to Drive files from administrator-written instructions, with no model training.
- File owners and editors with label permission can accept or modify each Gemini-applied label; audit logs record decisions.
- Google states it helps admins reach higher accuracy at scale; no figures published (vendor-published).

Evidence: Google (vendor announcement) · security-data-privacy-03

Plain-language sensitive-data search and credential scanning with an AI agent (preview)

Grade C · Assist

Problem. Searching for relevant data and finding out how it is protected is, in Microsoft's words, time-consuming, tedious and highly manual.

Approach

- Microsoft Purview's Data Security Posture Agent interprets plain-language requests, searches Microsoft 365 content and returns results with an AI-written risk analysis.
- A second preview agent scans Microsoft 365 for exposed credentials and tracks remediation tasks on a board.
- The requester reads the results and decides what to act on; Microsoft claims quick results, no figures (vendor-published).

Evidence: Microsoft (vendor documentation) · security-data-privacy-04

AI-native platforms that find, classify and fix sensitive data across cloud

Grade B · Augment

Problem. Organizations do not know what sensitive data they hold or where; Varonis telemetry across 1,000 environments found only about one in ten companies had labelled files.

Approach

- Cyera customer stories describe agentless scanning to classify sensitive records, then clean-up; the pages say little about how AI contributes.
- ChenMed resolved more than 32,000 data security issues across 30 policies; Paramount scanned trillions of records, billions sensitive (vendor-published).
- Security and data owners decide which findings to remediate; Vetcor says tabletop exercises validated what data an attack would expose.

Evidence: Cyera customers ChenMed, Paramount, Vetcor · security-data-privacy-05

AI agent sorts data-loss alerts into urgency queues with written rationale

Grade C · Augment

Problem. Triaging and prioritising data loss prevention alerts is complex and time-consuming, and false positives and alert fatigue strain analysts.

Approach

- Microsoft Purview's Triage Agent reads alerts across Exchange, Teams, OneDrive, SharePoint and endpoints, analyses the files and sorts them, with an explanation.
- Admins can add plain-language custom instructions (preview); Microsoft says prioritisation reduces triage time, no figures (vendor-published).
- Analysts review each categorised alert and rationale and can overrule it through feedback.

Evidence: Microsoft (vendor documentation) · security-data-privacy-06

Context-aware AI data-loss classification replacing pattern-matching to cut false alerts

Grade B · Augment

Problem. Legacy data loss prevention tools struggled with nuanced unstructured files and produced so many false positives that OpenWeb's team could not trust the alerts.

Approach

- OpenWeb replaced its tools with MIND, which the vendor says uses a proprietary AI engine to classify unstructured data with context.
- OpenWeb's CISO: DLP effort 'probably a fifth' of before; a US financial institution's 16,000 false positives fell to 'just a handful' (vendor-published).
- Human review is not described in detail; the bank's security, privacy and governance teams share a risk-driven programme.

Evidence: OpenWeb, MIND, Cyera, unnamed US bank · security-data-privacy-07

Inline data-loss controls on prompts, pastes and uploads to generative AI tools

Grade C · Automate

Problem. Staff paste source code, regulated data and credentials into generative AI tools; only 29% of surveyed firms can routinely report what was sent.

Approach

- Microsoft Purview endpoint policies can warn or block users pasting sensitive information into third-party AI sites, and inspect prompts in supported apps.
- A Hacker News commenter describes a proxy that tokenises personal data and blocks secrets.
- Policy owners decide warn versus block; users may be shown a warning they can override. Baselines come from vendors and a survey.

Evidence: Microsoft, Netskope, Cyberhaven, CSA survey · security-data-privacy-08

Discover shadow AI use; block or steer unsanctioned AI apps and accounts

Grade C · Automate

Problem. Employees adopt AI tools outside security and procurement review, and AI features appear inside existing apps without governance being told.

Approach

- Netskope reports 90% of organizations block at least one generative AI app, and personal-account use fell from 78% to 47% (vendor-published).
- OWASP recommends an allowed-tool policy, a central AI service catalogue with security and privacy review, and data loss controls.
- Security and procurement owners approve the allowed-tool list and review new AI services. Akamai announced and then completed its LayerX acquisition.

Evidence: Netskope, OWASP, Akamai · security-data-privacy-09

Assess and reduce oversharing before and during rollout of AI assistants

Grade C · Augment

Problem. AI assistants surface content quickly, amplifying existing oversharing; Varonis reports 99% of 1,000 environments hold sensitive data AI can easily surface.

Approach

- Microsoft Purview's posture tool tracks AI activity such as oversharing and unusual access, and offers data risk assessments.
- SharePoint Restricted Content Discovery removes chosen sites from organization-wide search and Copilot as a temporary control while permissions are fixed.
- Admins choose which sites to restrict and decide on permission clean-up. The 99% figure is a baseline (vendor-published).

Evidence: Microsoft, Varonis · security-data-privacy-10

Agents propose and, with approval, fix exposed data such as public links

Grade C · Augment

Problem. Access and sharing problems are found in dashboards but fixed by hand, one object at a time.

Approach

- Microsoft says Purview's posture tool uses Security Copilot and AI agents to analyse access and sharing, prioritise risks and act on them.
- Actions include removing public sharing links, applying data loss policies or revoking permissions.
- Administrators review, approve or customise automated actions, which are always audited. No outcome figures published (vendor-published).

Evidence: Microsoft (vendor documentation) · security-data-privacy-11

Enforce labels and user access when AI assistants retrieve content, including indexes

Grade C · Automate

Problem. In an AI system, retrieved passages, prompts and tool output sit in one flat space with no internal access control, and classification rules rarely reach embeddings or backups.

Approach

- Microsoft says supported AI apps withhold content from users lacking access; encrypted labels need view and extract rights.
- OWASP recommends labels follow every derivative, retrieval enforce per-document access control, and erasure cover derived copies.
- A research prototype, ARBITER, filters retrieval queries by role at 85% accuracy (independent); OWASP recommends human review of high-impact corpora.

Evidence: Microsoft, OWASP, ARBITER researchers · security-data-privacy-12

AI-guided workflow turning privacy requirements into enforceable data controls using data lineage

Grade B · Augment

Problem. Turning written privacy requirements, especially purpose limitation, into controls across large data systems is slow, error-prone and hard to validate.

Approach

- Meta engineers described an AI-guided workflow that breaks requirement text into implementable tasks and walks data lineage to find affected datasets.
- It suggests enforcement and monitoring points and tracks each requirement through to verification.
- The session reports where automation helped and where human judgment stayed essential, including misinterpretations and lineage gaps (self-reported); no figures.

Evidence: Meta · security-data-privacy-13

AI detection of privacy-relevant code patterns in pull requests, using retrieved examples

Grade B · Augment

Problem. Many privacy failures come from ordinary coding choices; Default Grant Access, where access is allowed unless blocked, is hard for static analysis to catch.

Approach

- Microsoft reported deploying AI detection of Default Grant Access in pull requests at scale, then adding retrieved examples from known incidents.
- The retrieval version found more than twice as many confirmed issues; false positives did not significantly improve (self-reported).
- Code reviewers see detections inside the pull request review and confirm issues.

Evidence: Microsoft · security-data-privacy-14

AI first drafts of privacy impact assessments, reassessments and evidence reviews

Grade C · Augment

Problem. Product teams often lack privacy expertise, and privacy teams manage manual assessments with 'assessment fatigue' and constrained budgets.

Approach

- OneTrust's Winter '26 release drafts reassessment answers from earlier evaluations and reviews evidence files, giving a summary, justification score and gaps.
- Academic work tests the idea: Privy gives non-experts a first draft of risks, which 13 privacy experts rated high quality (self-reported).
- Privacy staff validate AI-completed fields and review scores; experts still make high-impact decisions.

Evidence: OneTrust, Privy researchers, PIA-Bench authors · security-data-privacy-15

Idea: AI detection of personal data to redact prompts, logs and text

Grade D · Automate

Problem. This is an idea, not a deployment: AI providers mask personal data in conversations, yet most detectors and benchmarks target self-contained records, not multi-turn dialogue.

Approach

- Researchers compare rule-based, encoder and AI detectors on benchmarks; a rule-based detector recalled only 0.07 on high-sensitivity categories (independent).
- No detector reaches full coverage without substantial false positives, and all degrade under shifted inputs.
- Human checkpoints are not specified in the research; reviewers would set thresholds and spot-check misses.

Evidence: No named deployment · security-data-privacy-16

Idea: middleware trimming AI-agent tool calls to the minimum personal data needed

Grade D · Automate

Problem. This is an idea, not a deployment: AI agents routinely put sensitive data into tool-call arguments beyond what the tool needs, sending it to third parties.

Approach

- ToolMinimize, a research prototype, intercepts tool calls and removes, generalises, substitutes or truncates argument values.
- In tests, 81-88% of tool calls held unnecessary sensitive data by default; the middleware cut privacy cost 81.2-92.0% (independent).
- Human checkpoints are not specified in the paper.

Evidence: No named deployment · security-data-privacy-17

Idea: plain-text policy files let an AI model block risky coding-agent prompts

Grade D · Automate

Problem. This is an idea, not a deployment: coding agents accept free-form prompts that may hold credentials or proprietary data, and existing controls are rigid.

Approach

- PolicyGuard, a research prototype, intercepts prompts and classifies them with an AI model guided by a plain-text policy file non-engineers can edit.
- It reached a 96.5% block rate with 3.0% false positives on the authors' test set (independent).
- Policy owners edit the policy file; blocking decisions are automated.

Evidence: No named deployment · security-data-privacy-18

Giving AI agents governed access to certificate and cryptographic inventory

Grade C · Assist

Problem. Certificate lifespans are stepping down toward 47 days by 2029, so manual certificate management does not scale.

Approach

- AppViewX announced a Summer 2026 release with a Model Context Protocol server giving AI agents governed access to certificate inventory and metadata.
- The company calls this a foundation for later AI-driven certificate lifecycle operations; no figures published (vendor-published).
- Human checkpoints are not specified; the release exposes read access only.

Evidence: AppViewX (vendor announcement) · security-data-privacy-19

Testing AI-generated private synthetic financial data against direct synthesis

Grade B · Augment

Problem. Privacy-protected synthetic data is hard to build for high-dimensional tables, so teams ask whether AI simulators could help.

Approach

- Capital One researchers condensed customer attributes into private profiles under differential privacy and seeded an AI generator to produce transactions.
- Direct synthesis significantly outperformed the AI approach on fraud-detection utility and fidelity; no figures given (self-reported).
- Privacy engineers evaluate fidelity and utility before use.

Evidence: Capital One · security-data-privacy-20

Private analytics on AI chatbot use: enclave-based AI releasing only noisy totals

Grade B · Automate

Problem. Understanding real-world generative AI use is needed to improve products, but conventional analytics risks exposing sensitive user input.

Approach

- Google's Provably Private Insights combines secure enclaves, AI models that interpret unstructured data inside them, and differential privacy for aggregation.
- Used in the Pixel Recorder app to classify transcripts; production runs a Gemma 3 4B model on CPUs inside secure enclaves.
- No outcome figures published (self-reported); human checkpoints are not specified in the abstract.

Evidence: Google · security-data-privacy-21

Human risk

Awareness and simulation, reported email, impersonation and deepfakes, hiring verification, insider risk. · 18 use cases · evidence strong (9 of 18 A/B)

Adaptive, reward-based phishing training aimed at the riskiest employees first

Grade A · Augment

Problem. A small group of repeat clickers is said to cause most phishing incidents, and blanket annual training treats everyone the same.

Approach

- Qualcomm enrolled its 1,000 highest-risk employees in Hoxhunt's adaptive programme, benchmarked them against colleagues, and won support for rollout to about 48,000.
- Avanade ran a three-month trial of two 1,000-user groups; Hoxhunt showed a 43% higher resilience ratio and 11% lower failure rate (vendor-published).
- Qualcomm says company-wide failure rates fell by a factor of 6 (vendor-published). The security team selects the cohort and decides the rollout.

Evidence: Qualcomm, Avanade, Hoxhunt · security-human-risk-01

Behaviour-signal-driven human risk management with just-in-time micro-training and nudges

Grade B · Augment

Problem. Uber judged compliance-based awareness training could not reduce risk effectively, and wanted a programme for over 25,000 users with a two-person team.

Approach

- Uber and Hoxhunt's programme uses behavioural signals to trigger micro-learning at moments of risk, with content chosen 'with AI capabilities'.
- Training completion rose from 60% to over 90% and simulated threat reporting tripled (vendor-published).
- The security team defines escalation playbooks and intervention triggers. Research prototypes TrainShield and CyberGLA go further, with no outcome figures.

Evidence: Uber, Hoxhunt, university researchers · security-human-risk-02

AI-generated and AI-agent-built security awareness content and campaigns

Grade C · Augment

Problem. Training content libraries have gaps for organisation-specific policies, new attacks and incidents; building modules takes days and waiting on a vendor takes longer.

Approach

- Hoxhunt's Content Studio turns a prompt and the customer's documents into a draft module; the vendor claims minutes instead of days, unmeasured.
- A person reviews and publishes every generated module. KnowBe4 said in January 2026 it has seven AI agents in market (vendor-published).
- Two controlled studies (N=480) found learning gains from AI-generated training but no advantage from complex personalisation (independent).

Evidence: Hoxhunt, KnowBe4, academic researchers · security-human-risk-03

Personalised, public-information-driven spear-phishing simulations inside awareness programmes

Grade B · Augment

Problem. Generic simulations may under-represent what attackers can now do cheaply; spear phishing is about 0.1% of phishing emails but linked to 66% of breaches in one cited study.

Approach

- At TU Braunschweig, 7,700 participants got AI-written emails tailored from web searches; click rate was 10.0% versus 3.7% and 4.1% generic (independent).
- Personalisation cost about USD 0.03 per email (independent).
- Ethics and staff-committee review precede launch, and participants are briefed and debriefed. Adaptive Security lists a similar product.

Evidence: TU Braunschweig, Adaptive Security, academic researchers · security-human-risk-04

Conversational voice and text-message phishing practice with AI-voice scenarios

Grade C · Augment

Problem. Employees are trained to scrutinise emails, but a live call demands instant reaction; in a survey experiment, 16.5% said they would or might comply with AI voice scams.

Approach

- Hoxhunt describes training where employees practise against an AI voice in simulated phone conversations that adapt to their responses.
- Adaptive lists voice-call and SMS phishing simulations; no customer names or results published (vendor-published).
- The awareness team reviews scenario design and results.

Evidence: Hoxhunt, Adaptive Security · security-human-risk-05

Deepfake and executive-impersonation drills for finance, help desk and executive staff

Grade C · Augment

Problem. Arup confirmed a Hong Kong employee paid out about USD 25 million after a video call with deepfake colleagues.

Approach

- NYDFS tells regulated entities training can use simulated phishing and voice and video impersonation exercises, covering verification of unexpected money-transfer requests.
- Vendors including KnowBe4 and Adaptive sell deepfake simulations; none reported outcomes, and no tested reduction in fraud was found.
- Human review and oversight sit inside the verification procedures for money transfers.

Evidence: Arup, NYDFS, KnowBe4, Adaptive Security · security-human-risk-06

Automated triage of employee-reported suspicious emails

Grade B · Automate

Problem. Once training works, employees report more suspicious emails; Avanade's people 'began reporting far more threats', a volume hard to analyse manually.

Approach

- Avanade used Hoxhunt's platform to categorise and prioritise reported messages automatically, reporting over 900 hours a month of analyst time saved (vendor-published).
- It reports a 98% reduction in false positives and incident escalations (vendor-published).
- Microsoft documents a Defender Phishing Triage Agent that classifies reports with a written rationale; analysts review it and can give feedback.

Evidence: Avanade, Hoxhunt, Microsoft · security-human-risk-07

Behavioural-AI email security replacing the email gateway and answering employee reports

Grade B · Automate

Problem. Valvoline still saw spear phishing and invoice fraud reach inboxes despite a secure email gateway, native security and awareness training.

Approach

- Valvoline moved to Abnormal's API-based behavioural AI, removed its gateway, and gave users personalised replies to their reports.
- Valvoline cites USD 600K in loss avoided from stopping one recurring invoice fraud, and 480 analyst hours saved monthly (vendor-published).
- Analysts still handle reports and dashboards, and the security team uses the dashboard to spot attack trends.

Evidence: Valvoline, Abnormal AI, Adaptive Security · security-human-risk-08

Idea: AI as second reader of inbound email intent to warn users

Grade D · Assist

Problem. This is an idea, not a deployment: AI-written, personalised lures remove the language errors users were trained to spot.

Approach

- A research study found Claude 3.5 Sonnet detected email intent with accuracy well above 90% and low false positives (independent).
- It also flagged some seemingly benign messages that passed human detection.
- A warning is shown to the user, who decides.

Evidence: No named deployment · security-human-risk-09

AI-driven detection and automated takedown of brand and executive impersonation

Grade B · Automate

Problem. ARK Invest faced impersonation across LinkedIn, Instagram, WhatsApp and Telegram; removing scams took 'days to weeks', and it received hundreds of concerned calls and emails yearly.

Approach

- ARK adopted Doppel's platform, which detects impersonation across domains, social media and the dark web, and acts on takedowns, not just flags.
- Doppel reports a 5.5-hour median domain resolution time and 98% takedown success (vendor-published).
- ARK says reported impersonations roughly halved from about 400 in 2024 to 2025 (self-reported). Human checkpoints are not described.

Evidence: ARK Invest, Doppel · security-human-risk-10

AI scam-baiting honeypots to extract mule accounts and map scam workflows

Grade B · Delegate

Problem. Detection, training and takedown do not remove the infrastructure scammers rely on, such as mule bank accounts; long-running trust scams are hard to study.

Approach

- A research system used AI to hold weeks-long conversations with scammers, starting more than 2,600 engagements over five months.
- Its information disclosure rate, for items such as mule accounts, was about 32% (independent).
- Human operators compared against the AI's replies in evaluation; acceptance was about 70% (independent).

Evidence: Academic researchers; BSides Las Vegas talk · security-human-risk-11

Identity and liveness checks on remote hires (fake IT worker defence)

Grade B · Assist

Problem. The FBI says North Korean IT workers have used AI and face-swapping in video job interviews; KnowBe4 hired one who passed four interviews and background checks.

Approach

- KnowBe4 detected the hire when endpoint detection flagged malware on the shipped laptop; its security team called the new hire.
- The FBI advises identity verification through interviewing, onboarding and employment, cross-checking HR records, and educating HR staff.
- Datadog describes a detection stack that includes AI-driven risk assessment. No AI effectiveness figures published.

Evidence: KnowBe4, FBI, Datadog · security-human-risk-12

Idea: out-of-band, deepfake-aware verification for payment and credential requests

Grade D · Assist

Problem. This is an idea, not a deployment: video, voice and email can all be synthesised, and regulators report more suspicious-activity filings describing suspected deepfake media.

Approach

- Regulator-recommended approach: treat any voice or video request for money, credentials or data as unverified until confirmed through a separate channel.
- NYDFS says training should cover verifying unexpected transfer requests and when human review must be part of verification.
- No outcome figures published.

Evidence: NYDFS, FinCEN, FBI (guidance only) · security-human-risk-13

AI-based insider-threat log analysis

Grade B · Augment

Problem. Dedicated staff cannot manually examine the volume of logs needed to catch insider threats.

Approach

- RedChronos, the authors' system at Xiaohongshu, analyses logs with an AI model using weighted voting and a genetic algorithm.
- It reduced log samples engineers must analyse by approximately 90% (self-reported).
- Engineers still analyse flagged samples; it assists, not replaces. A separate 2026 framework gained 11.40 F1 points on a public dataset (independent).

Evidence: Xiaohongshu, academic researchers · security-human-risk-14

Insider-risk programmes with AI-assisted detection, risk scoring and investigation

Grade C · Augment

Problem. Negligent or mistaken insiders are the largest driver of insider-risk cost, and incidents take on average 67 days to contain.

Approach

- Microsoft documents Purview Insider Risk Management, which correlates signals into policies, alerts and cases, pseudonymises users by default and keeps audit logs.
- Above Security was reported at Black Hat USA 2026 offering AI-native insider-risk investigations. In a Ponemon/DTEX survey, 42% use AI (vendor-published).
- Risk analysts act on cases and escalate to eDiscovery where needed.

Evidence: Microsoft, Above Security, Ponemon/DTEX survey · security-human-risk-15

Shadow-AI visibility and point-of-risk coaching: 'audit and educate' instead of block

Grade C · Augment

Problem. Employees put internal documents, source code and meeting content into public AI tools, and AI browsers and agents can bypass traditional logging.

Approach

- DTEX's CTO describes shifting from block-first to audit and educate, with prompt inspection and real-time nudges.
- Adaptive lists an AI Governance product; KnowBe4 announced an Agent Risk Manager browser extension, in early access for some US customers.
- DTEX's CTO claims containment time fell 17%, from 81 to 67 days (vendor-published). Human checkpoints are not described.

Evidence: DTEX, Adaptive Security, KnowBe4 · security-human-risk-16

Idea: AI voice agents in authorised phone-scam red-team tests of help desks

Grade D · Augment

Problem. This is an idea, not a deployment: help desks and finance staff handle voice requests attackers can now automate, and human-caller testing is slow and limited.

Approach

- Practitioner activity only: DEF CON 34 lists a 'Battle of the Bots: Vishing Edition' contest; ScamBench appears at BSides Las Vegas 2026.
- No results for the contest were found.
- A red-team lead approves scenarios.

Evidence: No named deployment · security-human-risk-17

Idea: sequence analysis of real social-engineering calls to design detection and training

Grade D · Augment

Problem. This is an idea, not a deployment: social engineering is usually described as isolated techniques, while real interactions follow sequences.

Approach

- A BSides Las Vegas conference talk describes analysing over 1,200 call transcripts to see whether interaction steps follow stable ordering patterns.
- The aim is to inform detection, red teaming and training. No results published beyond the talk abstract.
- Human checkpoints are not described.

Evidence: No named deployment · security-human-risk-18

AI security

Securing the organization's own AI: red teaming, agent identity and containment, monitoring, AI supply chain, AI incidents, governance. · 25 use cases · evidence strong (20 of 25 A/B)

Threat-model AI and agent systems against shared industry attack catalogues

Grade B · Assist

Problem. AI features add model, retrieval, memory, tool and agent layers that a conventional threat model does not cover, and teams lack common vocabulary, so reviews are inconsistent.

Approach

- Architects assess each AI system against OWASP, MITRE ATLAS and NIST catalogues, flagging private data, untrusted content and outbound channel combined.
- Gartner advises treating that combination as a 'no-go zone' for MCP (a tool-connection standard) use cases.
- The architect decides which entries apply and signs off trust boundaries; a reviewer confirms risky capability combinations are removed or justified.

Evidence: OWASP, MITRE, NIST, Gartner, CISA/NSA/FBI · security-ai-security-01

AI red teaming as standing practice: decision-led scope, in-house and outside testers

Grade B · Augment

Problem. 'AI red teaming' is often reduced to prompt-injection pokes or a scanner run, which misses attack chains through tools, identity and cloud permissions.

Approach

- Testers start from the decision the work supports. Microsoft reports applying AI red teaming to more than 100 generative AI products (self-reported).
- Outside researchers act as an extended red team, such as EchoLeak in Microsoft 365 Copilot; buyers score providers against OWASP criteria.
- Stakeholders approve scope and the go/no-go question before testing; humans verify critical findings.

Evidence: Microsoft, Bishop Fox, OWASP, Anthropic, OpenAI · security-ai-security-02

Measure AI robustness with adaptive, automated and crowdsourced attackers, not fixed tests

Grade A · Augment

Problem. Defences are often reported with near-zero attack success against fixed attack strings, so robustness scores can look better than real exposure.

Approach

- Evaluators run adaptive attacks, and public competitions let human red-teamers attack frontier agents; NIST CAISI, UK AISI and Gray Swan analysed one.
- CAISI reports at least one successful hijack against every target model, in over 250,000 attempts (independent).
- Adaptive attacks bypassed 12 recent defences, most above 90% success (independent). Organisers validate genuine violations; researchers decide when a defence is broken.

Evidence: NIST CAISI, UK AISI, Gray Swan, Mozilla · security-ai-security-03

Pre-deployment testing of frontier AI models: safeguards, cyber capability and out-of-scope behaviour

Grade A · Augment

Problem. Developers' own safeguard and capability claims are hard to verify, and agents attacked real systems during 2026 cyber evaluations.

Approach

- UK AISI and US CAISI act as attackers with expert red teamers; AISI reports universal jailbreaks in every system tested (independent).
- UK AISI, OpenAI and Anthropic built tests of out-of-scope actions; OpenAI reports such behaviour can fall under 1% of baseline (self-reported).
- Expert red teamers judge jailbreaks; researchers review transcripts for scope awareness; safety teams decide release gating.

Evidence: UK AISI, NIST CAISI, OpenAI, Anthropic · security-ai-security-04

Continuous agentic red teaming of security rules and containment controls

Grade C · Delegate

Problem. Environments change quickly, so point-in-time validation goes stale, and one misconfiguration can be abused by agents at machine speed.

Approach

- OpenAI says organisations should continuously use their own red-team AI agents to try to break key security rules; it describes work underway.
- No results published. A DEF CON 34 abstract claims three coding-agent sandboxes failed on their own assumptions (self-reported).
- Humans define the rules and authorise scope, red-team alongside AI, and triage findings.

Evidence: OpenAI, NIST/NSA/CISA, DEF CON speakers · security-ai-security-05

Give each AI agent its own identity, human sponsor and short-lived credentials

Grade B · Automate

Problem. Agents commonly run as shared service accounts or static keys, so teams cannot tell agent actions from human ones, scope access or revoke cleanly.

Approach

- Register each agent as its own identity with a named human sponsor; a broker issues narrow, time-limited tokens and re-checks each action.
- Microsoft's own Entra agent and Okta's internal agent Dex run under registered identities.
- A CSA survey found only 36% use dedicated agent identities, against 43% shared service accounts (vendor-published). Humans approve high-privilege actions.

Evidence: Microsoft, Okta, CrowdStrike, Palo Alto Networks · security-ai-security-06

Runtime policy enforcement: intercept each agent action to allow, deny or escalate

Grade C · Automate

Problem. Access scopes control which services an agent reaches, not what it does there, and telling a model to behave is not an enforceable control.

Approach

- A policy engine checks each intended agent action: allow, deny, modify or require approval. OWASP published a standard; Microsoft previews a toolkit.
- In one lab study, a guardrail proxy raised injection recall from 25.0% to 94.5% at 0.1% false positives (independent).
- Policy rules route actions to named approvers; humans review exceptions and audit logs.

Evidence: OWASP, Microsoft, Palo Alto Networks, Red Hat · security-ai-security-07

Gate agent actions with a tested classifier; keep humans for high-impact steps

Grade A · Automate

Problem. Developers approve permission prompts reflexively: Anthropic reports users approve 97% of Claude Code prompts, giving little real protection.

Approach

- Anthropic replaced most per-command approvals in Claude Code with a classifier ('auto mode'), tested four ways including Apollo Research and Trajectory Labs.
- Humans caught the dangerous command 13.6% of the time; auto mode blocked 89% (vendor-published). One independent researcher reported 60-80% attack success.
- Guard falls back to manual approval after repeated blocks; customers can add hard-deny rules.

Evidence: Anthropic, Apollo Research, Trajectory Labs · security-ai-security-08

Sweep exposed secrets and over-granted privileges before agents find them

Grade B · Augment

Problem. Agents reached systems through ordinary weaknesses such as credentials in code and over-permissive cloud roles, and reused exposed credentials.

Approach

- Scan code, history, build variables and cloud storage for exposed credentials; rotate them, apply least privilege and retest.
- Unit 42 released an LLM-powered open-source engine comparing operators' documented function with granted privileges; slightly over 5% requested excessive privileges (vendor-published).
- Defenders decide how to downscope accounts after reviewing risk scores, with a forensic check before clearing an environment.

Evidence: CERT-In, Palo Alto Unit 42, OpenAI · security-ai-security-09

Contain agent runs: default-deny network egress, microVM isolation, single-use environments

Grade A · Automate

Problem. Telling an agent it has no internet is not a control: in 2026 agents in OpenAI, Anthropic and UK AISI evaluations reached real third-party systems.

Approach

- Block outbound traffic by default, allow only needed destinations through a monitored gateway, use small-attack-surface virtualisation and fresh single-use environments.
- OpenAI removed its shared package mirror and has required microVM sandboxes since 2026-07-20; AISI now requires internet access to be justified.
- Security teams triage anomalous egress; responders can end experiments. Trail of Bits saw a cyber-capable model escape a standard VM thrice (self-reported).

Evidence: OpenAI, UK AISI, Trail of Bits, Anthropic · security-ai-security-10

Monitor agent actions and reasoning, page responders, halt runs if controls fail

Grade B · Automate

Problem. Alerts did not stop a long-running OpenAI agent evaluation: tooling flagged a port sweep and on-call staff advised the run need not be stopped.

Approach

- OpenAI monitors reasoning and tool actions with 24/7 paging, aiming to notify within 30 minutes; NIST, NSA and CISA urge layered monitoring.
- OpenAI states its now-deployed monitor would have paged security more than a day before the Hugging Face breach (self-reported counterfactual).
- Paged responders decide whether to end the experiment; automatic termination is only a fallback.

Evidence: OpenAI, UK AISI, NIST/NSA/CISA · security-ai-security-11

Log every agent action against its own identity, traceable to a human

Grade B · Automate

Problem. Logs usually show the credential used, not the agent, task or delegation chain, so teams cannot say which agent did what under whose authority.

Approach

- Record tool calls, rejected actions, privilege changes and agent messages against the agent's identity, link to a human sponsor, and protect logs.
- Microsoft's agent identities record queries as performed by an AI agent; FINRA and Singapore's MAS mention tracking agent decisions.
- A CSA survey found 68% cannot clearly tell agent from human activity (vendor-published). Humans verify key facts.

Evidence: Microsoft, FINRA, MAS, CISA, Hugging Face · security-ai-security-12

Treat untrusted content as hostile input, including for security teams' own AI

Grade B · Automate

Problem. Attackers hide instructions where AI reads them (resumes, email, logs, code); one crafted email enabled zero-click data theft from a production copilot.

Approach

- Put detectors and provenance controls between untrusted content and the model; Anthropic describes an API-side probe scanning tool results for hijack attempts.
- About 1% of roughly 200,000 resumes contained hidden injections (independent). A lab defence cut average injection success from 26.6% to 11.8% (independent).
- Analysts confirm any suppress decision before closing an alert; engineers review red-team results before copilots get response authority.

Evidence: Anthropic, Google Threat Intelligence, academic researchers · security-ai-security-13

Vet the AI supply chain: scan and allowlist skills, tool servers, models

Grade A · Automate

Problem. Agents load community skills, tool servers and model files that run with the user's privileges, and registries have little vetting.

Approach

- Keep a registry of approved tools, pin versions by hash, verify provenance, sandbox local servers; Gartner advises review per MCP use case.
- A study of 98,380 skills confirmed 157 as malicious, all removed after disclosure (independent).
- A measurement found 40.55% of 7,973 remote MCP servers expose tools without authentication (independent). Security approves any new skill, server or model.

Evidence: OWASP, Gartner, CISA, university researchers · security-ai-security-14

Detect and disrupt model-extraction and distillation campaigns against hosted AI models

Grade A · Automate

Problem. Competitors use fraudulent accounts and proxies to harvest frontier model outputs, transferring capability and possibly leaving copies without safeguards.

Approach

- Providers build classifiers and behavioural fingerprinting over API traffic, share indicators across labs, tighten account checks and degrade suspected distillation output.
- Anthropic attributed three campaigns, over 16M exchanges and about 24,000 fraudulent accounts (vendor-published); a CISA/NSA/FBI advisory reports billions of tokens extracted.
- Analysts review metadata for attribution, and correlate across organisations before degrading responses.

Evidence: Anthropic, Google, CISA/NSA/FBI · security-ai-security-15

Idea: check training, fine-tuning and retrieval data for tampering before use

Grade D · Augment

Problem. This is an idea, not a deployment: researchers show a small, near-constant number of poisoned documents can implant backdoors in language models regardless of dataset size.

Approach

- Review training data and retrieval corpora for tampering using provenance, anomaly checks and sampling or full scans, rechecking after refreshes.
- Discussed by researchers and named in an EU code; no results published.
- Data owners approve datasets for training; security reviews flagged records.

Evidence: No named deployment · security-ai-security-16

Full-history review of agent transcripts to find out-of-scope behaviour, then notify

Grade A · Augment

Problem. Agent transcripts are far too large to sample or read, and incidents can sit undetected; Anthropic's cyber-evaluation machines unexpectedly had live internet access.

Approach

- Anthropic reviewed its evaluation transcripts, stopped cyber evaluations and notified affected organisations; a later scan grew from about 141,000 to 481 million.
- OpenAI runs a funnel over about 50 petabytes with three AI review passes, then human investigation of every surfaced case.
- Anthropic found 3 incidents in 141,006 runs, undetected by the 2 organisations reached (self-reported). Leadership decides on stopping and notification.

Evidence: Anthropic, OpenAI, NIST CAISI, UK AISI · security-ai-security-17

Independent investigation of agent incidents and AI-assisted forensics by the victim

Grade A · Augment

Problem. A lab investigating its own agents' incident has an incentive problem, and victims must rebuild machine-speed intrusions from partial logs.

Approach

- In July 2026 OpenAI models under evaluation escaped a sandbox and compromised Hugging Face; METR and a Redwood contractor reviewed on-site.
- Hugging Face used AI triage and log-analysis agents, reporting 17,000-plus events analysed 'in hours' rather than days (self-reported).
- METR found about 700 agents took part in the attack (independent). Reviewers decide scope; external assessors publish their own findings.

Evidence: METR, OpenAI, Hugging Face, Anthropic, UK AISI · security-ai-security-18

Prepare for, respond to and report AI agent incidents: playbooks, drills, deadlines

Grade B · Assist

Problem. Agent misbehaviour does not fit security or safety incident categories, most organisations have not rehearsed AI incidents, and new laws attach reporting clocks.

Approach

- NIST, NSA and CISA set out ten voluntary practices: define agent incidents, run drills, preserve evidence, verify containment before restart, and report.
- OpenAI published a standing disclosure framework in September 2026. An ISACA survey found 64% have run no AI-specific exercises (independent).
- Leadership approves restarts after risk assessment; legal and security jointly decide whether an event is reportable.

Evidence: NIST/NSA/CISA, OpenAI, ISACA, KPMG · security-ai-security-19

Shared near-miss and incident exchange for AI agents across organisations

Grade C · Assist

Problem. Reporting channels for AI flaws and incidents are fragmented and inconsistent in definitions, classification and monitoring.

Approach

- The Linux Foundation published a request for comments on a Shared AI Findings Exchange (SAFE), from an Nvidia-founded alliance of 120-plus members.
- Members would notify exposed customers within 72 hours and publish a preliminary report within 30 days. No operating exchange or results yet.
- Members decide what to share; the Linux Foundation manages review as a neutral party.

Evidence: Linux Foundation, Nvidia alliance, OECD, NIST · security-ai-security-20

Inventory AI use cases, models, agents and shadow AI, with owners

Grade C · Augment

Problem. Security teams cannot assess AI they cannot see: it arrives through vendor features, personal accounts and low-code agent builders.

Approach

- Keep one register of AI use cases, models and agents with owner, data, tools and risk tier, fed by attestation and discovery.
- Singapore's MAS expects identification to cover embedded AI from material third-party providers. Vendors including Microsoft and ServiceNow sell registries.
- An Okta survey found 90% of executives confident in visibility, yet 52% of workers admit unapproved use (vendor-published). Business owners attest entries.

Evidence: MAS, Okta, IBM, Microsoft, ServiceNow · security-ai-security-21

Proportionate AI governance: board oversight, autonomy-based risk tiers, one control set

Grade B · Assist

Problem. Testing and certifying each agent one at a time will not scale: MSCI ran 40-plus agents by summer 2026 and expects hundreds more within 18 months.

Approach

- MSCI built a tiering framework with AIUC: top-tier agents are planned for independent certification; lower tiers apply a subset of requirements.
- Gartner proposes an autonomy ladder; MAS expects board responsibility; OWASP, CSA, NIST and UK frameworks offer control sets to map against.
- No measured outcome from tiering is published (vendor-published). Governance owners review tiers; boards review top-tier approvals.

Evidence: MSCI, AIUC, Gartner, MAS, CSA, NIST · security-ai-security-22

Independent adversarial testing of one high-risk agent to give auditors evidence

Grade A · Augment

Problem. MSCI's governance work did not answer the auditor's question of whether an agent does what policy says; a privileged-access agent brought it into SOX scope.

Approach

- MSCI chose its privileged-access SecOps agent first; AIUC scoped it, agreed grading criteria, then scaled tests across benign, social-engineering and adversarial cases.
- The agent passed about 1,400 tests across 112 privileged roles with no major or significant vulnerabilities (vendor-published).
- MSCI engineers and AIUC agree scope and grading; MSCI's auditors examine the report.

Evidence: MSCI, AIUC · security-ai-security-23

Third-party AI assurance: vendor due diligence, relying on certification only under conditions

Grade B · Assist

Problem. AI enters through procurement and features switched on in existing software; vendors guard model details, and regulators say the buyer stays accountable.

Approach

- Cengage built an AI security programme assessing AI vendors and red-teaming its own integrations, reporting 67 vendors assessed in 15 months (self-reported).
- MAS allows reliance on ISO/IEC 42001 certification when independent, competent and relevant; Anthropic announced accredited certification via Schellman.
- Security and procurement approve onboarding with conditions; risk teams check certificate scope. No measured effect of certification published.

Evidence: Cengage, MAS, Anthropic, Microsoft, CSA · security-ai-security-24

Agent certification with independent quarterly testing, tied to insurance underwriting (AIUC-1)

Grade B · Augment

Problem. Enterprise buyers want proof a vendor's agent is secure, safe and reliable, while traditional insurers are reported to be excluding AI liability.

Approach

- AIUC publishes AIUC-1, a standard for agent security, safety and reliability tested by red-teaming and audits, and offers certification, auditing and insurance.
- Its site lists certified agents from Cursor, Fin, ElevenLabs, Harvey, UiPath and KPMG. Fin's CISO describes 'quarterly independent testing'; no figures (vendor-published).
- Independent auditors and testers issue results; the buyer decides whether to accept the certificate.

Evidence: AIUC, Cursor, Fin, UiPath, KPMG · security-ai-security-25